

NON-HUMAN IDENTITY LAB · EDITION 2

Machine identities, tested in public

67 cases on service accounts, secrets, privileged access and AI tools, with the guesses, the mistakes and the market in 2026

67
cases

57
guesses matched

10
guesses wrong

20
controls nothing noticed

Roshan Trivedi

10 November 2026 · roshantrivedi.co.in/nhi-lab/ · CC BY 4.0 · All data is made up

READ THIS FIRST

Before you start

Who it is for, how to read it, and how to read a case diagram.

Who this is for

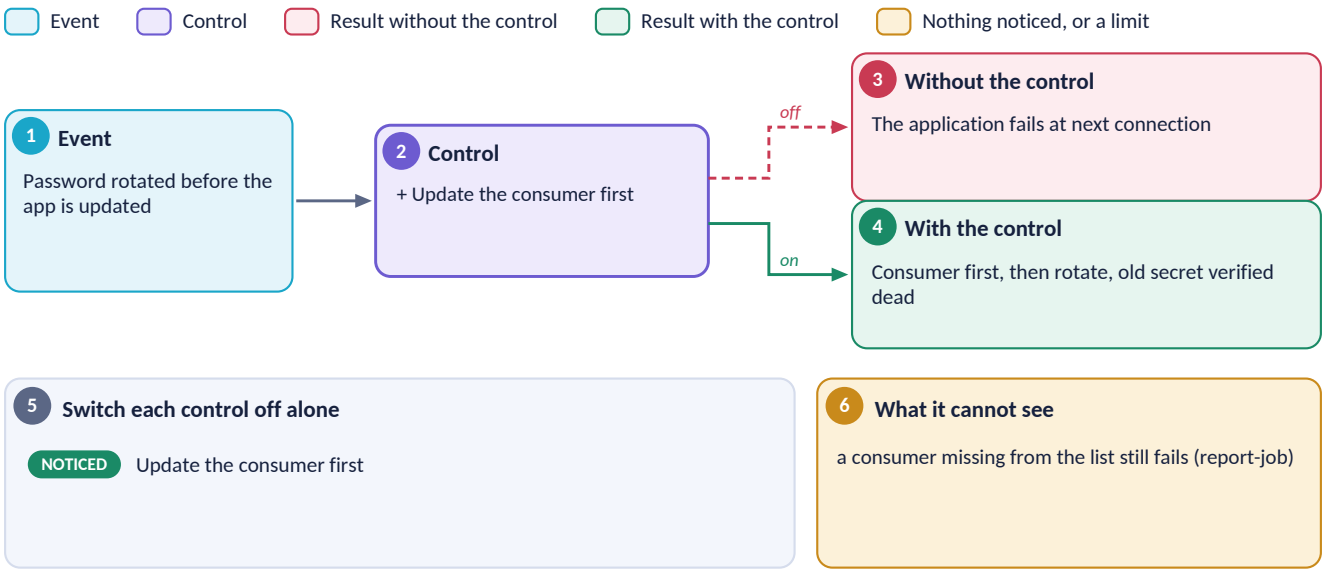
- Platform owners and IAM or PAM engineers who run service accounts, vaults, pipelines and AI integrations.
- Security architects who need to choose controls and explain the choice.
- Auditors and risk owners who want to see what was tested and what was not.
- Anyone who has been told that machine identities outnumber people and wants to know what to do about it.

How to read it

If you have	Read	You will get
10 minutes	Chapter 2	The findings in plain words and one picture of all 67 cases.
An hour	Chapters 1 to 4, then the cases for the step you care about	The method, the framework and the evidence for one step.
An afternoon	The whole book	Every case with its own workflow diagram, the market in 2026, what is missing and what comes next.

How to read a case diagram

Each of the 67 cases has the same kind of picture, so once you have read one you can read them all. The numbers on the boxes match the numbers below. This example is case N-R14-15, which is about rotating a password in the wrong order.



1. **Event.** What happens in the case, in one line.
2. **Control.** The rule or check being tested. Some cases test more than one.
3. **Without the control.** What the model did when the control was off. The dashed red line shows the path.
4. **With the control.** What it did when the control was on.
5. **Switch each control off alone.** If switching one control off changes the result, a check noticed it (green). If nothing changes, the control was masked by another or did not matter in this case (amber).
6. **What it cannot see.** The limit I recorded. Grey and empty means I found none, which is not the same as there being none.

Chain tests look a little different. The top row shows the attacker's links. A flag under a link shows where a control acts: it stops the attacker there, only reports, arrives too late, or has no effect.

A note on the data

Every account, bank and number in this book is made up. The bank is called Kaveri Finance and does not exist. Nothing relates to any employer, client or real company. The models are small and run in memory.

What changed since edition 1

The first edition had 27 cases and 21 pages. This one has 67 cases, a workflow diagram for each, the framework, a dated market chapter, a method chapter that lists my mistakes, an audit appendix, a roadmap and a glossary.

Contents

Before you start . . . 2
Who this is for . . . 2
How to read it . . . 2
How to read a case diagram . . . 3

1. The problem and what I tested . . . 6
Why machine identities . . . 6
The question . . . 6
Why a lab, and why guesses first . . . 6
What is in scope and what is not . . . 7
What you will find in the book . . . 7

2. The short version . . . 8
What I found . . . 8
All 67 cases on one page . . . 9
What I would do on Monday . . . 9

3. What we did . . . 10
The approach in one paragraph . . . 10
When it happened . . . 10
The procedure in one picture . . . 11
The steps, with what you should see . . . 11
What the words mean . . . 12
The numbers . . . 12
What went wrong . . . 12
Checking it again on 2 November 2026 . . . 13
What this method cannot tell you . . . 13

4. A framework for machine identities . . . 14
The seven steps . . . 14
Step 1 in detail: the inventory . . . 15
Deciding what to do with each credential . . . 15
Retire in stages . . . 16
When a secret leaks . . . 16
Standards for new credentials . . . 16
Metrics . . . 17
OWASP Non-Human Identities Top 10 (2025) . . . 17
What is left for you to set . . . 18

5. Step 1: Find . . . 19

6. Step 2: Own . . . 23

7. Step 3: Limit . . . 28

8. Step 4: Store and issue . . . 39

9. Step 5: Rotate and expire . . . 46

10. Step 6: Watch . . . 52

11. Step 7: Retire and respond . . . 57

12. Results . . . 62

By framework step . . . 62

The ten wrong guesses . . . 62

Controls that nothing noticed . . . 63

Limits I recorded . . . 64

What the numbers do not say . . . 66

13. The market in 2026 . . . 67

How to read the labels . . . 67

The timeline . . . 67

Who bought whom in 2026 . . . 68

AI agents get their own identity objects . . . 68

Standards and guidance . . . 68

The Salesloft Drift incident . . . 69

Other signals, with lower weight . . . 69

What I think the market still misses . . . 69

What I did not check . . . 70

14. What is missing . . . 71

15. Roadmap . . . 72

Rules I follow for every item . . . 73

Appendix A: Guess files and hashes . . . 74

Appendix B: Audit table . . . 76

Appendix C: Sources . . . 79

Appendix D: Glossary . . . 81

About the author . . . 82

CHAPTER 1

1 The problem and what I tested

Why machine identities, what I asked, and what is in and out of scope.

Why machine identities

Ask a security team how many people have accounts and you will get a number. Ask how many service accounts, API keys, CI tokens, certificates and AI-tool grants they have, who owns each one and when each stops working, and the room goes quiet.

Palo Alto Networks says in a 2026 press release that machine identities outnumber human ones by more than 80 to 1 [S1]. That is a vendor statistic, and I could not find the study behind it. I use it as a reason to look, and I do not rely on the number.

A real case shows why it matters. Google's threat intelligence group reported that from 8 August 2025 an actor used stolen OAuth tokens tied to the Salesloft Drift app to read data in customers' Salesforce accounts. Salesloft and Salesforce revoked all active tokens on 20 August 2025 [S11]. Nobody had to guess a password. Someone held a token that still worked.

The question

> **What I set out to test**
> Do the controls people recommend for machine identities stop the failures they are meant to stop, and would anything tell you if one stopped working?

Why a lab, and why guesses first

I cannot test a vendor's product on a vendor's data. What I can test is the reasoning behind a control. If this rule exists, does this failure stop? And if I switch the rule off, does anything notice?

So each case is a small model of one control and one failure. I write down what I expect with the control off and on. I lock the file with a SHA-256 hash and commit it before any code exists. Then I write the model, run it, and compare. A test you design after seeing the result will agree with you. A committed guess file makes it visible if I changed my mind.

What is in scope and what is not

In scope	Out of scope
Finding service accounts, owners, rotation, front doors for new identities, just-in-time and recorded privileged access, break-glass accounts, vendor access, and AI tools that hold credentials. Chain tests that join several failures.	Any real product. Any real company's data. Performance and cost. Legal or regulatory compliance. Kubernetes workload identity. Cloud-specific key habits.

What you will find in the book

- **Chapter 2** gives the findings and a one-page map of all 67 cases.
- **Chapter 3** says exactly what I did, in order, with dates and the mistakes I made.
- **Chapter 4** turns the evidence into a seven-step framework you can use on your own estate.
- **Chapters 5 to 11** hold the cases, one workflow diagram each, grouped by framework step.
- **Chapter 12** gives the results, the wrong guesses, the controls nothing noticed and the limits.
- **Chapter 13** covers the market in 2026, with a date and a source for every fact.
- **Chapters 14 and 15** say what is missing and what comes next.

CHAPTER 2

2 The short version

The findings in plain words, and a map of every case.

67	57	10	20	33
cases in four runs	guesses matched	guesses wrong	cases with a control nothing noticed	cases with a recorded limit

What I found

1. Most of my guesses held, which is weaker evidence than it sounds.

57 of 67 guesses matched. I wrote the guesses and the models, so a match shows that my reasoning is consistent. It does not show that a product behaves this way.

2. Ten guesses were wrong, and the wrong ones are the useful ones.

Five were about counting (S-R17-05, N-R14-07, N-R18-01, S-R17-09, P-R15-22). In two of those I never said what I was counting. Five were about which control does the work, or whether one covers another (N-R14-25, C-R16-C01, P-R15-06, P-R15-12, S-R17-08). Each is recorded with the right answer next to it.

3. In 20 cases a control sat there and nothing noticed when it was switched off.

In round 19 I split these into two kinds. Either another control was doing the same job, or the control had no effect on what the case counts, as with logs, reviews and thresholds. A control no check notices is one you cannot tell is working. Decide which it is before you rely on it or remove it.

4. A control that reports is not a control that stops.

In three chain tests an alert reported the attack after it happened, and a different control stopped it (C-R16-C05, C-R16-C06, C-R16-C17). Count the two separately.

5. Order decides whether a change causes an outage.

Update the consumer, then rotate, then prove the old secret is dead (N-R14-15, N-R14-20, P-R15-25). The shortcut caused 12 outages in one case and left 2 live old secrets in another.

6. A named owner did the most work.

Ownership stopped a chain at its first link (C-R16-C01) and turned silent risks into tickets (N-R14-09, N-R14-18). Everything else in the framework depends on knowing who answers for an identity.

7. Every case has a limit, and 33 of 67 have one written down.

Several controls accept a sign-off as text: an attestation, a break-glass reason, a ticket number. If the text is not checked against a system, the control checks that someone typed something.

All 67 cases on one page

One square per case, grouped by the framework step it tests. Green means my guess matched. Red means it was wrong. An amber dot means a control in that case was one nothing noticed. A dark corner means I recorded a limit.

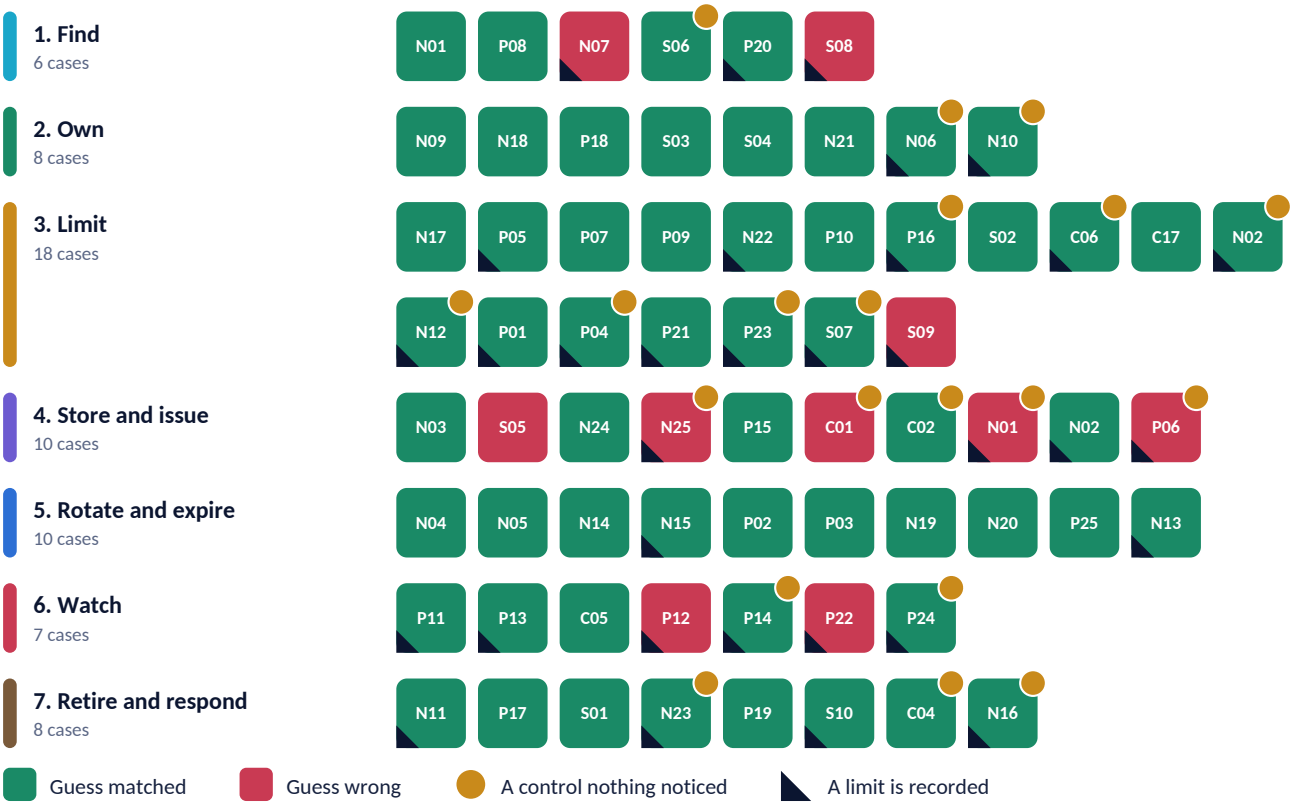


Figure 2.1 The 67 cases by framework step. Letters and numbers match the case ids in Chapters 5 to 11 (N01 is N-R14-01).

What I would do on Monday

If you take only one page from the book, take this one. Each line is a check you can do without buying anything.

1. Pick one source of service accounts you do not scan yet, and add it to the inventory (find).
2. List identities with no named owner. Ask the platform owner to claim or stage them for disable (own).
3. Look at your front door for new service accounts. Does it refuse one with no owner, scope or end date (own, limit)?
4. Take the last rotation you did and test that the old secret is refused (rotate).
5. Find the person who would see a break-glass sign-in tonight, and ask what they would do (watch).
6. Write down which of your controls would go unnoticed if you switched it off (all steps).

How far to trust all of this

The guesses and the models are mine. The results show that my reasoning holds together. They do not show that a product behaves this way. Chapter 3 says what the method cannot tell you.

CHAPTER 3

3 What we did

The procedure, the dates and the mistakes. Enough detail to repeat it.

The approach in one paragraph

Pick a failure and a control that should stop it. Write what I expect with the control off and on. Hash the guess file and commit it. Only then write a small in-memory model of the control, run it twice, and compare. Switch each control off alone to see whether anything notices. Write down what the control cannot see. Run it again on a second machine and compare the output.

When it happened

Date	What happened
31 October 2026	The use-case catalogue reached 187 rows (193 after six gap rows were added later). Draft guesses were written for rounds 14, 15 and 17. Nothing was hashed or run.
2 November 2026, first run	Guess files hashed and committed on the Mac, then the models were written and run. 24 must-run cases and 3 gap cases from 2026 incident reports: 27 in all.
2 November 2026, second-run guesses	19 more cases: 13 stretch cases and 6 chain tests. Hashed on the Mac (40c2f87c…) and committed as 78d7e3e before any code.
2 November 2026, second run	Code and results committed as 05235fe. The Mac output matched the build sandbox exactly.
2 November 2026, publishing	The lab page with 46 animated cases, this book, a 54-second silent video, and the framework, market, method, audit, roadmap and explainer pages.
10 November 2026, third run	2 more cases, NHI4 and NHI8. Guesses committed as e50df1b, code and results as ce3c57e. The Mac output matched the sandbox.
10 November 2026, fourth run	The 19 queued cases. Guesses hashed (729e16f2…) and committed as a2dc1fd before any code. Code and results committed as cbec7a8. The Mac results file had the same SHA-256 as the sandbox one.

The procedure in one picture

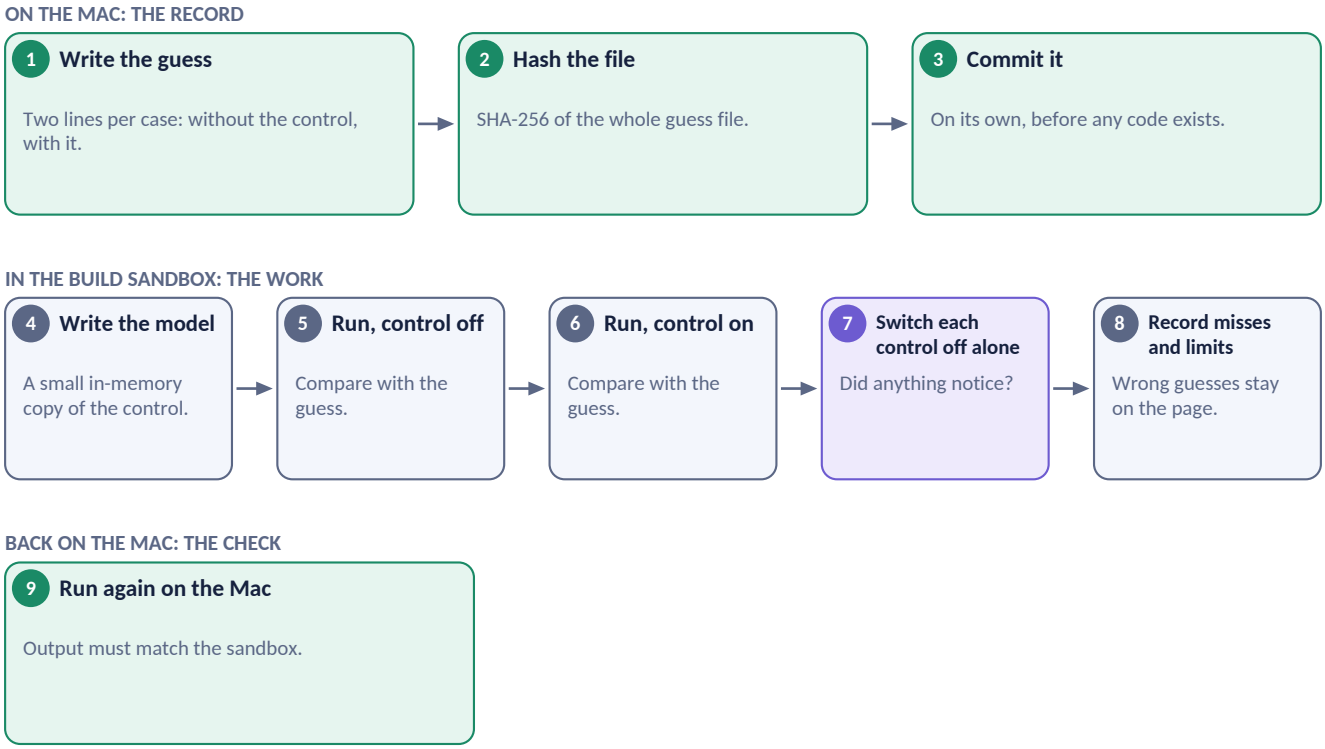


Figure 3.1 Nine steps in three places. The rule that matters is that code comes after the commit. The numbers match the table below.

The steps, with what you should see

#	Step	Expected result
1	**Write the guess.** Numbers, not "better". Two lines per case.	A guess file. Nothing has been run.
2	**Hash the guess file.** `shasum -a 256 guesses.md` on the Mac. Give it a file name, or the command waits for input.	A 64-character hash.
3	**Commit the file alone**, then note the commit.	A commit from before the code exists.
4	**Write the model.** In memory, made-up data only (a fictional bank, Kaveri Finance).	Code that runs with no network and no real system.
5	**Run with the control off.** Compare each result with the guess.	A match, or a mismatch recorded with both numbers.
6	**Run with the control on.** Compare.	A match, or a recorded mismatch.
7	**Switch each control off alone.** If the result does not change, no check noticed that control.	"Noticed" or "masked" for each control.
8	**Write down the limit.** What can the control not see?	A limit line, or a note that I found none.
9	**Run again on a second machine** and compare the output.	Identical output. If not, stop and find out why.

> **Careful with the commit**
> Commit only the guess file before the code. On my Mac I once ran git add with no paths, and I ran a hash command with no file name, which waits for input. Both were harmless and both cost time.

What the words mean

Term	Meaning in this book
Match	The result equals what the guess said, in both runs.
Wrong guess	A number or a ranking in the guess did not equal the result. The book keeps both.
Noticed	Switching that one control off changed a result.
Masked	Switching it off changed nothing, because another control covered it or the control did not matter in that case.
Limit	What the control cannot see. Every case should have one.
Chain test	A series of links an attacker needs. The test records which link each control stops.

The numbers

27
first run: 25 matched, 2 wrong

19
second run: 17 matched, 2 wrong

2
third run: 1 matched, 1 wrong

19
fourth run: 14 matched, 5 wrong

20
cases with a control nothing noticed

4 of 4
runs that matched on the Mac

What went wrong

These are the mistakes, in the order they matter. The first ten are wrong guesses. The last two are mistakes in my own test harness.

What went wrong	Case	What I did
I guessed the scan would miss 1 secret. It missed 2.	S-R17-05	Recorded. The 2 misses were a secret split over two lines and one in base64.
I guessed a short token lifetime would change the replay result.	N-R14-25	It did not. Binding and revoking already refused both replays. Recorded.
My own arithmetic was wrong.	N-R14-07	Nine identities with two or three names each cannot make 51 entries. The count is 43. A rule that stripped trailing digits also merged two real accounts. Recorded.
I guessed the ticket scan would matter most.	C-R16-C01	The owner rule did. Recorded.
I guessed 3 alerts for 3 replays of a copied key.	N-R18-01	The model gave 1, because it raises one alert per new network and all 3 replays came from one network. Recorded.
I guessed 0 events would arrive with no controls.	P-R15-22	The connector delivers 14 of 20 either way. I had not said what I was counting. Recorded.
I guessed 4 alerts for 5 creation attempts.	S-R17-09	The model alerts on every attempt, refused or not. I never wrote down which I meant. Recorded.
I guessed the drill would find 2 faults.	P-R15-12	It found 1, because the routing check caught the other first. Recorded.
I guessed the injection control would matter alone.	P-R15-06	The reveal policy already stopped both reveals, so it did not. Rotation mattered, and I had guessed it did not. Recorded.
I guessed 4 agents would still hold credentials at day 10.	S-R17-08	The scan and 3 registrations had already left 1. The expiry, which I guessed no one would notice, disabled it. Recorded.

What went wrong	Case	What I did
Bad test data on the first run.	N-R14-07	I had given 21 identities one shared owner, so the merge collapsed them to 11. I fixed the data and kept the first-run file as RESULTS-stretch-first-run.md.
A harness slip.	C-R16-C04	An extra scenario ignored its "late" marker. I fixed it so the marker sets the attack day to 120, and re-ran.

Checking it again on 2 November 2026

After the second run I re-ran everything in the build sandbox. The verify script printed 5 of 5 guess files match their recorded hash. Running run.py and run2.py gave results identical to the committed ones, except for the time stamp. The Mac output of the second run had already matched the sandbox. On 10 November 2026 the verify script covers 6 guess files, and the round 19 results file has the same SHA-256 on the Mac and in the sandbox.

What this method cannot tell you

- I wrote the guesses and the code. A match shows my model agrees with my reasoning. It does not show that a real product behaves that way.
- A hash proves the file did not change after I committed it. It does not prove when I wrote it, beyond the commit time.
- Chain tests are rule models. Each link is stopped by the controls I decided stop it, so the results follow from my rules.
- Three chain tests have an extra scenario I wrote after the fact to probe a limit. Each is marked as an extra.

CHAPTER 4

4 A framework for machine identities

Seven steps, drawn from what the cases showed. Targets and thresholds are yours to set.

This framework is a draft method tested only on made-up data. Every one of the 67 cases sits in exactly one step. Where a number depends on your organisation, the book says so and leaves it for you to set.

The seven steps

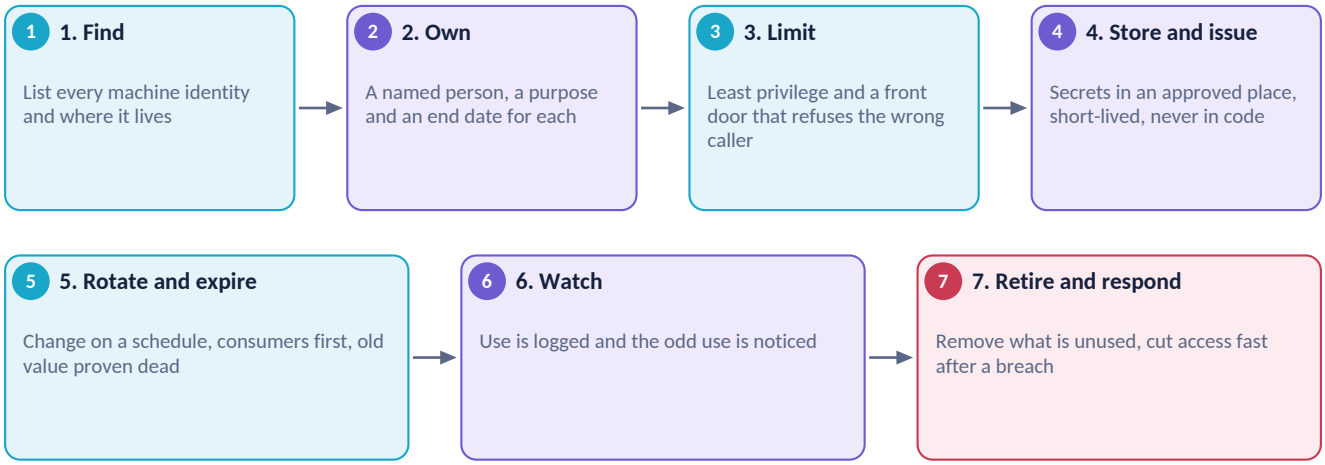


Figure 4.1 The seven steps in order. What you retire drops out of the next discovery scan, so step 7 feeds step 1 again.

Step	What to do	What you should see	Cases
1. Find	One list from every source: directory, cloud, CI, SaaS, repositories, AI tools.	One list. Each row shows its source.	6
2. Own	A named person, a purpose and an end date for each identity. No owner means escalate, then stage for disable.	Every row has a person who can say what it is for.	8
3. Limit	Tier by blast radius. Least privilege. A front door that refuses the wrong caller.	A caller with the wrong identity or too much reach is refused, and the log says who asked.	18
4. Store and issue	Values in the approved vault. Prefer short-lived and per-job credentials. Scan before commit.	No value in code, tickets or chat.	10
5. Rotate and expire	Update the consumer, rotate, then prove the old value is dead. Close the ticket after that.	The old value is refused and no application fails.	10
6. Watch	Log every use. Alert on the odd one: break-glass at 2 a.m., a grant used from a new place.	Someone is told the same day.	7

Step	What to do	What you should see	Cases
7. Retire and respond	Monitor, disable with a rollback window, delete after a hold. After a vendor breach, revoke their grants.	Nothing deleted that someone needs. Access to a breached vendor ends inside your target time.	8

Step 1 in detail: the inventory

One row per identity. Keep the inventory out of wide circulation. It is a map of targets.

Field	Why it is there	Example (made up)
Identity	The thing you can point at.	svc-billing-export
Type	Service account, API key, token, certificate, workload or agent credential.	Service account
Owner	One named person who answers for it. A team alias nobody reads does not count.	A person, with a backup
Purpose	Lets a reviewer say yes or no without guessing.	Nightly billing export
Tier	How much damage it can do. Decides review order.	Tier 1
Permissions	What it can reach, and what it actually used.	Read on one database
Secret type and location	Where the value lives and who can read it.	Password, in the approved vault
Created, last used, expires	Age, idle time and end date. Missing last-use data is itself a finding.	Created 14 months ago, last used yesterday, no expiry
Consumers	Who breaks if you change it.	Billing job, reporting app

Flag these gaps

- No owner.
- No purpose.
- No expiry.
- Last use older than your limit (you set the limit).
- Permissions broader than the use.
- Secret outside the approved store.

Order the review by tier: Tier 0 and Tier 1 first. Tiers are a proposal. Tier 0 can control identity systems or all of production, Tier 1 reaches production data or systems, Tier 2 reaches little. Your organisation sets the real thresholds.

Deciding what to do with each credential

Disabling can break something, so it needs the owner. Deleting or revoking cannot be undone, so list first, get approval and wait out a hold period.

Situation	Decision	Who approves	Flag
No owner	Cannot be kept. Escalate, then stage for disable.	Platform owner	High impact
Owner known, no expiry	Keep, and set an end date.	Owner	
Idle past the limit	Stage for disable. Do not delete yet. A quarterly job can look idle for months.	Owner, platform owner	High impact
Broader than its use	Reduce permissions, or replace with a short-lived or workload identity.	Owner	

Situation	Decision	Who approves	Flag
Long-lived key in CI	Replace with a per-job, short-lived credential.	Pipeline owner	
Secret outside the approved store	Move it, then rotate it. Copies elsewhere may already exist.	Owner	
Secret exposed	Treat as compromised. Follow the leak steps below.	Security lead	High impact
Signing or CA key	Roll forward only. Revoking first breaks everything it signed.	Platform owner	Irreversible

Retire in stages

Turn it off before you throw it away. If someone shouts, turn it back on. Delete only after the hold period.

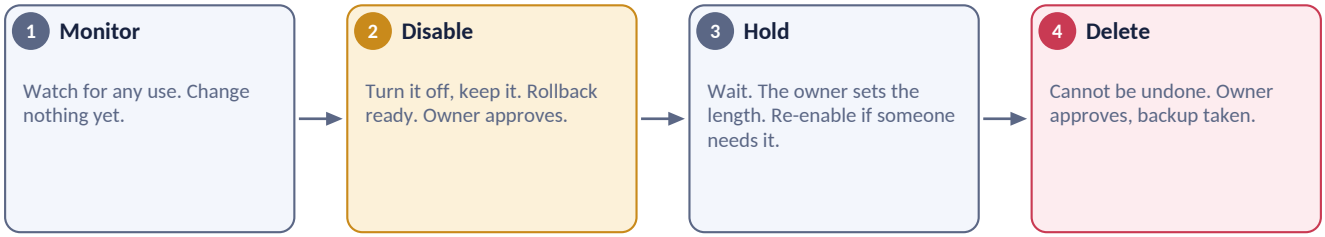


Figure 4.2 Four stages. Only the last cannot be reversed. I have not set a hold length. That is your decision.

When a secret leaks

Do not wait for proof of misuse. Assume somebody copied it.

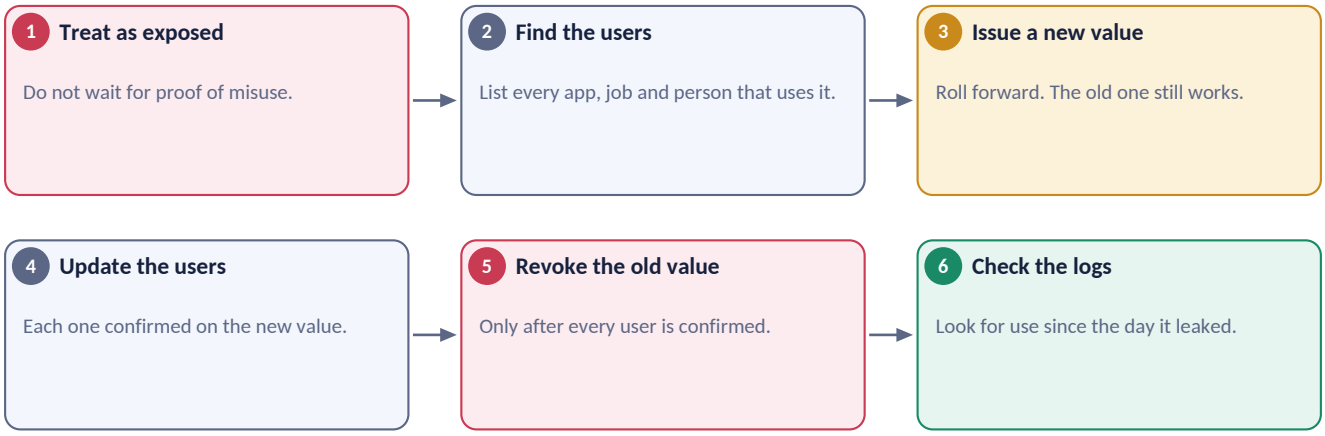


Figure 4.3 Six steps. Step 5 cannot be undone, so it comes after every user has moved. Signing keys and CA keys are roll-forward only.

> **Never do this**
> Rotate the leaked key and leave the old one valid. The lab showed the same mistake in another form: 5 rotation tickets were closed while 2 old secrets still worked (N-R14-20).

Standards for new credentials

Start clean and you do not have to clean up later.

1. An owner is named when the credential is created.
2. An end date is set when it is created.

3. Permissions are the least that do the job.
4. The value is stored in the approved vault and never in code, tickets or chat.
5. Prefer short-lived and per-job credentials to long-lived shared ones.
6. Use is logged, and the log names who or what used it.
7. An AI agent has its own identity and a named human owner. No shared agent identity.

In the lab, a front door that refused new identities without an owner, scope and expiry (N-R14-18) stopped the problem at creation. A weekly sweep also disabled expired keys (S-R17-04).

Metrics

Count from your own data. I have left the targets for you.

Metric	How to count it	Target	Lab example
Identities with a named owner	Owned identities divided by all identities	You set it	A key with no owner was paused on day 31 (N-R14-09)
Identities with an end date	Identities with an expiry divided by all	You set it	Ghost credential refused at creation (S-R17-04)
Time to cut a breached vendor	Minutes from notice to revoked grants	You set it	60 minutes in the model; a replay at minute 30 still worked (N-R14-23)
Failed rotations noticed within a day	Alerts raised divided by failures	You set it	Alert on day 1 instead of day 60 (N-R14-14)
Secrets caught before commit	Blocked divided by planted	You set it	6 of 8 blocked; 2 got through (S-R17-05)

The lab numbers come from small models and prove nothing about your estate.

OWASP Non-Human Identities Top 10 (2025)

OWASP publishes a Top 10 for non-human identities [S8]. I mapped each risk to the lab cases that touch it. Two had thin coverage: insecure authentication (NHI4) and environment isolation (NHI8). Round 18 added a case for each. The agentic risks ASI05 to ASI07 have no cases yet.

OWASP risk	Lab cases	Coverage
NHI1 Improper Offboarding	N-R14-11, P-R15-18, S-R17-01, S-R17-10, N-R14-10, N-R14-16	direct
NHI2 Secret Leakage	S-R17-05, S-R17-06, N-R14-24, C-R16-C02, N-R14-02, P-R15-06	direct
NHI3 Vulnerable Third-Party NHI	N-R14-05, N-R14-23, S-R17-01	direct
NHI4 Insecure Authentication	N-R14-25, N-R18-01	direct
NHI5 Overprivileged NHI	P-R15-05, S-R17-02, N-R14-17, N-R14-12, P-R15-01, P-R15-23, S-R17-07, S-R17-09	direct
NHI6 Insecure Cloud Deployment Configurations	N-R14-03, N-R14-25, C-R16-C02	direct
NHI7 Long-Lived Secrets	N-R14-05, N-R14-14, N-R14-25, N-R14-13	direct
NHI8 Environment Isolation	N-R14-17, N-R18-02	direct
NHI9 NHI Reuse	N-R14-21, P-R15-19, P-R15-14	direct
NHI10 Human Use of NHI	N-R14-22, S-R17-03, C-R16-C17	direct

I read OWASP's risk names for this mapping. The mapping is mine and is not an OWASP endorsement.

What is left for you to set

- Tier thresholds, idle limits and the hold period. Your organisation sets them. They are not set here.
- Reference points I read while building the method: the OWASP list above, and the identity and access controls in NIST SP 800-53 and ISO/IEC 27001. I name them as reading. I do not quote their text and I do not claim alignment.
- Not yet tested: cloud-specific key habits, Kubernetes workload identity, and any real product.

CHAPTER 5 · FRAMEWORK STEP 1 OF 7

5 Step 1: Find

List every machine identity and where it lives.

You cannot own or retire what you cannot see. This step builds one list from every place identities live: the directory, the cloud, the CI settings, the SaaS apps, the repositories and the AI tools people have connected.

What the cases in this step showed

- A directory-only scan found 12 of 27 identities. Merging three sources found all 27.
- Nine of ten targets were recorded, and nobody knew about the tenth until a coverage check compared the two lists.
- Keys for AI services turned up in six repositories. A scan found five of the six.

> **A question to ask**
> Where does your list come from, and which source would you add first?

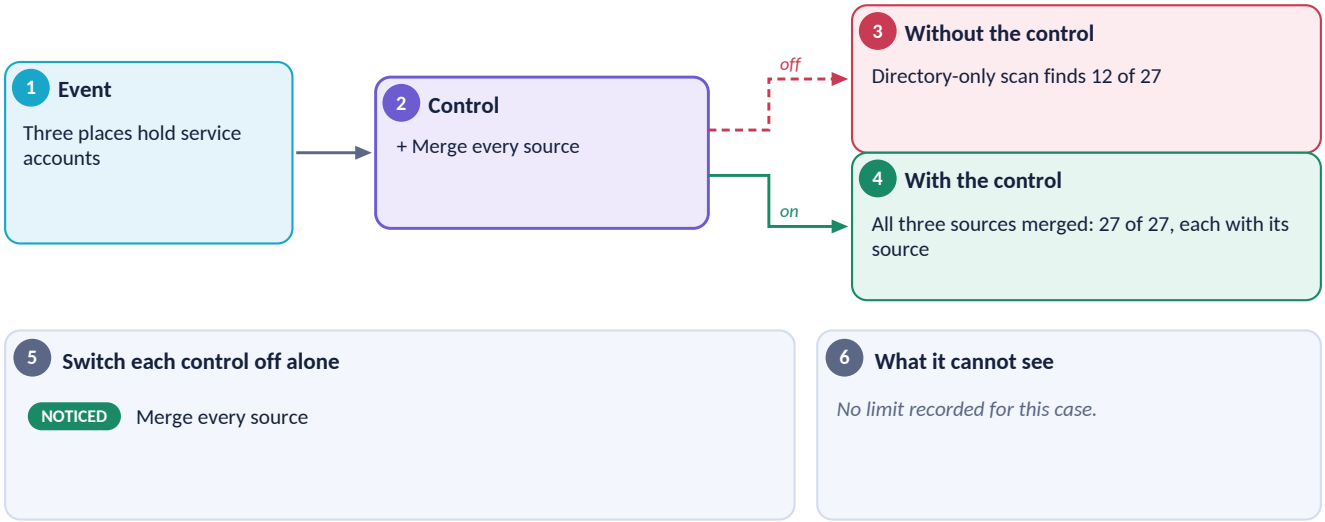
6 cases follow. Guesses that were wrong: N-R14-07, S-R17-08. Controls nothing noticed: S-R17-06.

Event · Control · Result without the control · Result with the control · Nothing noticed, or a limit

N-R14-01 Inventory misses a source

Step 1: Find · Run 1 · Discover · **Guess matched**

Three sources hold service accounts: the directory (12), the cloud (9) and CI settings (6). A scan of the directory alone is run.



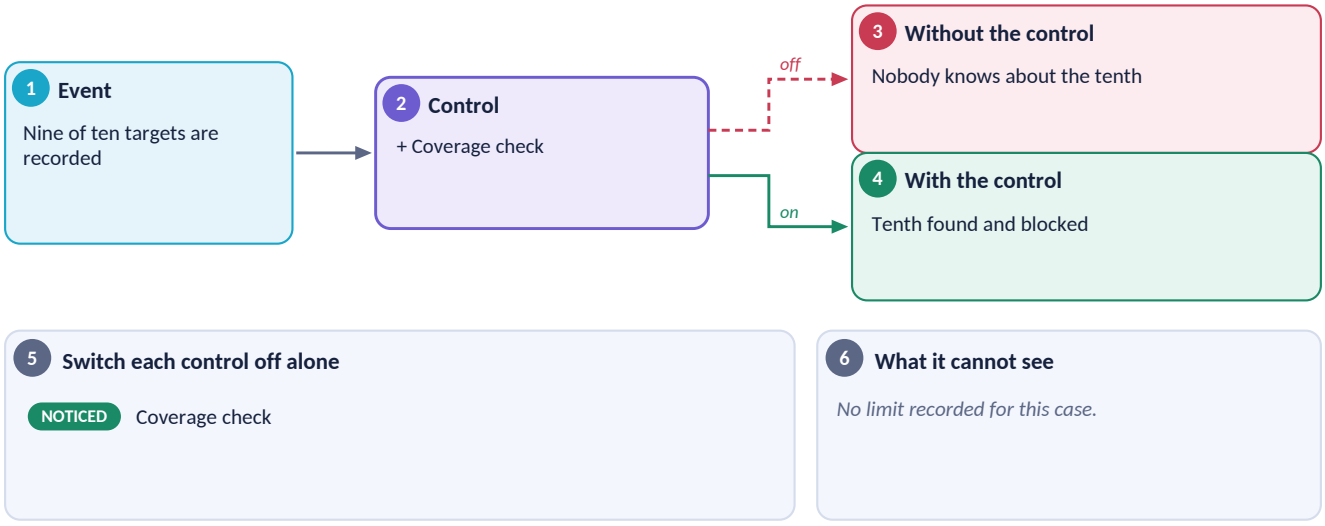
GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: found 12, total 27. With: found 27, total 27, has source yes.

TAKE-AWAY A scan is only as good as the list of places it covers. Merge every source and keep the source on each row, so a gap shows.

P-R15-08 Recording gap on one target

Step 1: Find · Run 1 · Privileged access · Guess matched

Sessions to nine of ten targets are recorded. The tenth is not.



GUESS Matched in both runs (control off, control on).

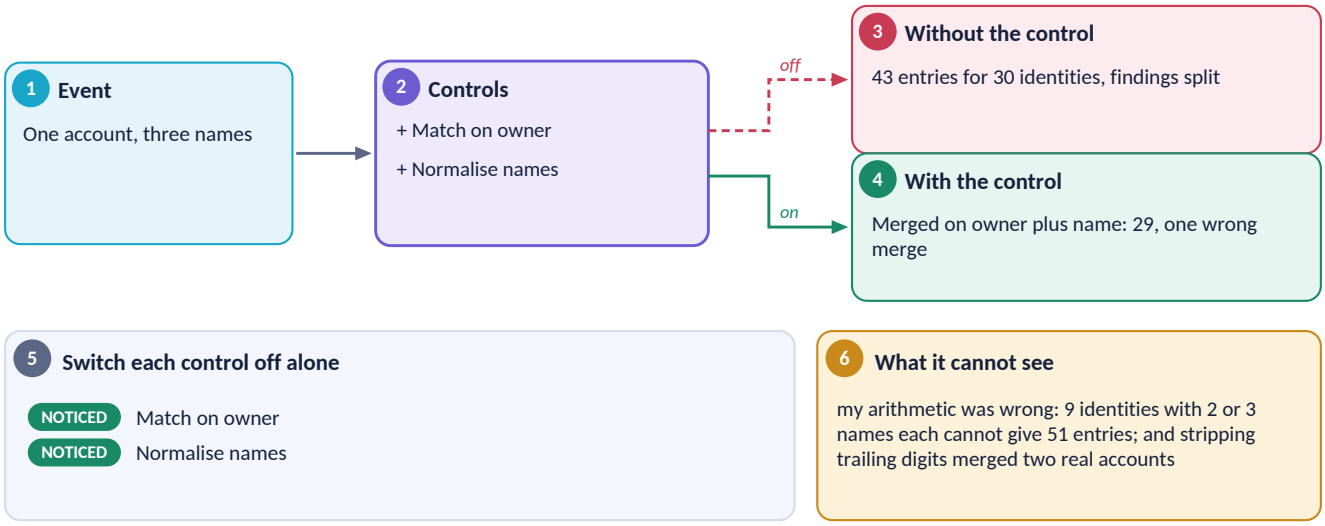
MEASURED Without: gap known no. With: gap known yes, target10 blocked yes.

TAKE-AWAY Nine recorded targets look like coverage. A check that compares the recording list with the target list found the tenth.

N-R14-07 One identity, three names

Step 1: Find · Run 2 · Discover · Guess wrong · Limit recorded

The same service account appears as `svc-billing` in the directory, `billing-svc@kaveri` in the cloud and `BILLING_SVC` in the vault. 30 identities, 9 of them appear under two or three names.



GUESS Wrong. I guessed 51 entries without the control and 30 with it. The true counts are 43 and 29. Nine identities with 2 or 3 names each cannot make 51. The rule also merged two real accounts.

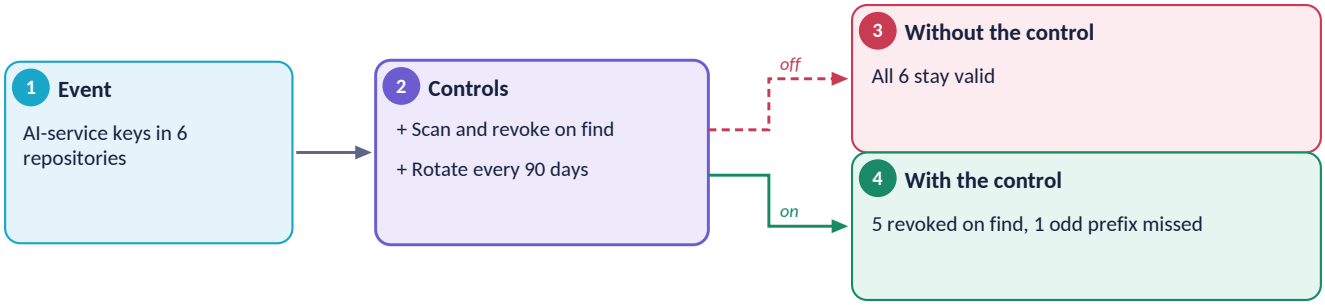
MEASURED Without: count 43, split findings yes, wrong merges 0. With: count 29, split findings no, wrong merges 1.

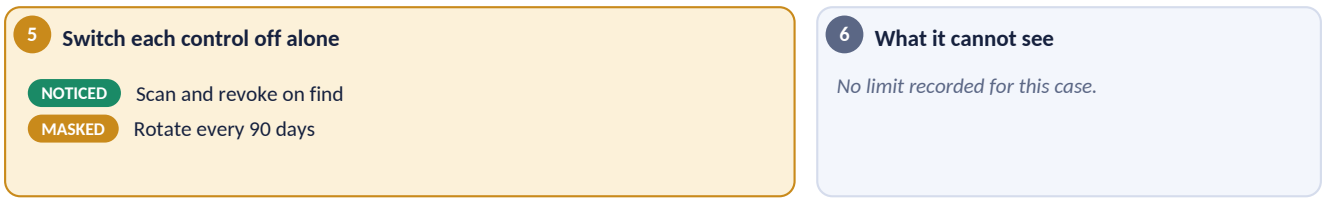
TAKE-AWAY One account with three names splits findings: 43 entries for 30 identities. Matching on owner and normalised name gave 29, one short, because it merged two real accounts. My own arithmetic in the guess was wrong too.

S-R17-06 AI-service keys leak into repositories

Step 1: Find · Run 2 · Shadow AI · OWASP NHI2 · Guess matched · Control masked

6 AI-service keys appear in 6 repositories. 2 are older than 90 days.



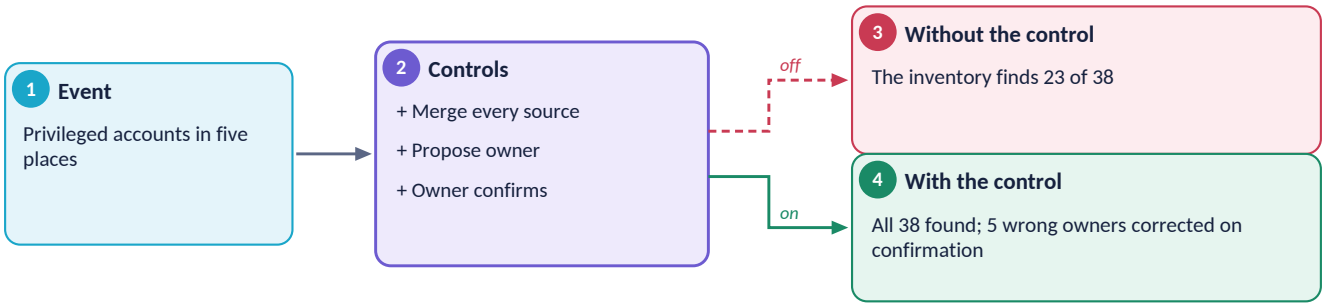


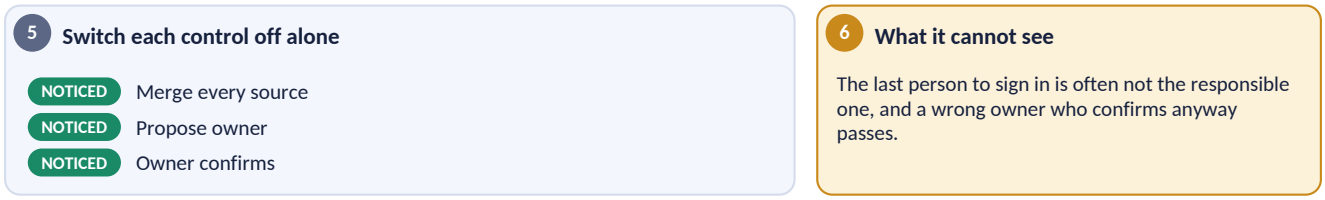
GUESS	Matched in both runs (control off, control on).
MEASURED	Without: revoked on find 0, valid 6. With: revoked on find 5, valid 1.
TAKE-AWAY	Six AI-service keys sat in six repositories. Scan and revoke removed 5 and missed one with an odd prefix. A 90-day rotation alone changed nothing, because the scan already covered it.

P-R15-20 Discover privileged accounts and assign owners

Step 1: Find · Run 4 · Privileged access · Guess matched · Limit recorded

38 privileged accounts across 5 places: directory (14), local administrators on servers (6), cloud roles (9), database administrators (5), network devices (4). The current inventory covers the directory and the cloud only.





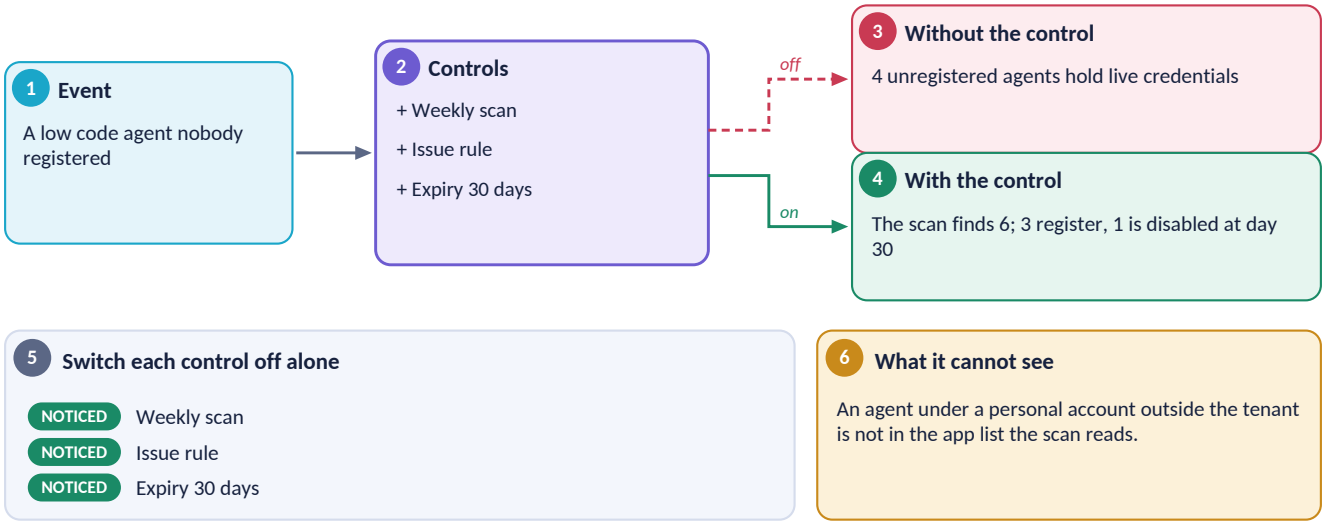
GUESS	Matched in both runs (control off, control on).
MEASURED	Without: found 23, proposed 0, confirmed 0, wrong owners corrected 0, wrong owners remaining 0. With: found 38, proposed 38, confirmed 33, wrong owners corrected 5, wrong owners remaining 0.
EXTRA SCENARIO	Merge off. Result matched my guess.
EXTRA SCENARIO	Confirmation off. Result matched my guess.
EXTRA SCENARIO	Proposal off. Result matched my guess.

TAKE-AWAY Merging five sources found 38 privileged accounts where the current inventory saw 23. The proposed owner was wrong for 5 of them, and the owner confirmation corrected all 5. A confirmer who is not the right person can still confirm a wrong owner.

S-R17-08 An agent built in a low code tool and never registered

Step 1: Find · Run 4 · Shadow AI · Guess wrong · Limit recorded

6 agents are built by business users. 2 are registered. 4 are not and hold live credentials.



GUESS **Wrong.** I guessed 4 agents would hold credentials at day 10 with the issue rule off, and that the 30 day expiry would go unnoticed. The scan had already flagged them and 3 owners had registered, so 1 agent holds credentials. The expiry is what disables the last one.

MEASURED Without: found 0, flagged 0, registered after request 0, disabled 0, unregistered with creds day10 4, unregistered with creds day31 4. With: found 6, flagged 4, registered after request 3, disabled 1, unregistered with creds day10 0, unregistered with creds day31 0.

EXTRA SCENARIO Scan off. Result matched my guess.

EXTRA SCENARIO Issue rule off. Result differs from my guess: {'unregistered_with_creds_day10': [4, 1]}.

TAKE-AWAY The weekly scan found all 6 agents and flagged the 4 unregistered ones. Three owners registered, so 1 agent stayed unregistered, and the 30 day expiry is what disabled it. An agent under a personal account is not in the tenant list the scan reads.

CHAPTER 6 · FRAMEWORK STEP 2 OF 7

6 Step 2: Own

A named person, a purpose and an end date for each.

An identity that no person answers for cannot be kept. This step gives each identity a named owner, a purpose and an end date, and says what happens when one is missing.

What the cases in this step showed

- A key with no owner stayed active on day 31. With a rule it was paused on day 31.
- A front door that refuses new identities without an owner, scope and end date stopped the problem at creation.
- Four agents on one shared key left the log unreadable. One key per agent named the agent.
- A vendor engineer who left their company still had an active account at 120 days. A sponsor review every 30 days disabled it.

> **A question to ask**
> If a credential in your estate has no owner today, who finds out, and when?

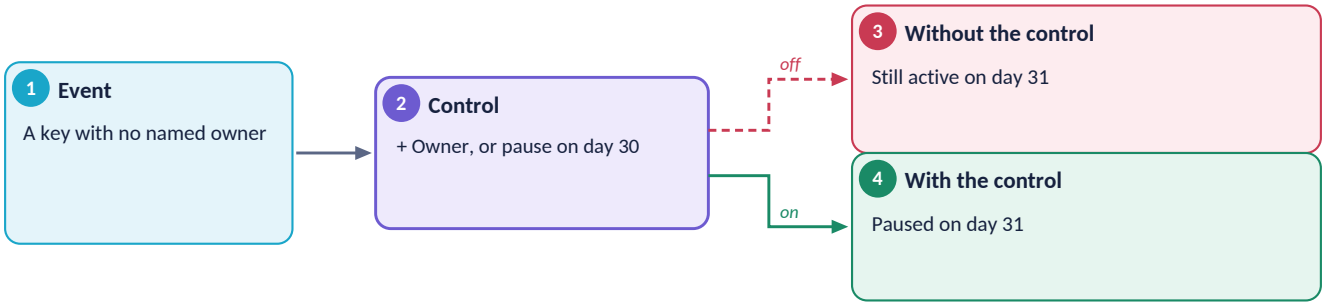
8 cases follow. All guesses in this step matched. Controls nothing noticed: N-R14-06, N-R14-10.

Event · Control · Result without the control · Result with the control · Nothing noticed, or a limit

N-R14-09 Identity with no owner

Step 2: Own · Run 1 · Own and retire · **Guess matched**

A key is found with no named owner.



5 Switch each control off alone

NOTICED Owner, or pause on day 30

6 What it cannot see

No limit recorded for this case.

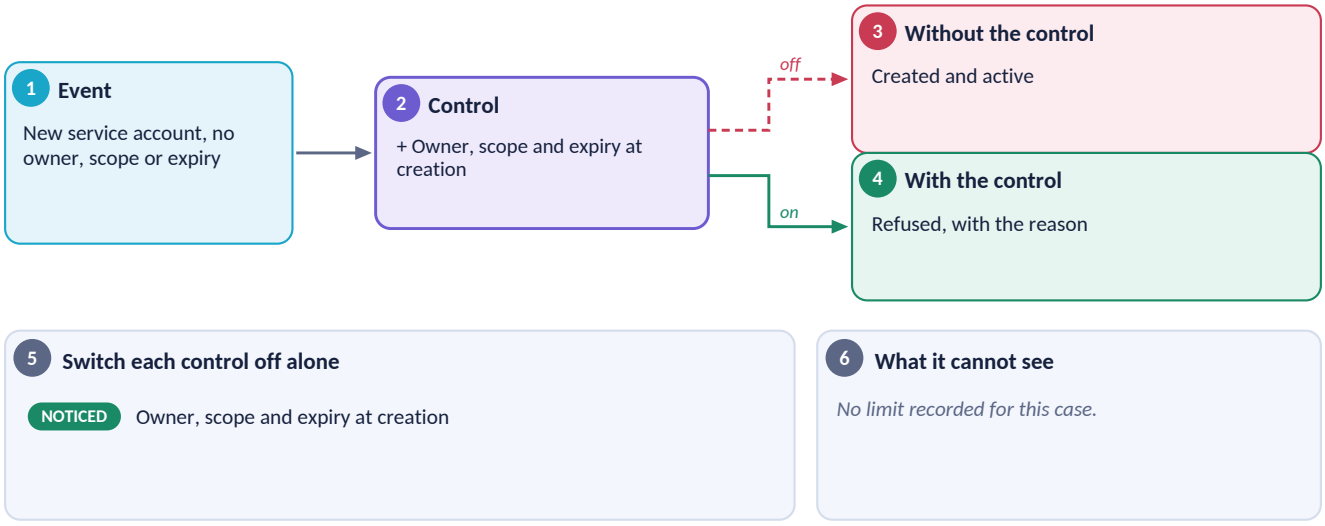
GUESS	Matched in both runs (control off, control on).
MEASURED	Without: active day31 yes, paused day31 no. With: active day31 no, paused day31 yes.

TAKE-AWAY With no rule, an ownerless key stays active. A rule that pauses it on day 31 turns a silent risk into a ticket someone has to answer.

N-R14-18 Front door for new identities

Step 2: Own · Run 1 · Front door and trust · **Guess matched**

A developer creates a new service account with no owner, no scope and no expiry.



GUESS **Matched** in both runs (control off, control on).

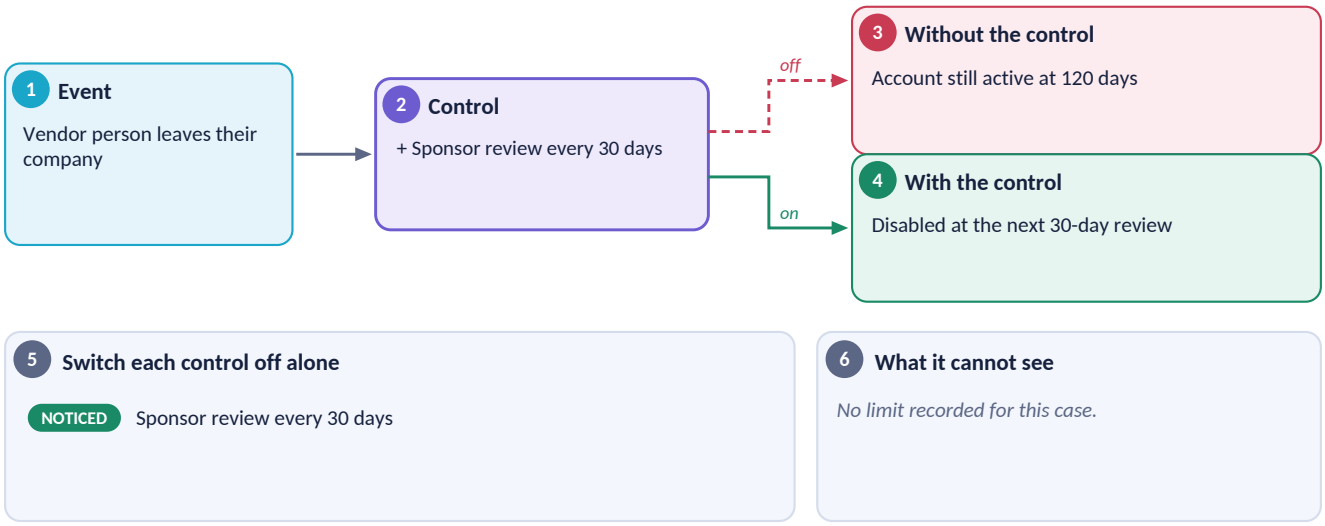
MEASURED Without: created yes, active yes. With: created no, reason given yes.

TAKE-AWAY A front door that refuses new identities without an owner, a scope and an expiry stops the problem at creation. That is cheaper than finding it later.

P-R15-18 Vendor person leaves the vendor

Step 2: Own · Run 1 · Privileged access · OWASP NHI1 · **Guess matched**

A vendor engineer leaves their company. Their account on your side is still active.



GUESS **Matched** in both runs (control off, control on).

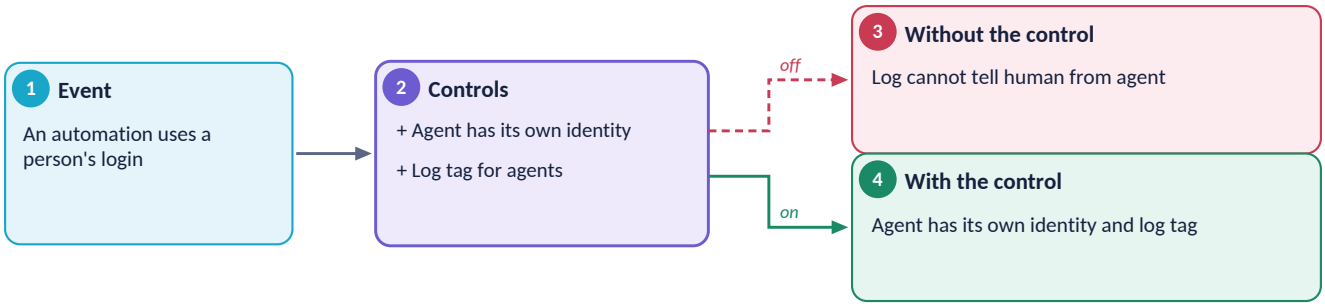
MEASURED Without: active day120 yes. With: disabled by day 30.

TAKE-AWAY When a vendor's engineer leaves their company, your account for them stays. A sponsor review every 30 days disabled it. Without the review it was still active at 120 days.

S-R17-03 Agent runs under a person's account

Step 2: Own · Run 1 · Shadow AI · OWASP NHI10 · **Guess matched**

An automation uses a person's login, so the log shows that person.



5 Switch each control off alone

NOTICED Agent has its own identity

NOTICED Log tag for agents

6 What it cannot see

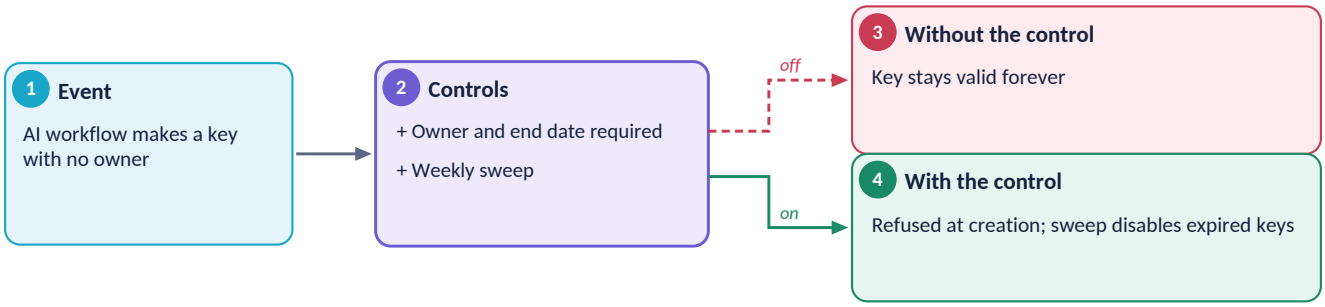
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: can tell human from agent no. With: attributed to agent yes, human history clean yes.
TAKE-AWAY	An automation that uses a person's login makes the log unreadable. A separate agent identity and a log tag tell a human from an agent.

S-R17-04 Ghost credential

Step 2: Own · Run 1 · Shadow AI · **Guess matched**

An AI-assisted workflow creates a key with no owner for a project that then ends.



5 Switch each control off alone

NOTICED Owner and end date required

NOTICED Weekly sweep

6 What it cannot see

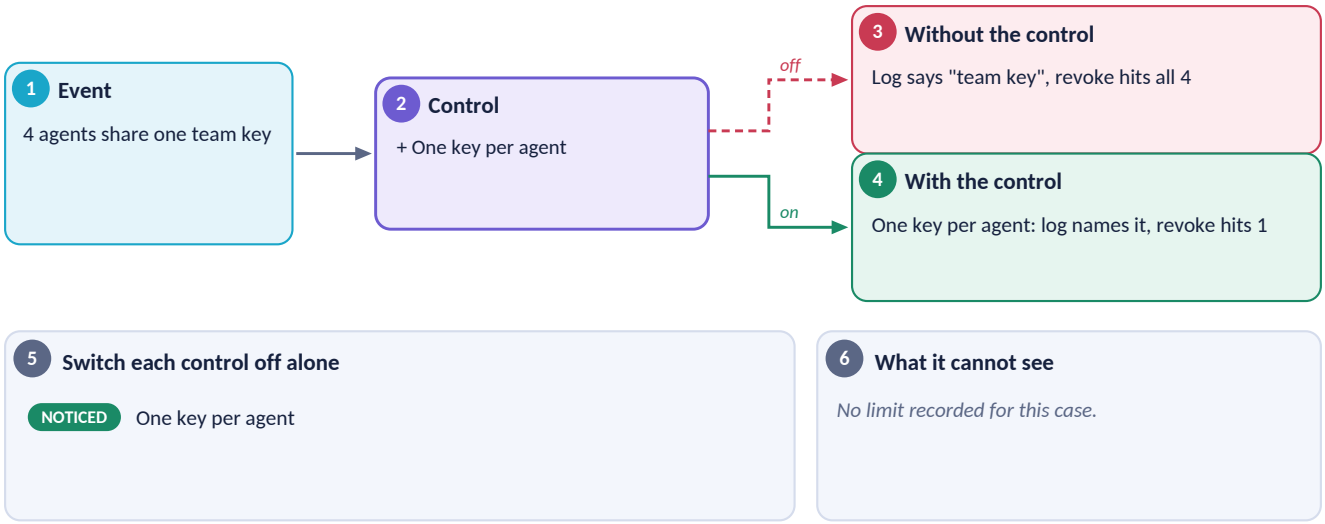
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: key valid after end yes. With: creation refused yes, expired disabled yes.
TAKE-AWAY	AI-assisted workflows can create keys with no owner. Refusing them at creation, and sweeping each week, stopped ghost credentials.

N-R14-21 Agents share a team credential

Step 2: Own · Run 2 · Own and retire · OWASP NHI9 · **Guess matched**

4 agents use one shared key. One agent misbehaves.

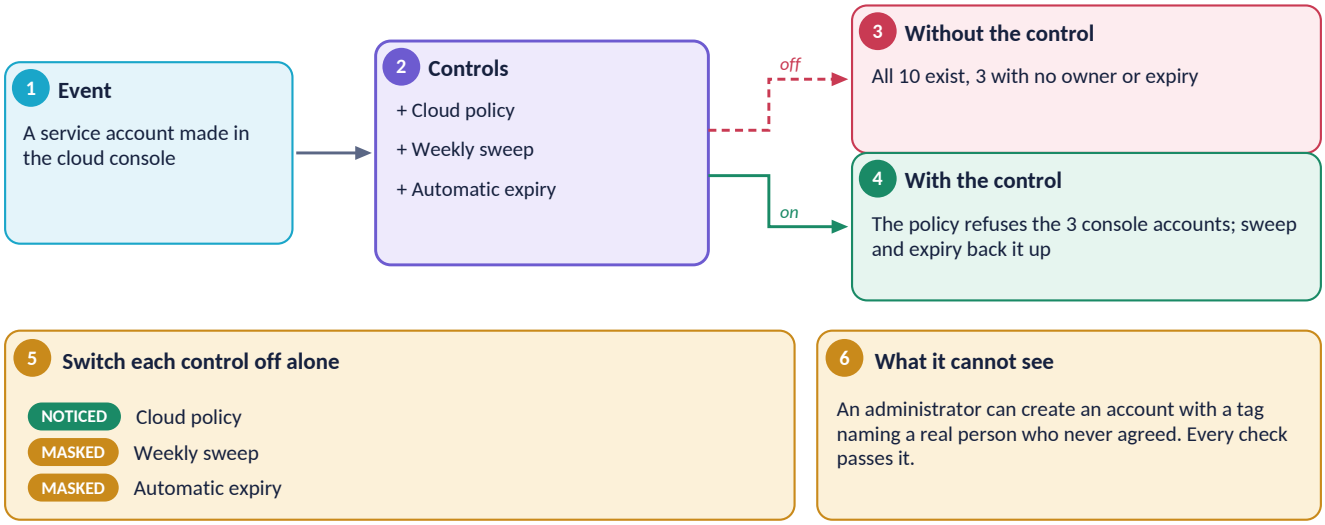


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: log names agent no, revoke hits 4. With: log names agent yes, revoke hits 1.
TAKE-AWAY	Four agents on one team key: the log says "team key" and a revoke hits all four. One key per agent makes the log name the agent and the revoke hit one.

N-R14-06 An identity created outside the normal process

Step 2: Own · Run 4 · Own and retire · **Guess matched** · **Control masked** · **Limit recorded**

10 service accounts are created in a month. 7 go through the front door (owner, scope, expiry). 3 are created straight in the cloud console by developers to unblock a release.

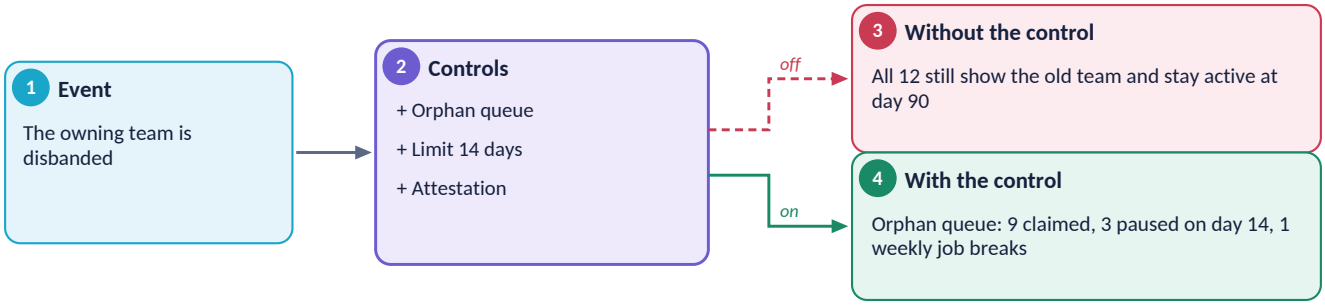


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: created 10, refused 0, ownerless day 1 3, first found day none, removed day none, ownerless day 30 3. With: created 7, refused 3, ownerless day 1 0, first found day none, removed day none, ownerless day 30 0.
EXTRA SCENARIO	Policy off, sweep and expiry on. Result matched my guess.
TAKE-AWAY	The cloud policy refused the 3 accounts made in the console, so the weekly sweep and the automatic expiry had nothing left to find. With the policy off they worked: the sweep found the accounts on day 7 and the expiry removed them on day 14. While the policy is on, no result shows that those two are there. An owner tag that names a real person who never agreed passes all three.

N-R14-10 The owning team is disbanded

Step 2: Own · Run 4 · Own and retire · OWASP NHI1 · **Guess matched** · **Control masked** · **Limit recorded**

12 service accounts are owned by a team called Payments Ops. The team is disbanded on day 0.



5 Switch each control off alone

- NOTICED Orphan queue
- NOTICED Limit 14 days
- MASKED Attestation

6 What it cannot see

A team mailing list that nobody reads is accepted as an owner.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: queued day0 0, claimed by day14 0, paused day14 0, outages 0, active with old owner day90 12. With: queued day0 12, claimed by day14 9, paused day14 3, outages 1, active with old owner day90 0.
EXTRA SCENARIO	Orphan queue off. Result matched my guess.
EXTRA SCENARIO	14 day limit off. Result matched my guess.
TAKE-AWAY	The orphan queue listed all 12 accounts of the disbanded team, 9 were claimed within 14 days, and the 14 day limit paused the other 3, which caused 1 outage. The quarterly attestation changed none of the numbers the case counts. A mailing list nobody reads still counts as a valid owner.

CHAPTER 7 · FRAMEWORK STEP 3 OF 7

7 Step 3: Limit

Least privilege and a front door that refuses the wrong caller.

A credential should reach as little as the job needs, and the door in front of it should refuse the wrong caller. This step covers least privilege, trust between workloads, approvals, multi-factor sign-in and the old doors that stay open next to a new vault.

What the cases in this step showed

- A low-value workload got a high-value role until trust was bound to one workload.
- Of 40 admin group members, 8 did privileged work. Pruning removed 32.
- In two chain tests the control that blocked the path was not the one that only reported it.

> **A question to ask**
> Does anything still let a person or a tool walk around your vault?

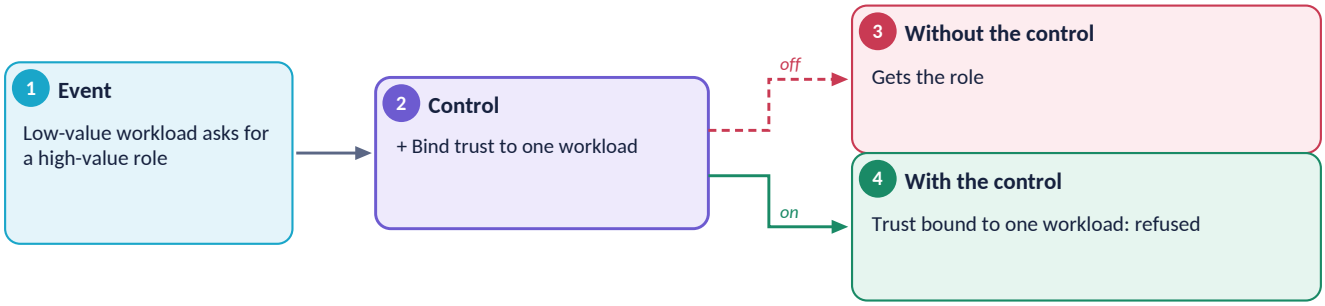
18 cases follow. Guesses that were wrong: S-R17-09. Controls nothing noticed: P-R15-16, C-R16-C06, N-R18-02, N-R14-12, P-R15-04, P-R15-23, S-R17-07.

Event · Control · Result without the control · Result with the control · Nothing noticed, or a limit

N-R14-17 Loose federation trust

Step 3: Limit · Run 1 · Front door and trust · OWASP NHI5, NHI8 · **Guess matched**

A cloud role trusts any workload in one account. A low-value workload asks for the high-value role.



5 Switch each control off alone

NOTICED Bind trust to one workload

6 What it cannot see

No limit recorded for this case.

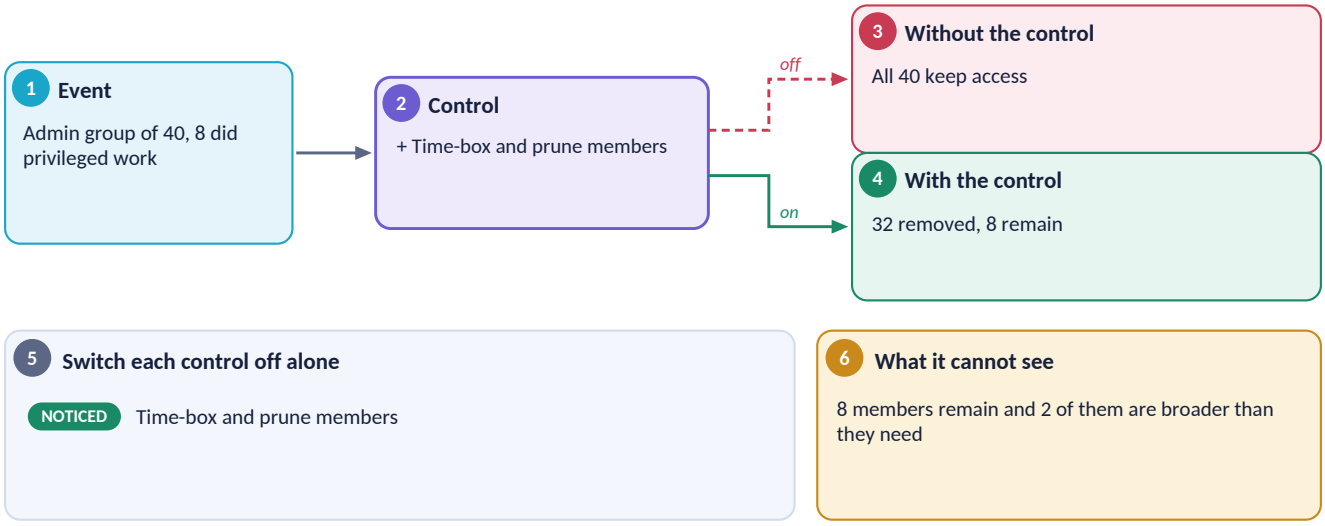
GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: gets role yes. With: gets role no.

TAKE-AWAY A role that trusts any workload in an account hands a high-value role to a low-value job. Binding trust to one workload refused it.

P-R15-05 Standing admin group membership

Step 3: Limit · Run 1 · Privileged access · OWASP NHI5 · **Guess matched** · **Limit recorded**

An admin group has 40 members. Eight did privileged work last month.



GUESS **Matched** in both runs (control off, control on).

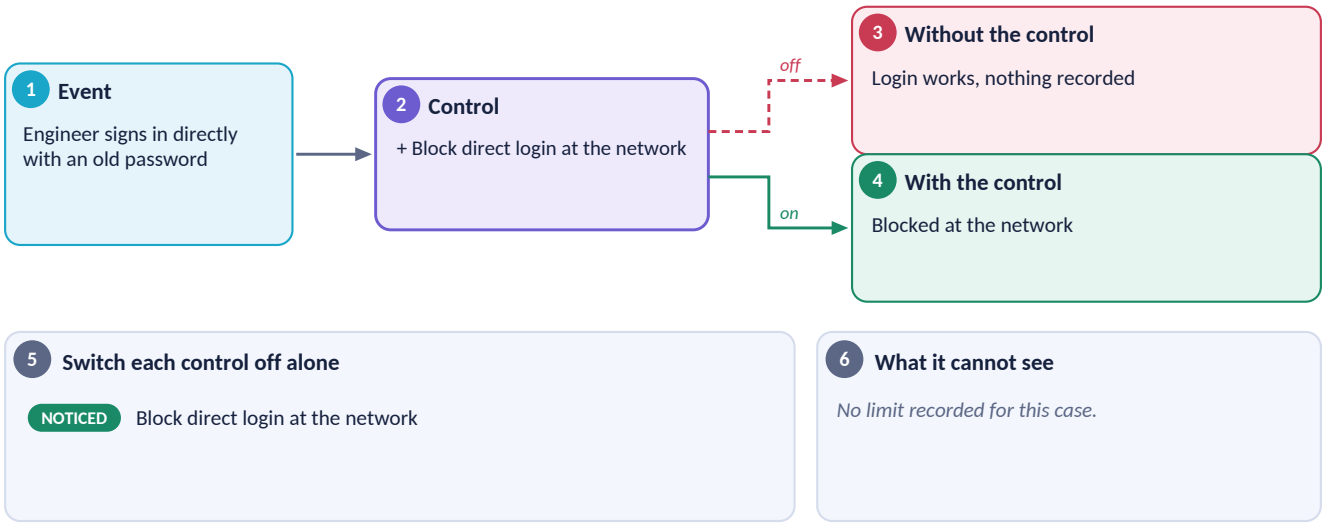
MEASURED Without: members 40. With: members 8, removed 32.

TAKE-AWAY Of 40 admin group members, 8 did privileged work. Pruning removed 32. Two of the remaining 8 were still broader than they need, so pruning is a start and not an end.

P-R15-07 Direct login still open

Step 3: Limit · Run 1 · Privileged access · **Guess matched**

The vault is in place. An engineer uses an old password to sign in directly.



GUESS **Matched** in both runs (control off, control on).

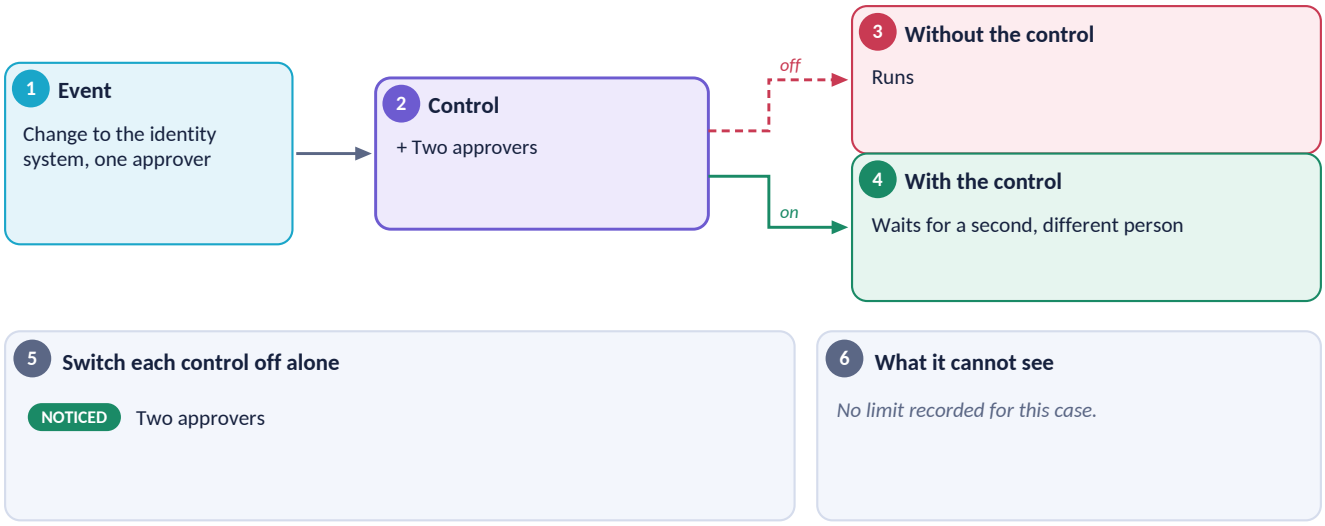
MEASURED Without: login works yes, recorded no. With: login works no.

TAKE-AWAY A vault does not help while the old password still works. Blocking the direct route at the network closes the old door.

P-R15-09 Two approvers for Tier 0

Step 3: Limit · Run 1 · Privileged access · **Guess matched**

A request to change the identity system is approved by one person.

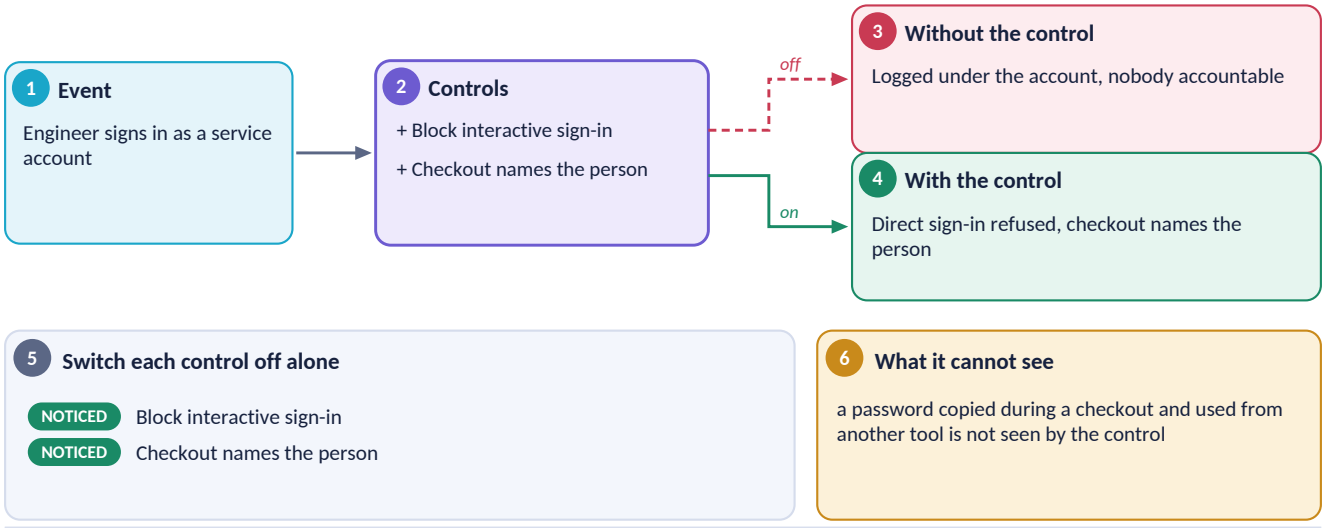


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: runs with one yes. With: runs with one no, same person twice refused yes.
TAKE-AWAY	A change to the identity system with one approver just runs. Requiring a second, different person made it wait.

N-R14-22 A person logs in with a service account

Step 3: Limit · Run 2 · Front door and trust · OWASP NHI10 · **Guess matched** · **Limit recorded**

An engineer signs in interactively with a service account to fix a problem.

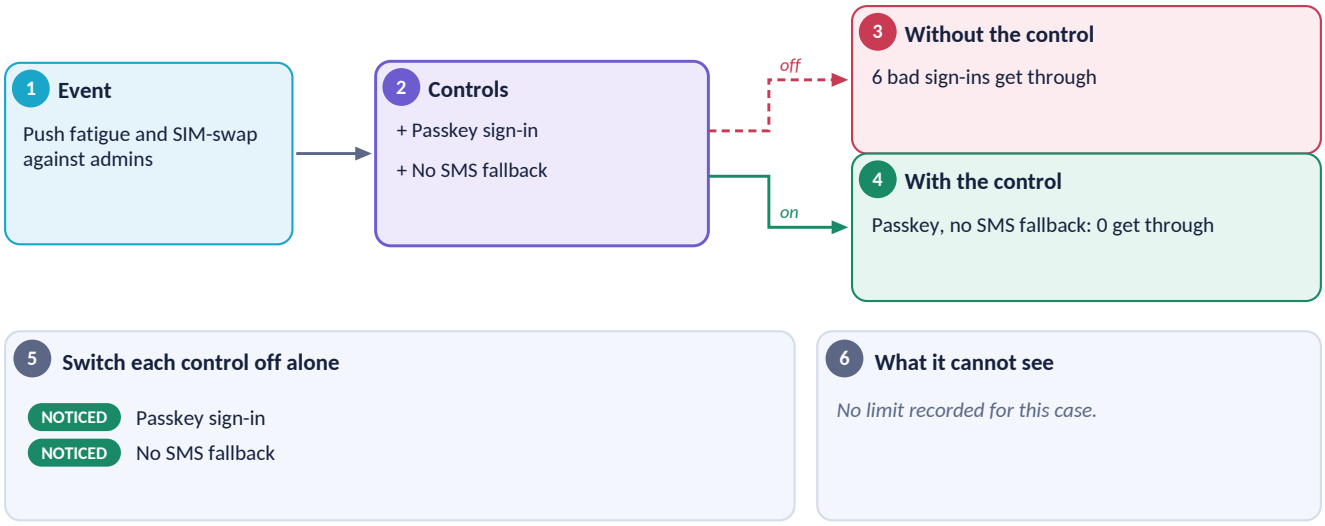


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: direct allowed yes, accountable none. With: direct allowed no, accountable asha.
TAKE-AWAY	A person who signs in as a service account is logged under the account. Refusing interactive sign-in and naming the person at checkout fixed accountability. A password copied at checkout and used elsewhere is still not seen.

P-R15-10 Phishing-resistant MFA for admins

Step 3: Limit · Run 2 · Privileged access · **Guess matched**

10 admin sign-in attempts: 4 genuine, 4 push-fatigue prompts accepted by a tired admin, 2 SIM-swap codes.

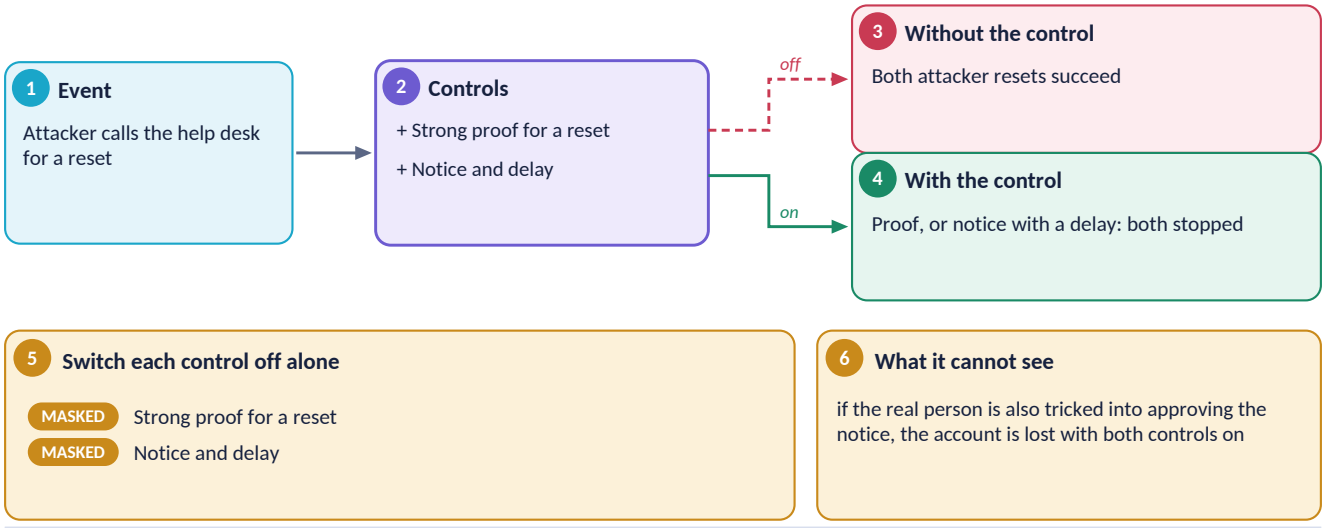


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: bad through 6, genuine ok 4. With: bad through 0, genuine ok 4.
TAKE-AWAY	Push fatigue and SIM swap got 6 bad sign-ins through. Passkeys with no SMS fallback let none through.

P-R15-16 Help desk reset path

Step 3: Limit · Run 2 · Privileged access · **Guess matched** · **Control masked** · **Limit recorded**

6 reset requests for admin accounts, 2 from an attacker using a known name and phone number.

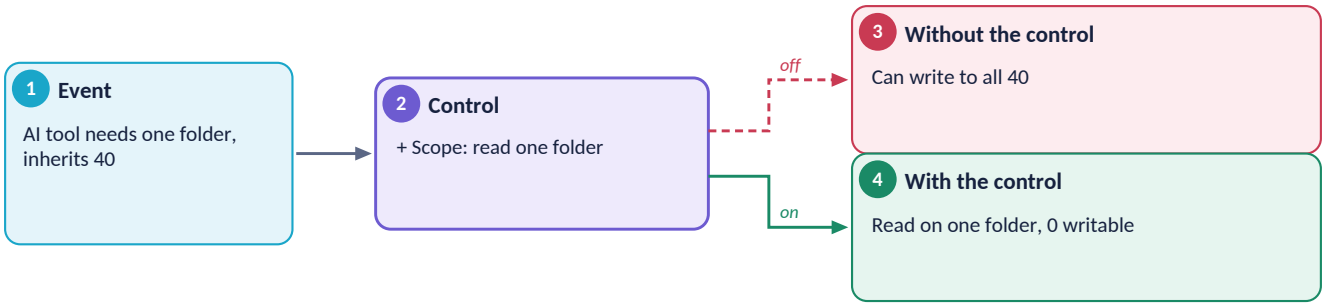


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: attacker resets ok 2. With: attacker resets ok 0.
TAKE-AWAY	A help desk reset path let both attacker resets through. Proof, or a notice with a delay, stopped both. Each control alone changed nothing, because the other already covered it. If the real person is tricked into approving the notice, both controls on still lose the account.

S-R17-02 AI tool inherits the full permissions of the person

Step 3: Limit · Run 2 · Shadow AI · OWASP NHI5 · **Guess matched**

An AI tool needs to read one folder, but inherits the person's write access to 40 folders.



5 Switch each control off alone

NOTICED Scope: read one folder

6 What it cannot see

No limit recorded for this case.

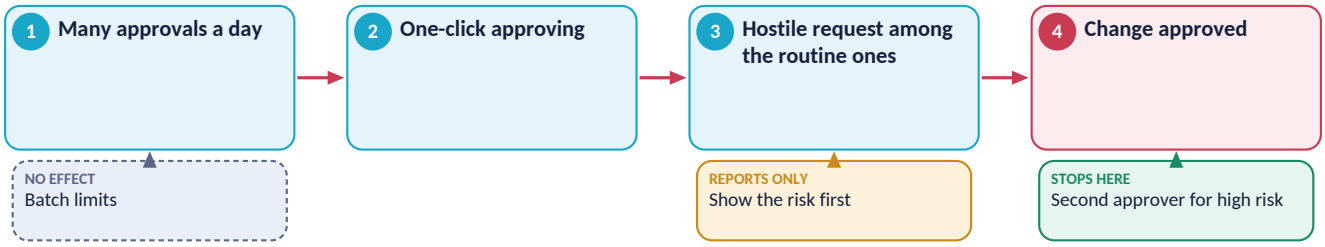
GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: readable 40, writable 40. With: readable 1, writable 0.
TAKE-AWAY	An AI tool that needs one folder inherited 40. Scoping it to read on one folder left no folder writable.

C-R16-C06 Approval fatigue

Step 3: Limit · Run 2 · Chain tests · **Guess matched** · **Control masked** · **Limit recorded**

Chain of links: many approvals a day, one-click approving, a hostile request hidden among routine ones, change approved.

Attacker path with no controls: reaches the last link



5 Switch each control off alone

MASKED Batch limits
NOTICED Show the risk first
NOTICED Second approver for high risk

6 What it cannot see

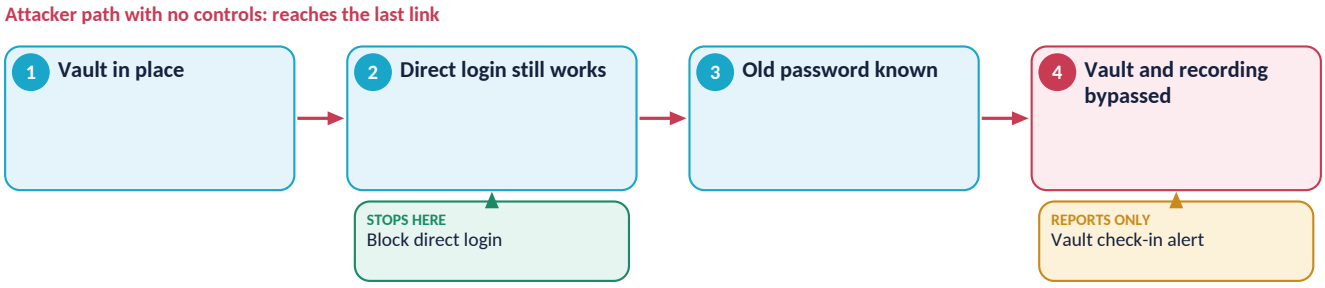
the rule model says risk-first display only flags the request. Whether a tired approver acts on the flag is human behaviour, which this model does not test

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without controls: the attacker reaches the last link. With all controls: stopped at link 4. Reported at link 3. Each control alone: Batch limits does not stop it; Show the risk first does not stop it; Second approver for high risk stops it at link 4. Best single control: Second approver for high risk.
TAKE-AWAY	Showing the risk first flags the hostile request. A second approver for high-risk requests stops it. Whether a tired approver acts on the flag is human behaviour, and this model does not test that.

C-R16-C17 The old door

Step 3: Limit · Run 2 · Chain tests · OWASP NHI10 · **Guess matched**

Chain of links: vault in place, direct login still works, old password known, vault bypassed.



5 Switch each control off alone

- NOTICED Block direct login
- NOTICED Vault check-in alert

6 What it cannot see

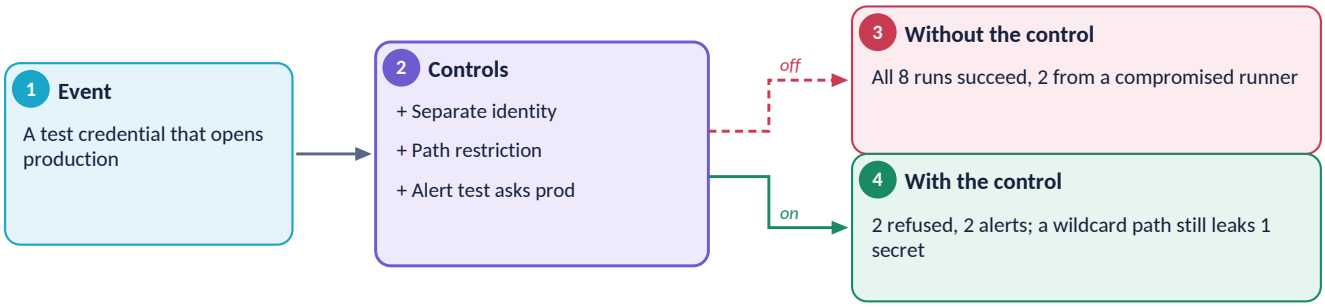
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without controls: the attacker reaches the last link. With all controls: stopped at link 2. Reported at link 4. Each control alone: Block direct login stops it at link 2; Vault check-in alert does not stop it. Best single control: Block direct login.
TAKE-AWAY	Blocking direct login stops the chain at link 2. A vault check-in alert only reports it, at link 4, after the bypass has happened.

N-R18-02 A test credential that opens production

Step 3: Limit · Run 3 · Front door and trust · OWASP NHI8 · **Guess matched** · **Control masked** · **Limit recorded**

The test pipeline and the production service share one service account and one vault path. Over a day there are 8 pipeline runs in the test environment. 2 of them come from a compromised test runner that tries the production database.



5 Switch each control off alone

- NOTICED Separate identity
- MASKED Path restriction
- NOTICED Alert test asks prod

6 What it cannot see

a refresh job copies production rows into the test database under the production identity. None of the three controls inspects data, so this is an assertion about my model, not a measurement

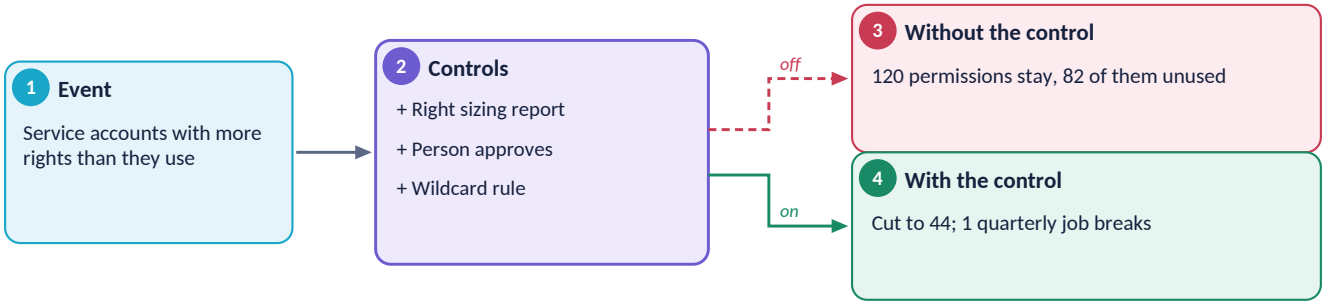
GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: normal ok 6, attacks succeeded 2, attacks refused 0, alerts 0, readable prod secrets 1. With: normal ok 6, attacks succeeded 0, attacks refused 2, alerts 2, readable prod secrets 0.
EXTRA SCENARIO	Separate identity off. Result matched my guess.

EXTRA SCENARIO	Path restriction off. Result matched my guess.
EXTRA SCENARIO	Alert off. Result matched my guess.
EXTRA SCENARIO	One production secret under a wildcard path, all controls on. Result matched my guess.
TAKE-AWAY	A test runner shared a service account and a vault path with production, so 2 attacks on the production database worked. A separate identity per environment stopped them, and the path restriction was masked by it. A production secret under a wildcard path was still readable from test, as I guessed.

N-R14-12 Overprivileged identities

Step 3: Limit · Run 4 · Front door and trust · OWASP NHI5 · **Guess matched** · **Control masked** · **Limit recorded**

15 service accounts hold 120 permissions in total. Over 90 days only 38 are used.



5 Switch each control off alone

- NOTICED Right sizing report
- MASKED Person approves
- NOTICED Wildcard rule

6 What it cannot see

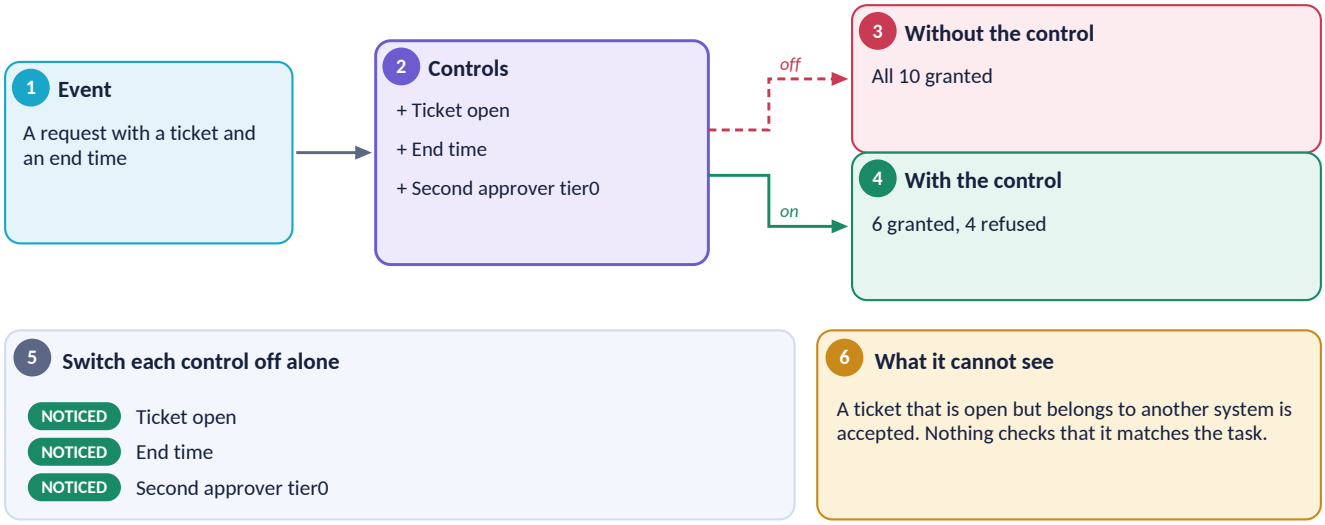
Ninety days of use cannot see a job that runs once a year, so its permission is removed too.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: permissions 120, unused permissions 82, removed 0, broken jobs 0, wildcard grants ok 2. With: permissions 44, unused permissions 6, removed 76, broken jobs 1, wildcard grants ok 0.
EXTRA SCENARIO	Report off. Result matched my guess.
EXTRA SCENARIO	Approval off. Result matched my guess.
EXTRA SCENARIO	Wildcard rule off. Result matched my guess.
TAKE-AWAY	The right-sizing report removed 76 of 120 permissions, and 1 removed permission served a quarterly job. The person approving each change made no difference here because the approver approved everything. Ninety days of use cannot see a job that runs once a year.

P-R15-01 Request privileged access with a ticket and an end time

Step 3: Limit · Run 4 · Privileged access · OWASP NHI5 · **Guess matched** · **Limit recorded**

10 requests. 6 are valid. 2 name a closed ticket. 1 has no end time. 1 asks for a Tier 0 system without a second approver.

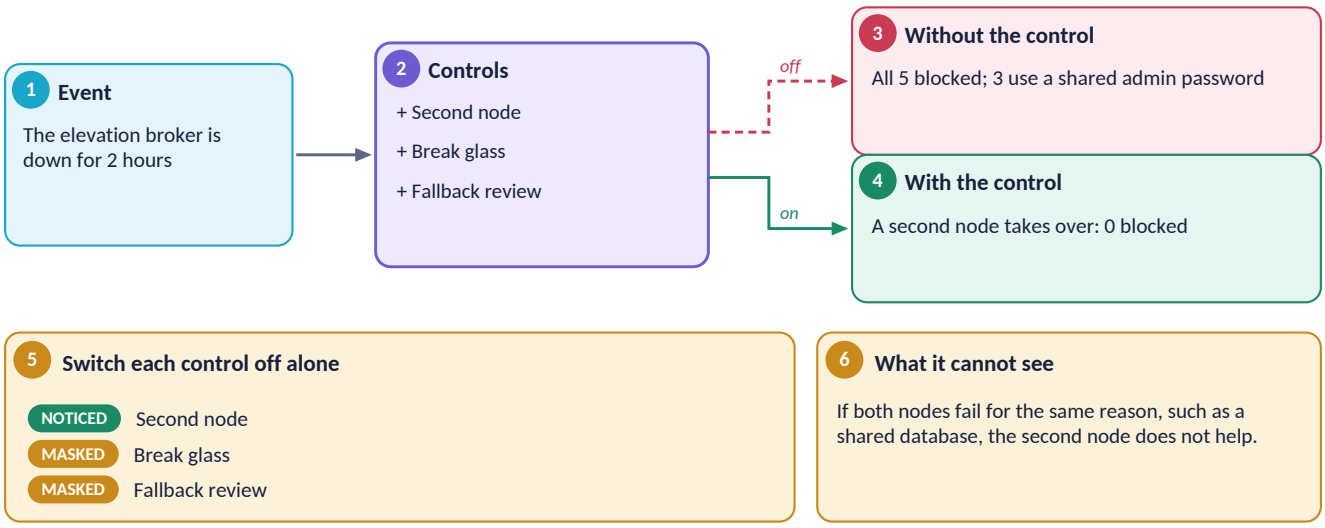


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: granted 10, refused 0. With: granted 6, refused 4.
EXTRA SCENARIO	Ticket check off. Result matched my guess.
EXTRA SCENARIO	End time rule off. Result matched my guess.
EXTRA SCENARIO	Second approver off. Result matched my guess.
EXTRA SCENARIO	Open ticket of another system, all controls on. Result matched my guess.
TAKE-AWAY	Of 10 requests, 6 were granted and 4 refused: a closed ticket twice over, no end time, and a Tier 0 request with no second approver. The check asks whether the ticket is open, not whether it matches the task, so an open ticket from another system passes.

P-R15-04 The elevation path is down

Step 3: Limit · Run 4 · Privileged access · **Guess matched** · **Control masked** · **Limit recorded**

The just in time broker is down for 2 hours. 5 engineers need access to fix an incident.



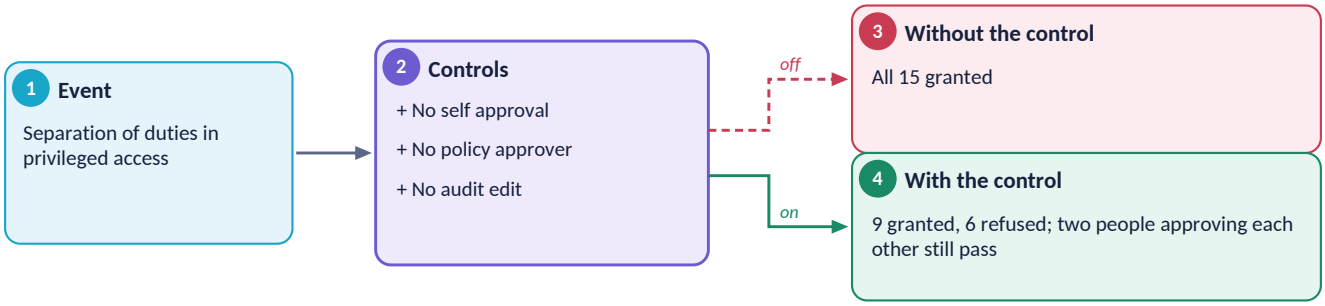
GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: blocked 5, break glass uses 0, alerts 0, reviews 0, shared password used 3. With: blocked 0, break glass uses 0, alerts 0, reviews 0, shared password used 0.

EXTRA SCENARIO	Second node off. Result matched my guess.
EXTRA SCENARIO	Second node and break-glass off. Result matched my guess.
TAKE-AWAY	With a second node up, nobody was blocked and nobody needed the break-glass fallback or its review, so neither was noticed when switched off. If both nodes fail for the same reason, the fallback is used even with the second node.

P-R15-21 Separation of duties inside privileged access

Step 3: Limit · Run 4 · Privileged access · **Guess matched** · **Limit recorded**

15 requests. 3 approve their own request. 2 are by a person who changed the vault policy and now approves access to the same vault. 1 is an administrator deleting their own audit log. 9 are fine.



5 Switch each control off alone

- NOTICED No self approval
- NOTICED No policy approver
- NOTICED No audit edit

6 What it cannot see

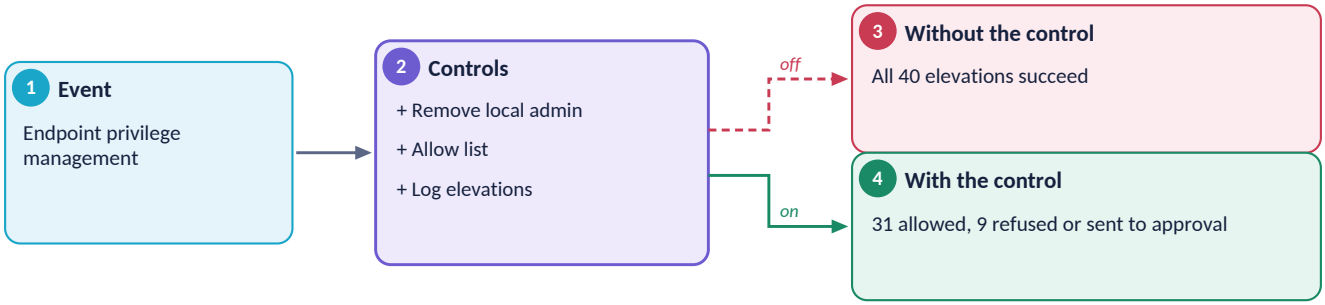
Two people approving each other's requests both pass, because each rule looks at one person at a time.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: granted 15, refused 0. With: granted 9, refused 6.
EXTRA SCENARIO	Self approval rule off. Result matched my guess.
EXTRA SCENARIO	Policy rule off. Result matched my guess.
EXTRA SCENARIO	Audit rule off. Result matched my guess.
EXTRA SCENARIO	Two people approve each other, all controls on. Result matched my guess.
TAKE-AWAY	Of 15 requests, 9 were granted and 6 refused by the three separation rules. Each rule looks at one person at a time, so two people approving each other pass all three.

P-R15-23 Endpoint privilege management

Step 3: Limit · Run 4 · Privileged access · OWASP NHI5 · **Guess matched** · **Control masked** · **Limit recorded**

30 workstations, each user a local administrator. 40 elevation requests over a week for 6 applications. 3 applications are allowed. 3 need approval. 2 requests are for a command shell. A renamed copy of a command shell is used once.



5 Switch each control off alone

- NOTICED Remove local admin
- NOTICED Allow list
- MASKED Log elevations

6 What it cannot see

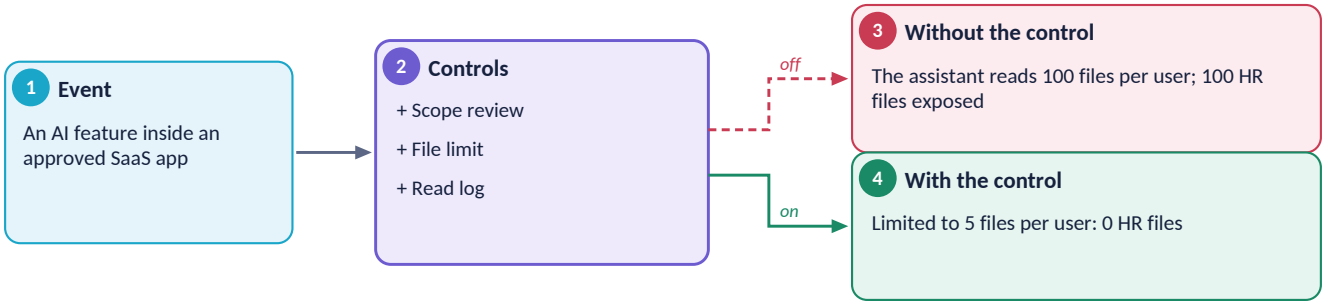
An allowed application that can start a shell passes its elevation on to the shell.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: allowed 40, refused or approval 0, shells allowed 2, renamed shell allowed yes. With: allowed 31, refused or approval 9, shells allowed 0, renamed shell allowed no.
EXTRA SCENARIO	Local admin removal off. Result matched my guess.
EXTRA SCENARIO	Allow list off. Result matched my guess.
EXTRA SCENARIO	List matches file name, not hash. Result matched my guess.
TAKE-AWAY	Removing local admin and using an allow list let 31 of 40 requests through and sent 9 to approval, with no command shell. A list that matches file names, not hashes, lets a renamed shell in. A shell started inside an allowed application inherits its elevation.

S-R17-07 AI features inside an approved SaaS app

Step 3: Limit · Run 4 · Shadow AI · OWASP NHI5 · **Guess matched** · **Control masked** · **Limit recorded**

A SaaS app that was approved adds an AI assistant. 10 users turn it on. Each user can open about 100 files. The task needs 5. 10 of those files are HR files that the users can technically open.



5 Switch each control off alone

- MASKED Scope review
- NOTICED File limit
- MASKED Read log

6 What it cannot see

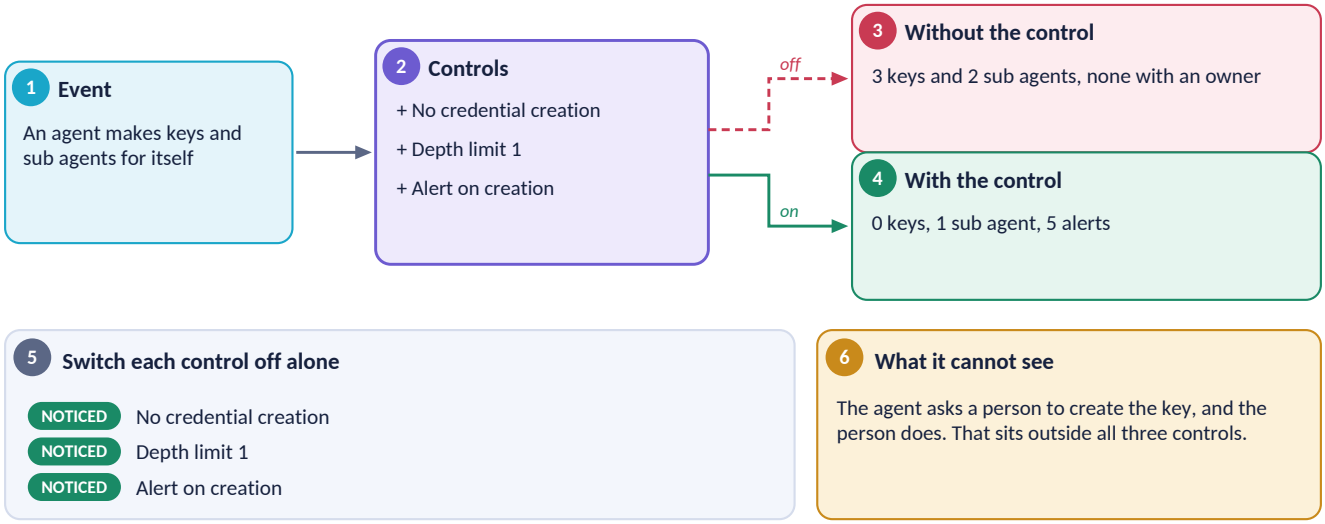
A file the user pastes in by hand is not covered by a limit on what the assistant fetches.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: files read per user 100, hr files exposed 100. With: files read per user 5, hr files exposed 0.
EXTRA SCENARIO	File limit off. Result matched my guess.
TAKE-AWAY	A file limit cut the assistant from 100 files per user to 5 and removed all HR files from reach. The scope review and the read log changed nothing the case counts. A file a user pastes in by hand is outside the limit.

S-R17-09 An agent creates credentials and sub agents for itself

Step 3: Limit · Run 4 · Shadow AI · OWASP NHI5 · **Guess wrong** · **Limit recorded**

An agent with wide rights creates 3 new keys and 2 sub agents in one run. One sub agent tries to create another.



GUESS	**Wrong.** I guessed 4 alerts. The model alerts on each of the 5 creation attempts, refused or not. Alerting only on creations that succeed would give 1. I never wrote down which I meant.
MEASURED	Without: keys 3, sub agents 2, refused 0, alerts 0, objects without owner 5. With: keys 0, sub agents 1, refused 4, alerts 5, objects without owner 1.
EXTRA SCENARIO	Credential rule off. Result matched my guess.
EXTRA SCENARIO	Depth limit off. Result matched my guess.
EXTRA SCENARIO	Alert off. Result matched my guess.
TAKE-AWAY	The credential rule and the depth limit cut the agent to 1 sub agent and no keys. The alert fired on every creation attempt, 5 in all, refused or not. A key created by a person at the agent's request sits outside all three controls.

CHAPTER 8 · FRAMEWORK STEP 4 OF 7

8 Step 4: Store and issue

Secrets in an approved place, short-lived, never in code.

A secret belongs in an approved store, short-lived where you can make it so, and never in code, tickets or chat. This step covers scanning, per-job credentials, vault backups and the paths a secret takes once it leaves the vault.

What the cases in this step showed

- The scan blocked 6 of 8 planted secrets. The 2 it missed matched no pattern.
- A token copied from a CI runner was replayed twice until it was bound and revocable.
- A vault backup on a weaker share let 5 non-backup reads through.

> **A question to ask**
> Where can a secret be read today that is not the approved store?

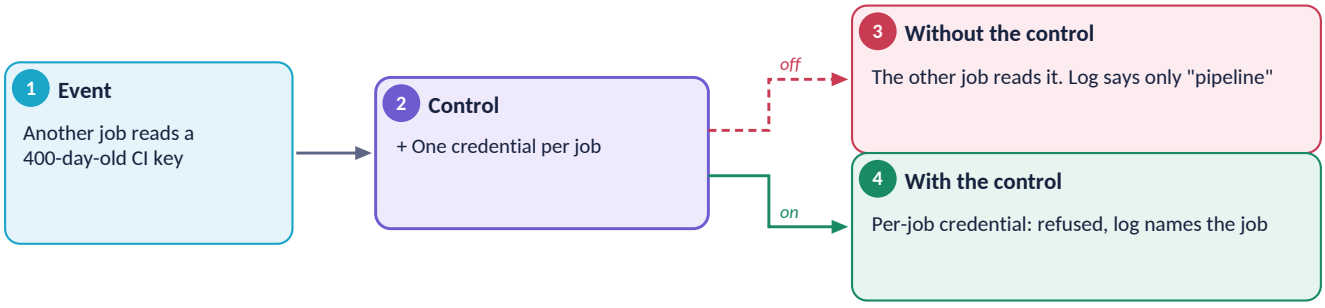
10 cases follow. Guesses that were wrong: S-R17-05, N-R14-25, C-R16-C01, N-R18-01, P-R15-06. Controls nothing noticed: N-R14-25, C-R16-C01, C-R16-C02, N-R18-01, P-R15-06.

Event · Control · Result without the control · Result with the control · Nothing noticed, or a limit

N-R14-03 Long-lived CI variable read by another job

Step 4: Store and issue · Run 1 · Front door and trust · OWASP NHI6 · Guess matched

A pipeline holds a cloud key that is 400 days old. A job from another project on the same runner reads the variable.



5 Switch each control off alone

NOTICED One credential per job

6 What it cannot see

No limit recorded for this case.

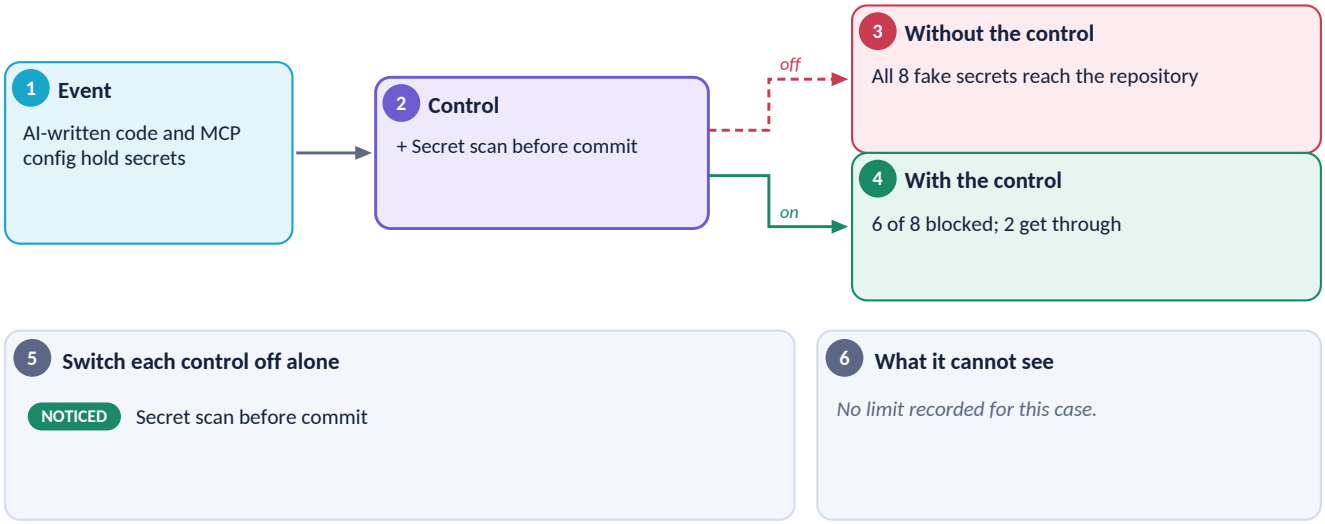
GUESS	Matched in both runs (control off, control on).
MEASURED	Without: other job reads yes, log pipeline. With: other job reads no, log job-B.

TAKE-AWAY A long-lived key shared by a pipeline can be read by any job on it. One credential per job makes the log name the job that used it.

S-R17-05 Secrets in AI-assisted code and config

Step 4: Store and issue · Run 1 · Shadow AI · OWASP NHI2 · Guess wrong

Generated code and an MCP configuration file contain fake secrets.



GUESS **Wrong.** I guessed the scan would miss 1 of 8 planted secrets. It missed 2: a secret split over two lines and one in base64.

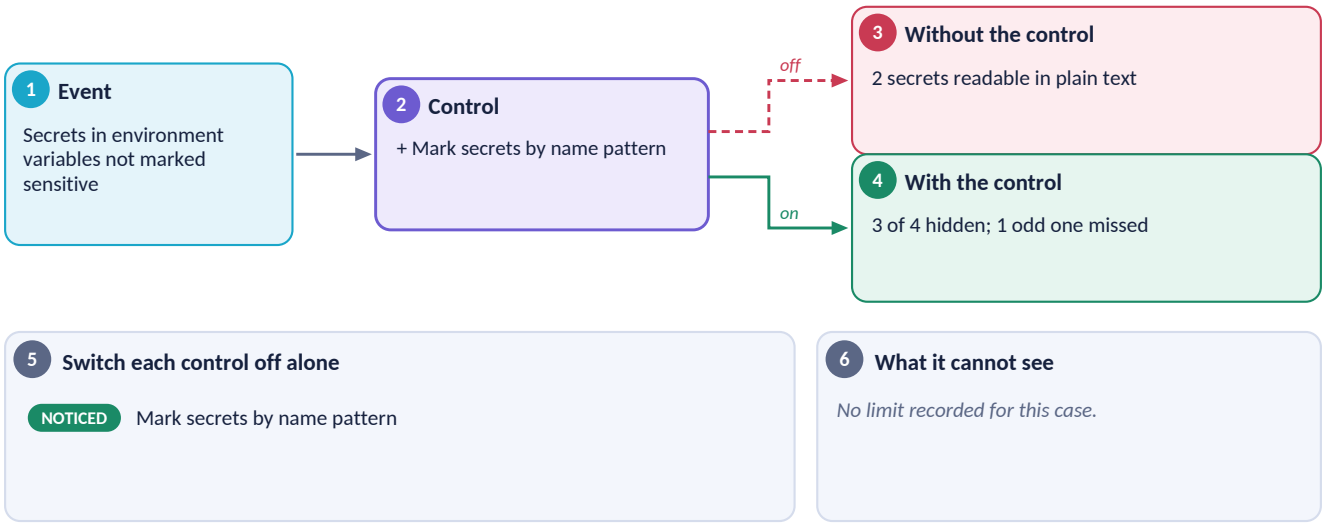
MEASURED Without: reached repo 8. With: blocked most yes, misses 2, missed split two lines, base64.

TAKE-AWAY The scan blocked 6 of 8 planted secrets. I guessed it would miss 1 and it missed 2: one split over two lines and one in base64. A pattern scan has this limit.

N-R14-24 Secrets in env variables not marked sensitive

Step 4: Store and issue · Run 1 · Gap cases from 2026 incidents · OWASP NHI2 · Guess matched

A project has 10 variables. Four are secrets. Two of those are marked sensitive by hand. An attacker with internal read access lists the variables.



GUESS **Matched** in both runs (control off, control on).

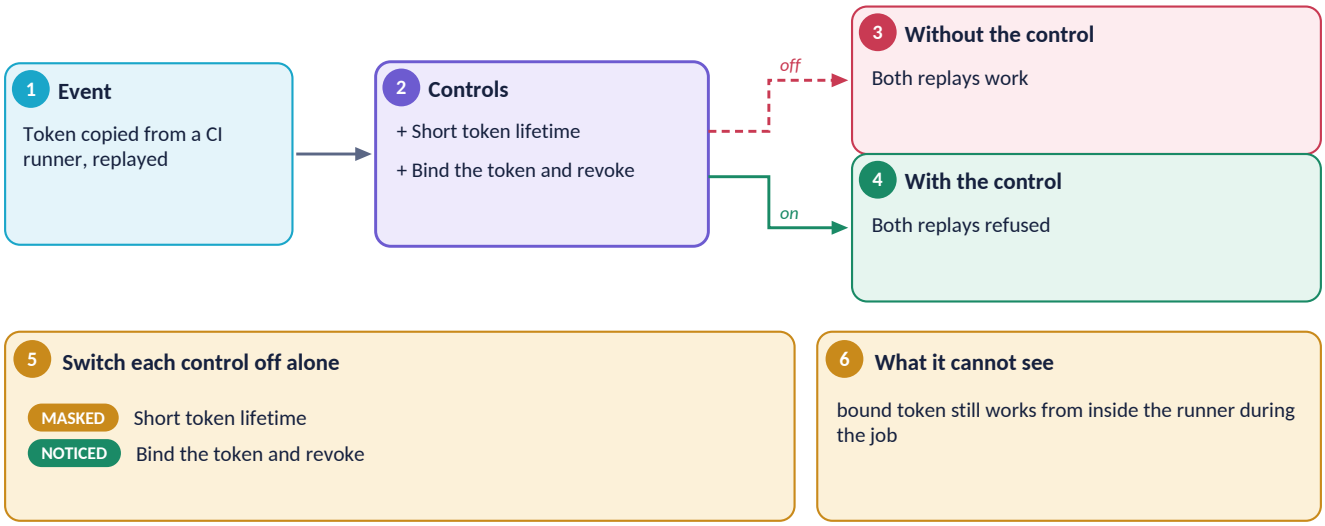
MEASURED Without: hidden secrets 2, readable secrets 2, nonsecrets hidden 0, readable secret names DEPLOY TOKEN, CFG BLOB. With: hidden secrets 3, readable secrets 1, nonsecrets hidden 0, readable secret names CFG BLOB.

TAKE-AWAY Secrets in environment variables can sit in plain text. Marking them by name pattern hid 3 of 4. The odd one was missed.

N-R14-25 Credential stolen from a CI runner, replayed

Step 4: Store and issue · Run 1 · Gap cases from 2026 incidents · OWASP NHI4, NHI6, NHI7 · Guess wrong · Control masked · Limit recorded

A job runs for 5 minutes with a deploy token. A malicious step copies the token at minute 1. The attacker replays it at minute 3 from another network, and again at minute 8 after the job ended.



GUESS Wrong. I guessed a short token lifetime would change whether a replay worked. It changed nothing. Binding the token and revoking it already refused both replays.

MEASURED Without: replay min3 yes, replay min8 yes. With: replay min3 no, replay min8 no.

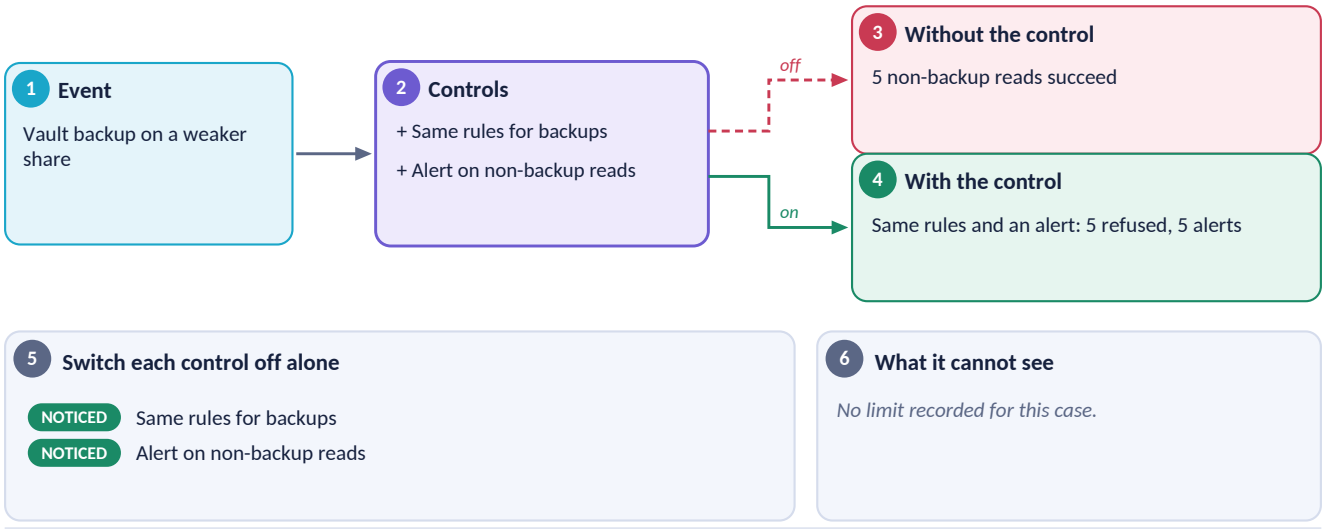
EXTRA SCENARIO 10-minute lifetime only. Result matched my guess.

TAKE-AWAY A token copied from a CI runner was replayed twice. Binding the token and revoking it refused both. I guessed a short lifetime would matter and it did not, because the binding had already blocked the replay.

P-R15-15 The vault, its backups and who can read them

Step 4: Store and issue · Run 2 · Privileged access · Guess matched

The vault backup is on a share with weaker rules. 6 accounts try to read it, 1 is the backup job.



GUESS Matched in both runs (control off, control on).

MEASURED Without: nonbackup reads ok 5, alerts 0. With: nonbackup reads ok 0, alerts 5.

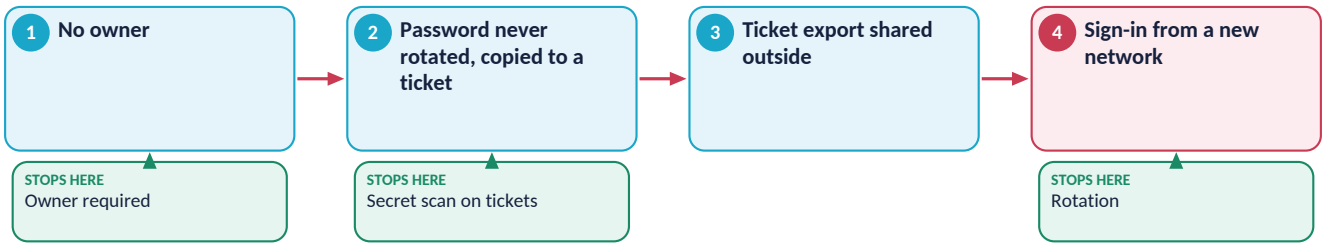
TAKE-AWAY A vault backup on a weaker share undoes the vault's rules. The same rules plus an alert on non-backup reads refused 5 reads and raised 5 alerts.

C-R16-C01 The forgotten service account

Step 4: Store and issue · Run 2 · Chain tests · Guess wrong · Control masked

Chain of links: no owner, password never rotated, copied to a ticket, ticket export shared, sign-in from a new network.

Attacker path with no controls: reaches the last link



5 Switch each control off alone

NOTICED Owner required
MASKED Secret scan on tickets
MASKED Rotation

6 What it cannot see

No limit recorded for this case.

GUESS **Wrong.** I guessed the secret scan on tickets would be the most useful single control. The owner rule was. It stops the chain at the first link.

MEASURED Without controls: the attacker reaches the last link. With all controls: stopped at link 1. Each control alone: Owner required stops it at link 1; Secret scan on tickets stops it at link 2; Rotation stops it at link 4. Best single control: Owner required.

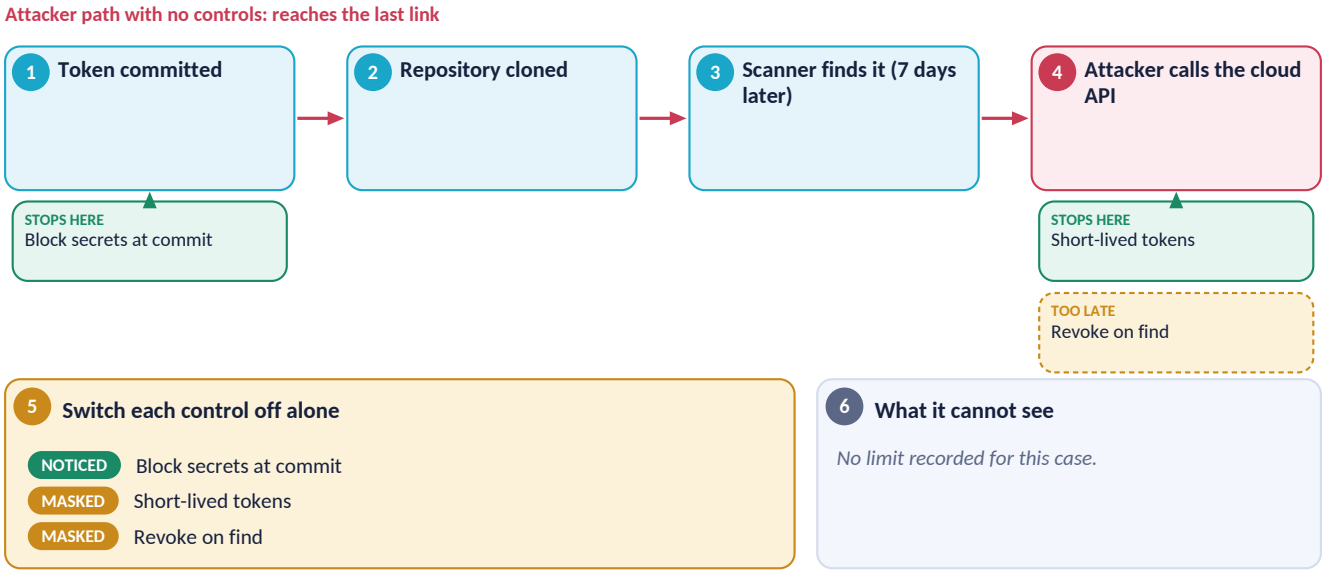
EXTRA SCENARIO Account already exists (legacy), owner rule cannot apply. Result matched my guess.

TAKE-AWAY Five links from no owner to a sign-in from a new network. The owner rule stops it at the first link. I guessed the ticket scan would matter most, and the owner rule did. For an account that already exists the owner rule cannot apply, and the ticket scan stops it at the second link.

C-R16-C02 The token in the repository

Step 4: Store and issue · Run 2 · Chain tests · OWASP NHI2, NHI6 · Guess matched · Control masked

Chain of links: token committed, repo cloned, scanner finds it, attacker calls the cloud API.

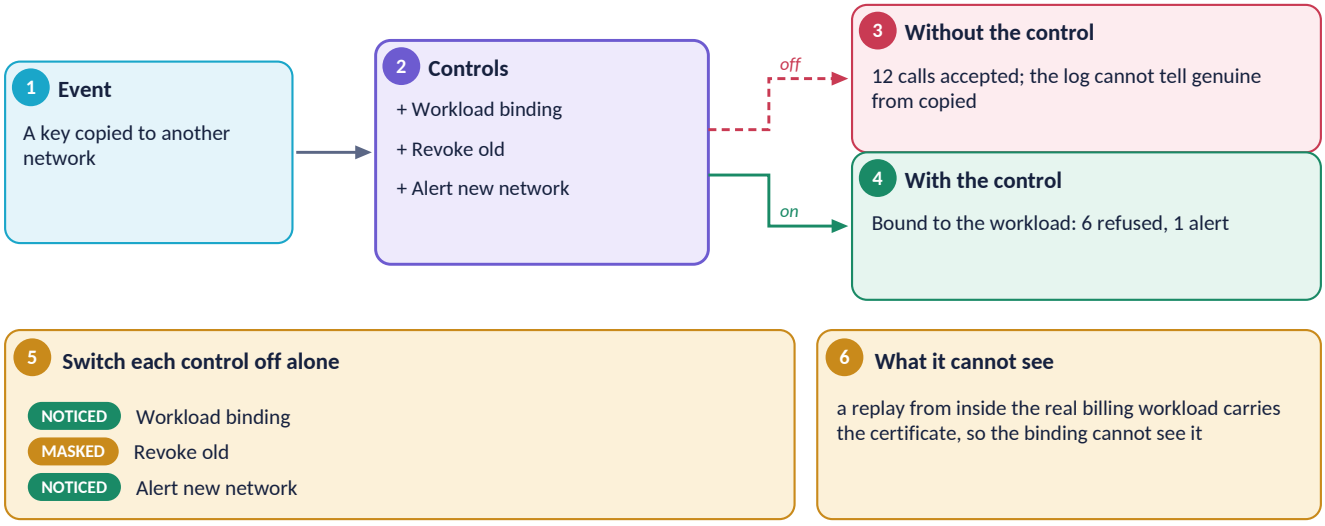


GUESS	Matched in both runs (control off, control on).
MEASURED	Without controls: the attacker reaches the last link. With all controls: stopped at link 1. Each control alone: Block secrets at commit stops it at link 1; Short-lived tokens stops it at link 4; Revoke on find does not stop it. Best single control: Block secrets at commit.
EXTRA SCENARIO	The finder is faster than the token lifetime (12 hours). Result matched my guess.
TAKE-AWAY	The commit block stops a token at link 1. A one-day token alone also stops the chain when the finder takes 7 days. If the finder is quicker than the token lifetime (12 hours), the short token alone no longer helps.

N-R18-01 A copied key from another network

Step 4: Store and issue · Run 3 · Front door and trust · OWASP NHI4 · Guess wrong · Control masked · Limit recorded

An internal payments API accepts a static key from the billing service. In one hour there are 12 calls: 6 genuine from the billing workload, 3 replays of a copied key from an unknown network, and 3 calls with the old key after it was rotated 2 days ago.



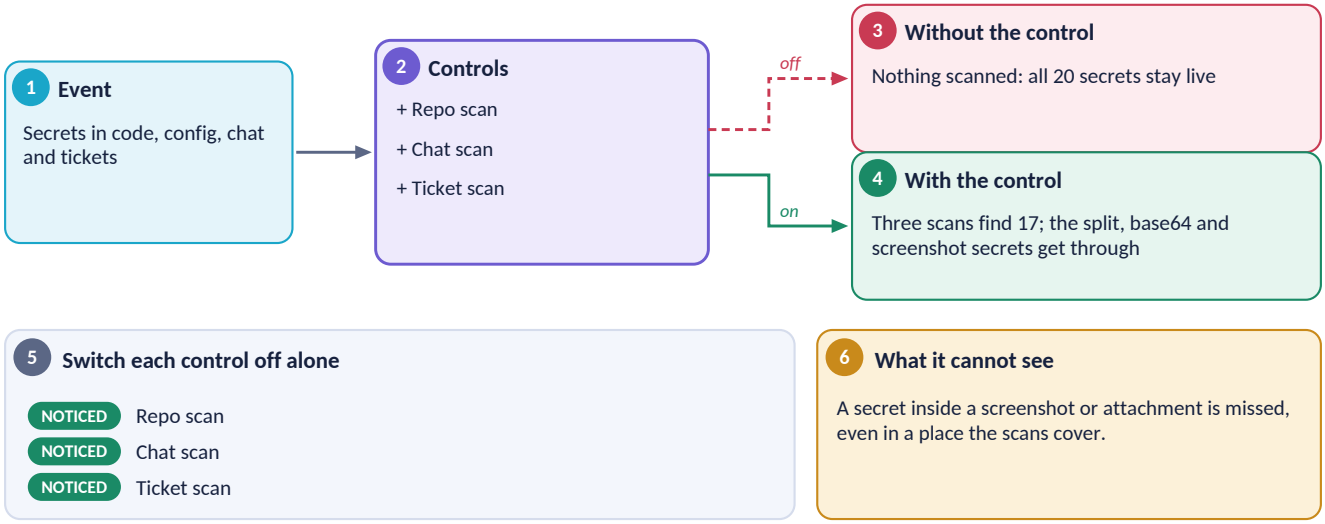
GUESS	Wrong. I guessed 3 alerts with all controls on. The result was 1 alert. The model raises one alert per new network, and all 3 replays came from the same network. Replays from 3 networks gave 3.

MEASURED	Without: accepted 12, refused 0, alerts 0, replays accepted 3, old key refused 0, can tell apart no. With: accepted 6, refused 6, alerts 1, replays accepted 0, old key refused 3, can tell apart yes.
EXTRA SCENARIO	Binding off. Result matched my guess.
EXTRA SCENARIO	Revocation off. Result matched my guess.
EXTRA SCENARIO	Alert off. Result matched my guess.
EXTRA SCENARIO	Replays from three different networks, all controls on. Result matched my guess.
TAKE-AWAY	A key copied to another network was replayed 3 times among 12 calls. Without a binding, the log showed "billing key" 12 times and nobody could tell the 6 genuine calls from the bad ones. With the key bound to the workload, the 6 bad ones were refused. I guessed 3 alerts and got 1, because the model raises one alert per new network. A call from inside the real workload still passes.

N-R14-02 Secrets in code, config, chat and tickets

Step 4: Store and issue · Run 4 · Discover · OWASP NHI2 · Guess matched · Limit recorded

20 fake secrets are planted. 8 in repository files (one split over two lines, one in base64), 4 in config files, 4 in a chat export, 4 in tickets (one only in an attached screenshot).

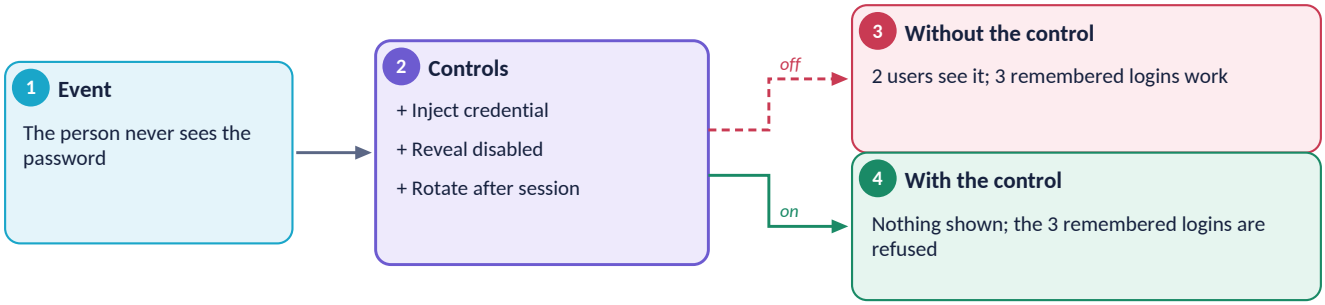


GUESS	Matched in both runs (control off, control on).
MEASURED	Without: found 0, still live 20, missed in scanned places 0, missed kinds none. With: found 17, still live 3, missed in scanned places 3, missed kinds base64, image, split.
EXTRA SCENARIO	Repo and config scan off. Result matched my guess.
EXTRA SCENARIO	Chat scan off. Result matched my guess.
EXTRA SCENARIO	Ticket scan off. Result matched my guess.
TAKE-AWAY	Three scans, each pointed at the places it covers, found 17 of 20 planted secrets. The other 3 sat inside scanned places: one split over two lines, one in base64 and one in a screenshot. Switching off any one scan left its places unprotected. No scan reads images, so the screenshot secret stays missed.

P-R15-06 The person never sees the password

Step 4: Store and issue · Run 4 · Privileged access · OWASP NHI2 · Guess wrong · Control masked · Limit recorded

10 privileged sessions go through a broker. 2 users try to reveal the password in the console. 3 users later try to log in directly with a password they remember.



5 Switch each control off alone

- MASKED Inject credential
- MASKED Reveal disabled
- NOTICED Rotate after session

6 What it cannot see

A recording tool on the user machine, or the credential in memory on the target, sits outside all three controls. This is an assertion about my model, not a measurement.

GUESS	**Wrong.** I guessed the credential injection would matter when switched off alone, and that rotation after each session was safe to drop. The reveal policy still stopped both reveals, so the injection went unnoticed. Without rotation all 3 remembered passwords still worked.
MEASURED	Without: sessions ok 10, reveals 2, direct logins ok 3, direct logins refused 0. With: sessions ok 10, reveals 0, direct logins ok 0, direct logins refused 3.
EXTRA SCENARIO	Injection off. Result differs from my guess: {'reveals': [2, 0]}.
EXTRA SCENARIO	Rotation off. Result differs from my guess: {'direct_logins_refused': [3, 0]}.
TAKE-AWAY	The credential injection and the disabled reveal button each stopped both reveals alone, so each hid the other. Rotation after every session is what refused the 3 passwords the users remembered. I got both parts of this wrong. A keylogger on the user machine is outside all three controls.

CHAPTER 9 · FRAMEWORK STEP 5 OF 7

9 Step 5: Rotate and expire

Change on a schedule, consumers first, old value proven dead.

Changing a secret is easy. Changing it without an outage, and proving the old value is dead, is where it goes wrong. This step covers rotation order, expiry, failed jobs, just-in-time windows and ranking what to fix first.

What the cases in this step showed

- Rotating before updating the application made it fail at the next connection.
- Five rotation tickets were closed while 2 old secrets still worked.
- Rotating 200 secrets caused 12 outages. Consumers first and a dry run caused none.

> **A question to ask**
> After your last rotation, did anyone test that the old secret was refused?

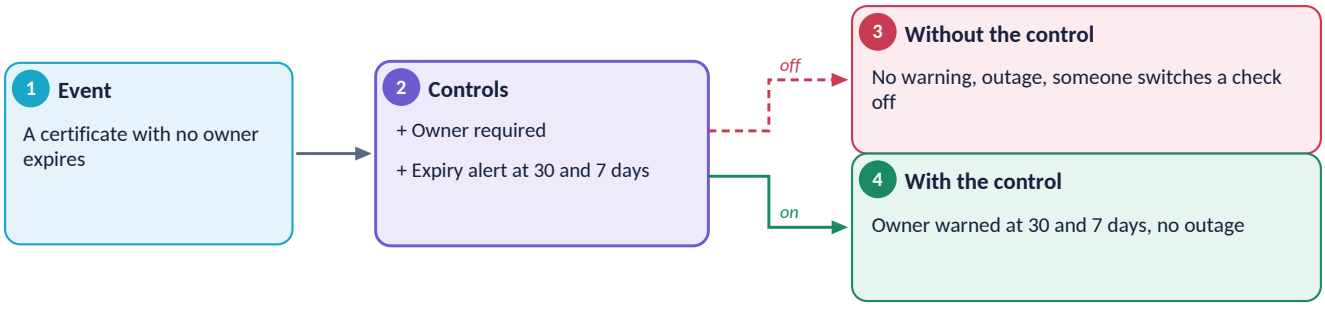
10 cases follow. All guesses in this step matched.

Event · Control · Result without the control · Result with the control · Nothing noticed, or a limit

N-R14-04 Certificate with no owner expires

Step 5: Rotate and expire · Run 1 · Credentials · **Guess matched**

A certificate expires at midnight. The expiry is 30 days away in the inventory, with no owner on record.



5 Switch each control off alone

NOTICED Owner required
NOTICED Expiry alert at 30 and 7 days

6 What it cannot see

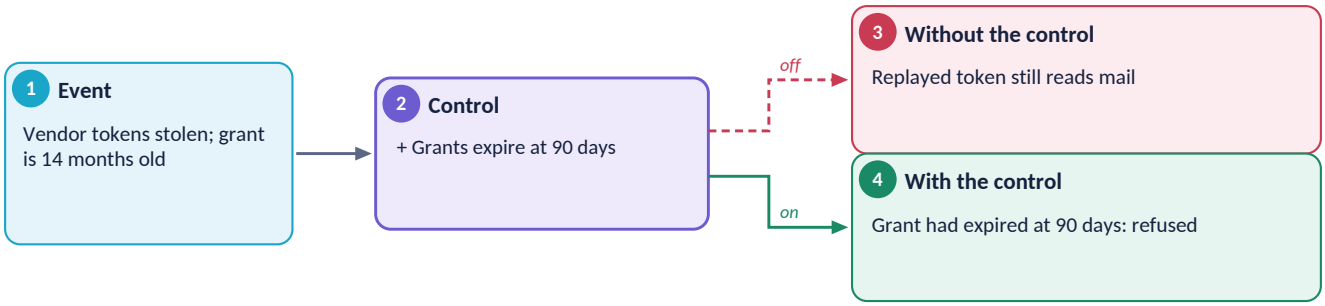
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: warnings 0, outage yes, check disabled yes. With: warnings 2, outage no, check disabled no.
TAKE-AWAY	A certificate nobody owns expires without a warning, and the usual fix is to switch the check off. An owner gets the warning at 30 and 7 days.

N-R14-05 Old OAuth grant, vendor breached

Step 5: Rotate and expire · Run 1 · Credentials · OWASP NHI3, NHI7 · **Guess matched**

A vendor app was granted wide read access 14 months ago and was last used 11 months ago. The vendor's tokens are then reported stolen.



5 Switch each control off alone

NOTICED Grants expire at 90 days

6 What it cannot see

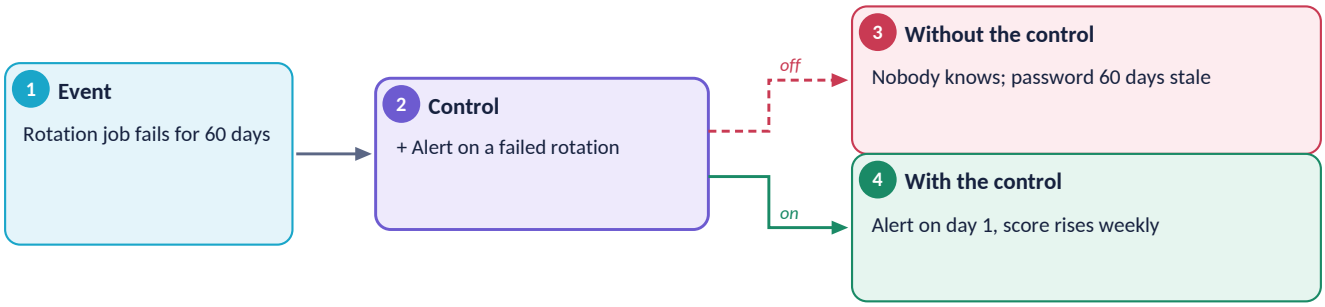
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: replay reads mail yes. With: replay reads mail no.
TAKE-AWAY	Vendor tokens outlive the vendor's care. A 90-day expiry on grants refused a 14-month-old grant even after the tokens were stolen.

N-R14-14 Rotation fails silently

Step 5: Rotate and expire · Run 1 · Credentials · OWASP NHI7 · **Guess matched**

A rotation job fails for one account for 60 days.



5 Switch each control off alone

NOTICED Alert on a failed rotation

6 What it cannot see

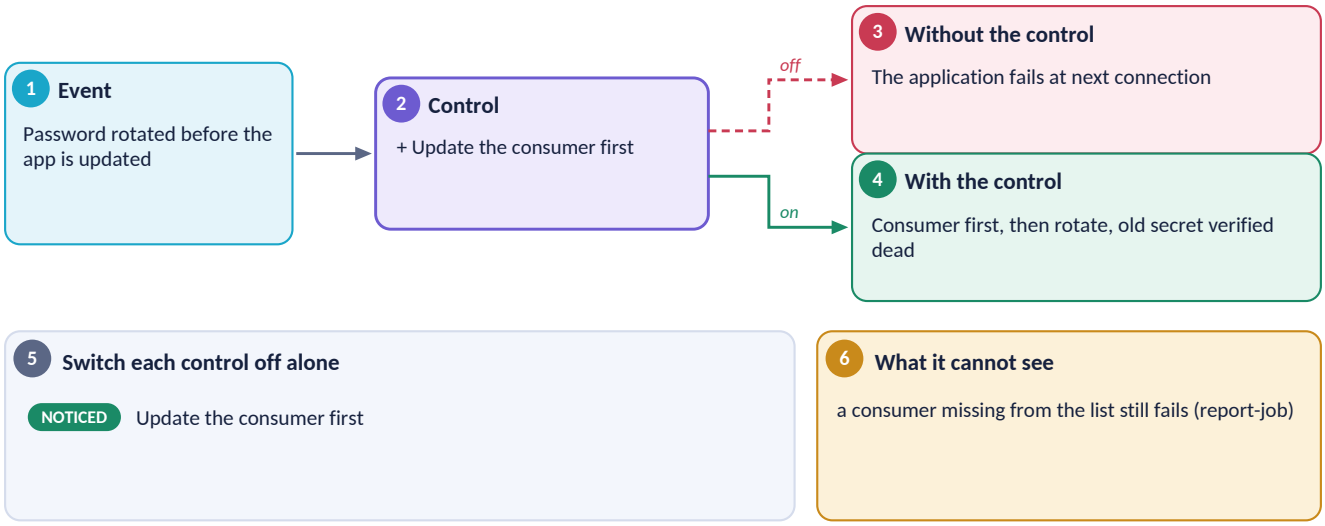
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: alert day none, days stale 60. With: alert day 1, score rises weekly yes.
TAKE-AWAY	A rotation job can fail for two months and nobody knows. An alert on day 1 and a score that rises each week make the failure visible.

N-R14-15 Rotate before consumer is updated

Step 5: Rotate and expire · Run 1 · Credentials · **Guess matched** · **Limit recorded**

A database password is rotated. The application still holds the old one.

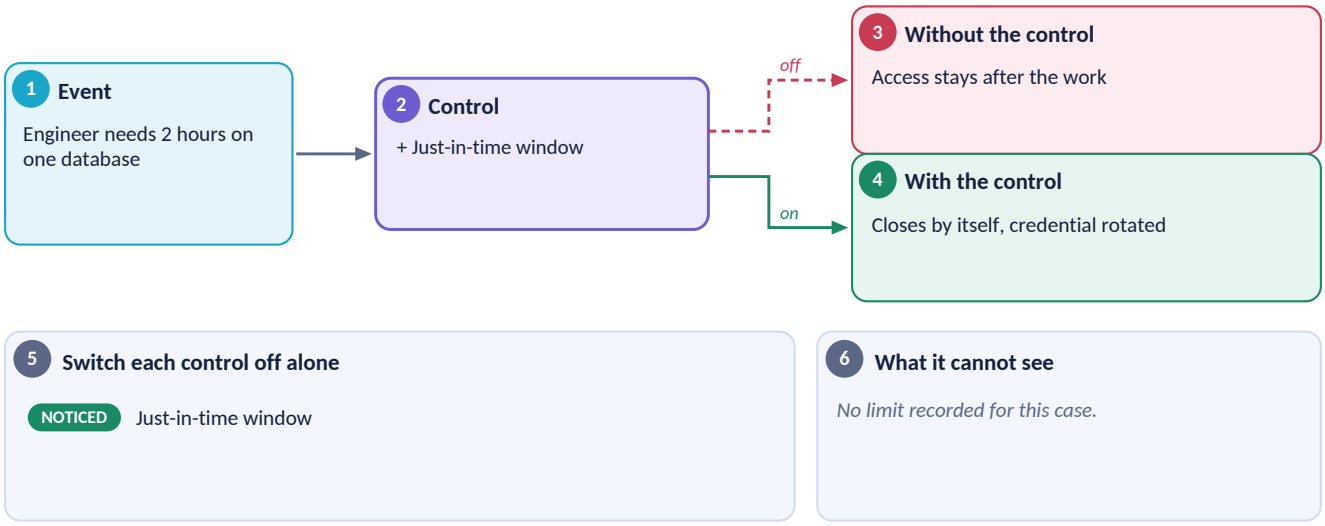


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: app fails yes. With: app fails no, old secret dead yes.
TAKE-AWAY	Rotate in the wrong order and the application fails at its next connection. Update the consumer first. A consumer missing from the list still fails.

P-R15-02 Just-in-time window

Step 5: Rotate and expire · Run 1 · Privileged access · **Guess matched**

An engineer asks for 2 hours on one database with an open ticket.

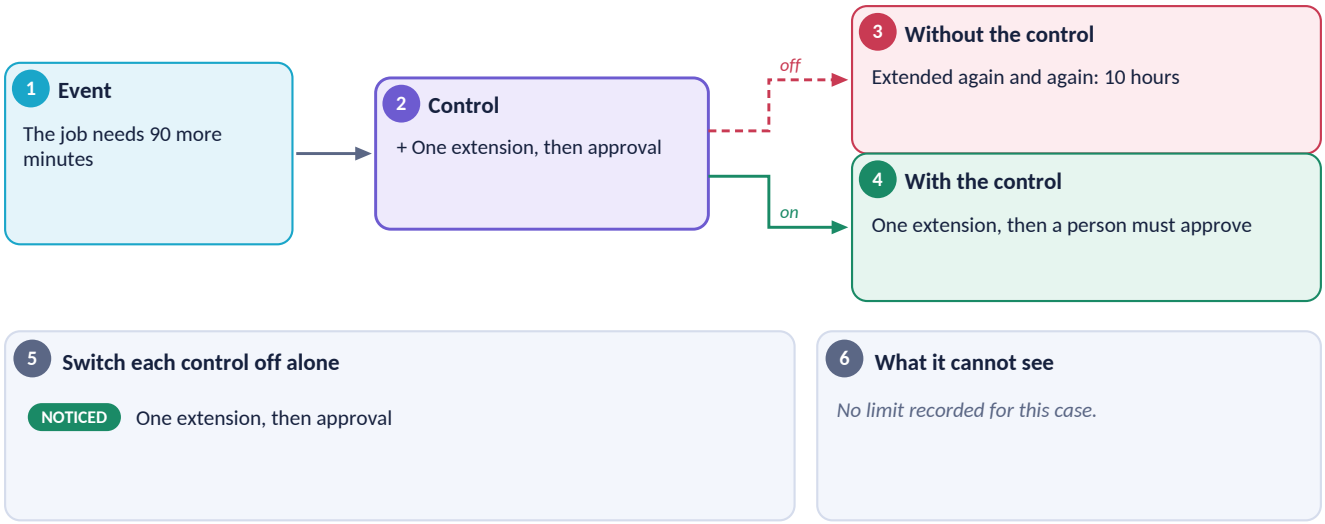


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: access after work yes. With: access after work no, credential rotated yes.
TAKE-AWAY	Standing access stays after the work is done. A two-hour window closes by itself and the credential is rotated.

P-R15-03 Work runs past the window

Step 5: Rotate and expire · Run 1 · Privileged access · Guess matched

The job needs 90 more minutes.

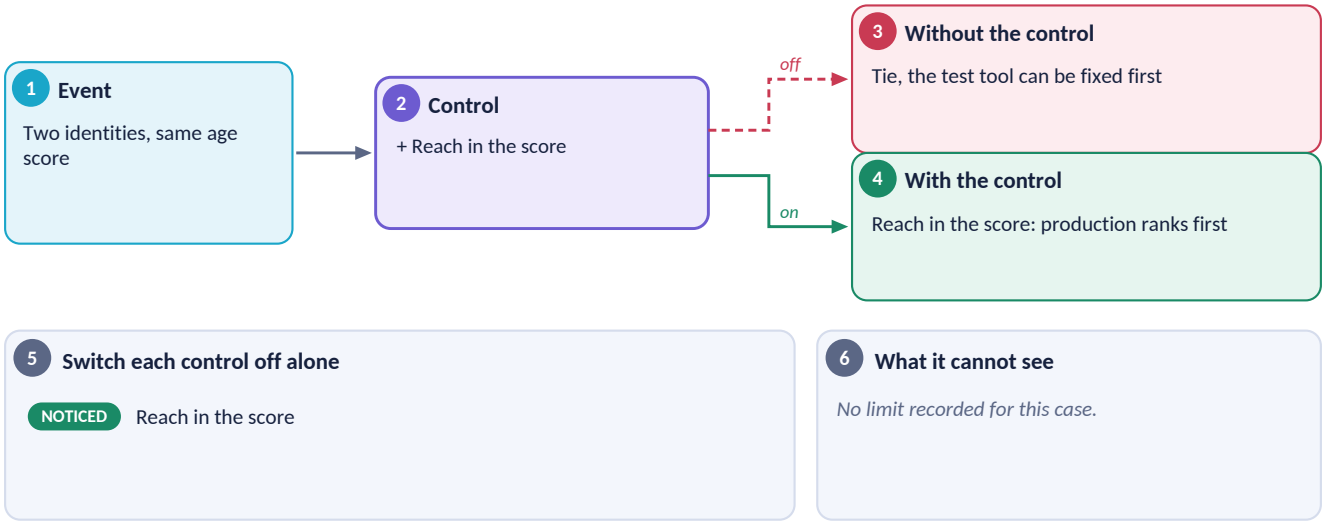


GUESS	Matched in both runs (control off, control on).
MEASURED	Without: open hours 10. With: extensions granted 1, second needs person yes.
TAKE-AWAY	Extensions can run on and on: 10 hours in the model. One extension, then a named person, stopped that.

N-R14-19 Scoring: rank so the top gets fixed first

Step 5: Rotate and expire · Run 2 · Credentials · Guess matched

Two identities with the same age score, one reaches production data and one reaches a test tool.

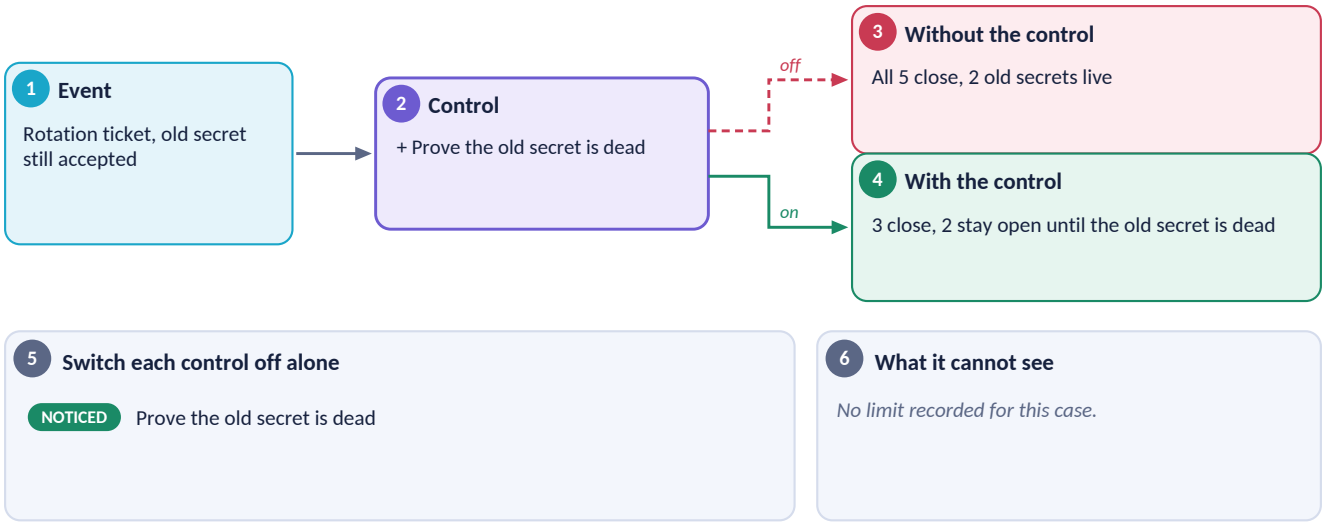


GUESS	Matched in both runs (control off, control on).
MEASURED	Without: tie yes, first none, listed first prod-payments. With: tie no, first prod-payments, listed first prod-payments.
TAKE-AWAY	Two identities with the same age score tied. Putting reach into the score ranked the production one first, so it is fixed first.

N-R14-20 Close only when the old secret is dead

Step 5: Rotate and expire · Run 2 · Credentials · **Guess matched**

A rotation ticket for 5 secrets. Two old secrets are still accepted by the target.

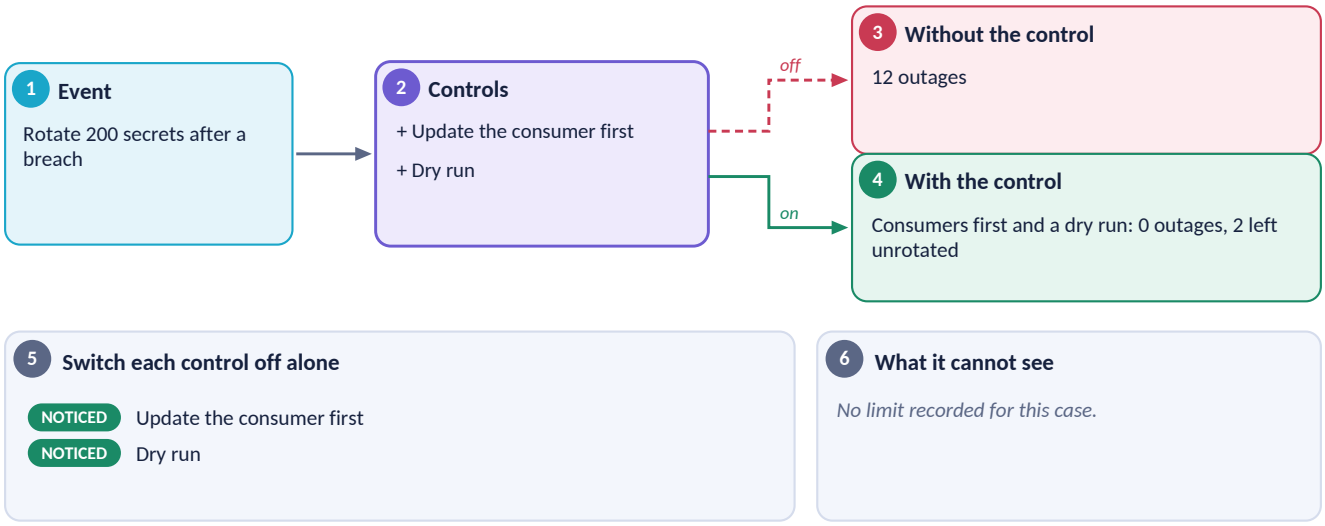


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: closed 5, open 0, old live 2. With: closed 3, open 2.
TAKE-AWAY	Closing a rotation ticket does not prove the old secret is dead. Of 5 tickets, 2 had old secrets still accepted. Checking first closed 3 and kept 2 open.

P-R15-25 Mass rotation after a breach

Step 5: Rotate and expire · Run 2 · Privileged access · **Guess matched**

200 secrets must be rotated. 12 consumers fail if rotated before their app is updated.

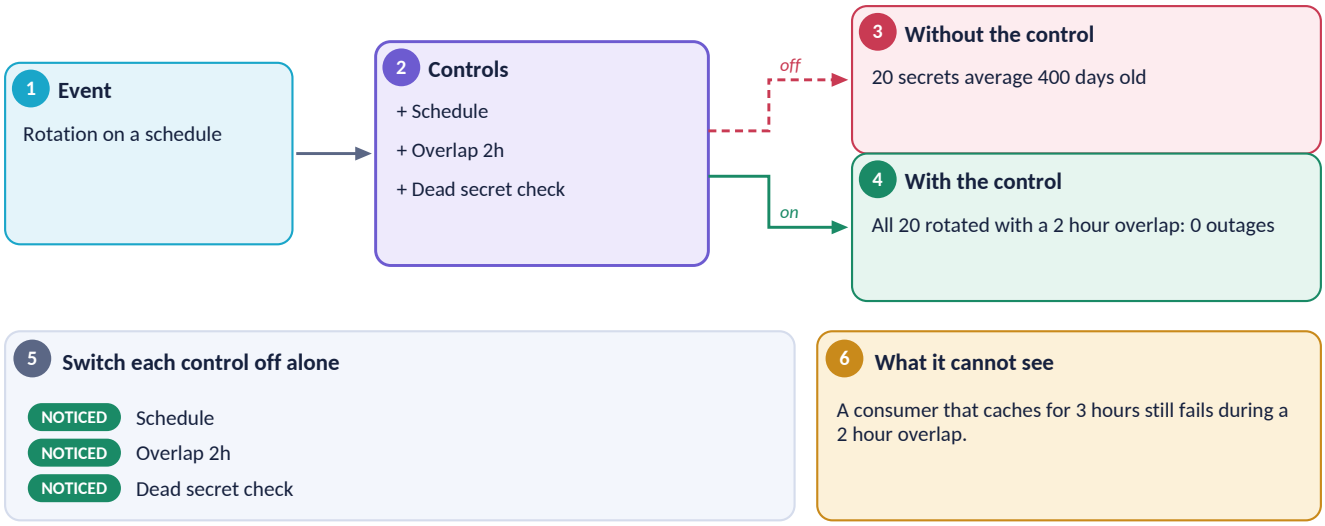


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: outages 12, unrotated 0. With: outages 0, unrotated 2.
TAKE-AWAY	Rotating 200 secrets after a breach caused 12 outages. Consumers first plus a dry run caused none, and left 2 secrets unrotated for a person to deal with.

N-R14-13 Rotation on a schedule

Step 5: Rotate and expire · Run 4 · Credentials · OWASP NHI7 · **Guess matched** · **Limit recorded**

20 secrets are due for rotation. 3 of their consumers cache the secret for up to an hour.



GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: rotated 0, avg age days 400, outages 0, old secrets valid after 2h 0. With: rotated 20, avg age days 0, outages 0, old secrets valid after 2h 0.
EXTRA SCENARIO	Overlap off. Result matched my guess.
EXTRA SCENARIO	Dead-secret check off. Result matched my guess.
EXTRA SCENARIO	Schedule off. Result matched my guess.
TAKE-AWAY	Rotating 20 secrets that averaged 400 days old caused no outage with a 2 hour overlap, and the dead-secret check left no old secret valid. A consumer that caches the secret for 3 hours still failed despite the overlap.

CHAPTER 10 • FRAMEWORK STEP 6 OF 7

10 Step 6: Watch

Use is logged and the odd use is noticed.

Use of a credential is logged and the odd use is noticed. The cases here cover break-glass accounts, shared accounts, the drill, session analytics and the integration feed. Break-glass is the one place where use is expected to be rare and loud.

What the cases in this step showed

- Break-glass used at 2 a.m. went unnoticed without an alert.
- Used for routine work on four days, it was noticed only because a monthly report flagged 2 uses with no ticket.
- In one chain test the alert reported the reuse and the rotation stopped it. They are not the same control.
- The break-glass drill found 1 fault, not the 2 I guessed, because the routing check had already caught one.
- Session analytics flagged 4 of 5 odd sessions and 10 normal ones. A 950 MB copy never reached the 1000 MB threshold.

> **A question to ask**
> If your break-glass account were used tonight, who would know by morning?

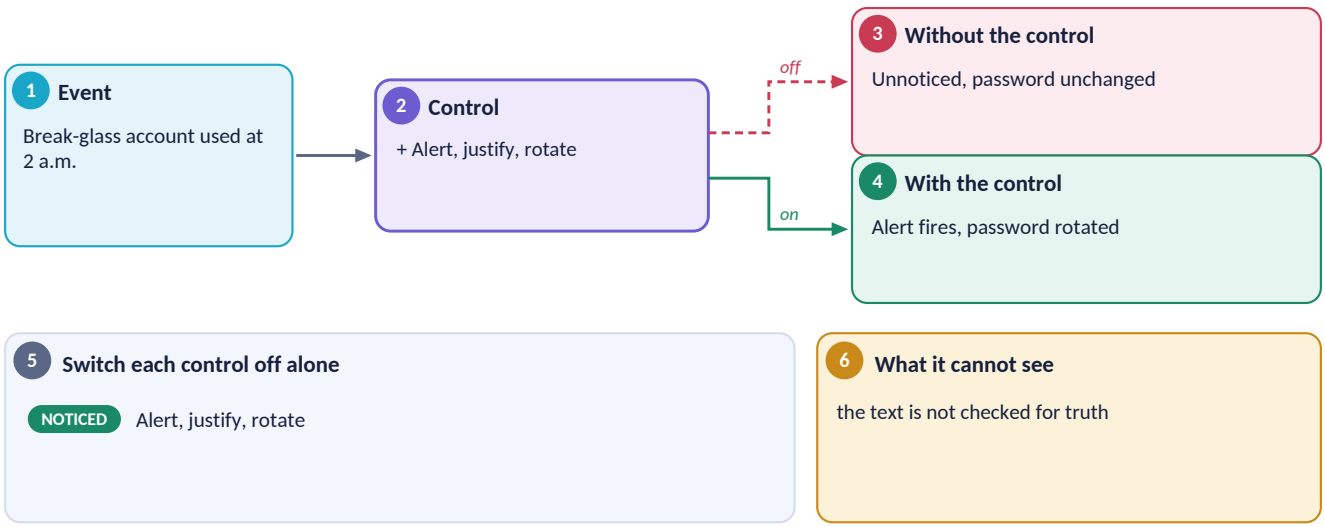
7 cases follow. Guesses that were wrong: P-R15-12, P-R15-22. Controls nothing noticed: P-R15-14, P-R15-24.

Event · Control · Result without the control · Result with the control · Nothing noticed, or a limit

P-R15-11 Break-glass used at 2 a.m.

Step 6: Watch · Run 1 · Privileged access · **Guess matched** · **Limit recorded**

The sign-in service is down. The break-glass account is used.

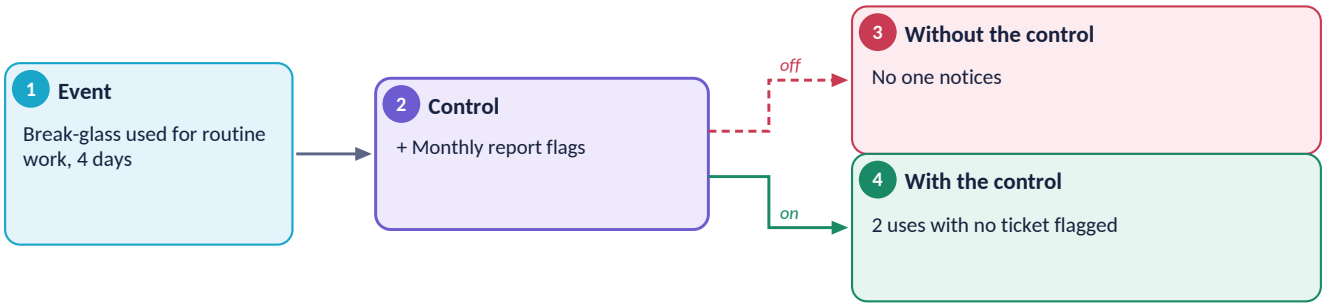


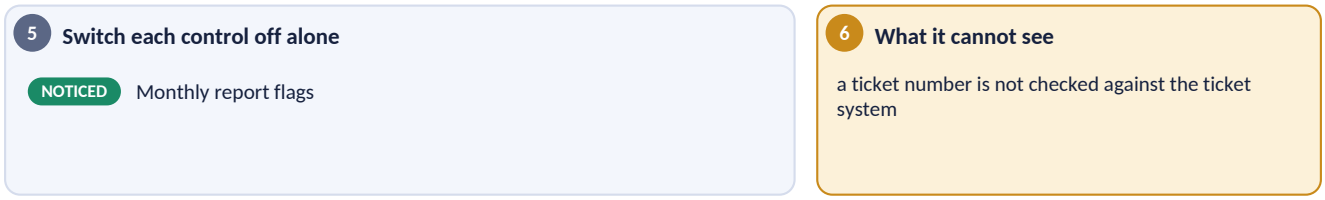
GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: alert no, rotated no. With: alert yes, rotated yes.
TAKE-AWAY	Break-glass used at 2 a.m. went unnoticed and the password stayed the same. An alert, a written reason and a rotation covered it. The reason is text, and the model does not check it is true.

P-R15-13 Break-glass becomes a side door

Step 6: Watch · Run 1 · Privileged access · **Guess matched** · **Limit recorded**

The break-glass account is used for routine work on four days in a month.



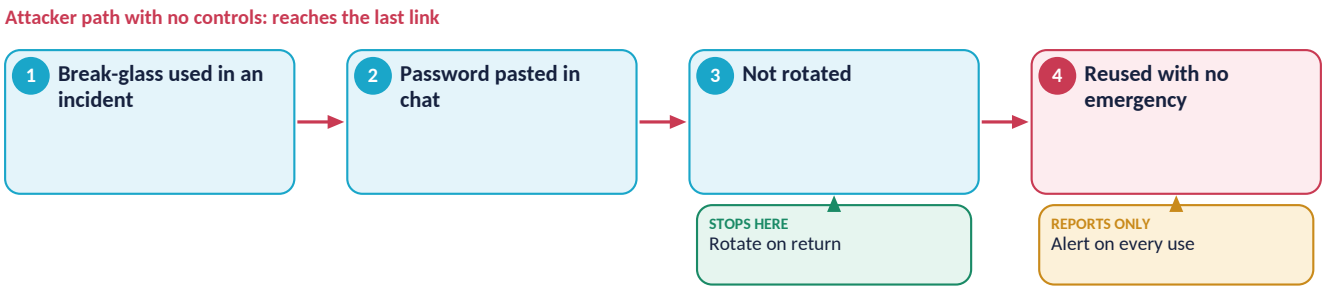


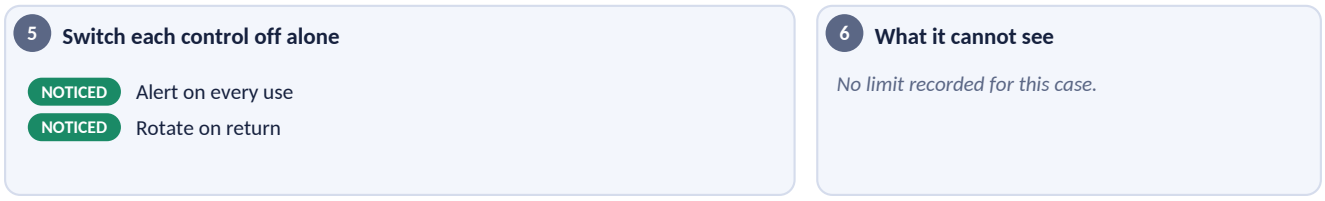
GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: flagged 0. With: flagged 2.
TAKE-AWAY	Break-glass can turn into a side door for routine work. A monthly report flagged 2 uses with no ticket. A ticket number is not checked against the ticket system.

C-R16-C05 The break-glass password everyone knows

Step 6: Watch · Run 2 · Chain tests · **Guess matched**

Chain of links: used in an incident, pasted in chat, not rotated, reused with no emergency.





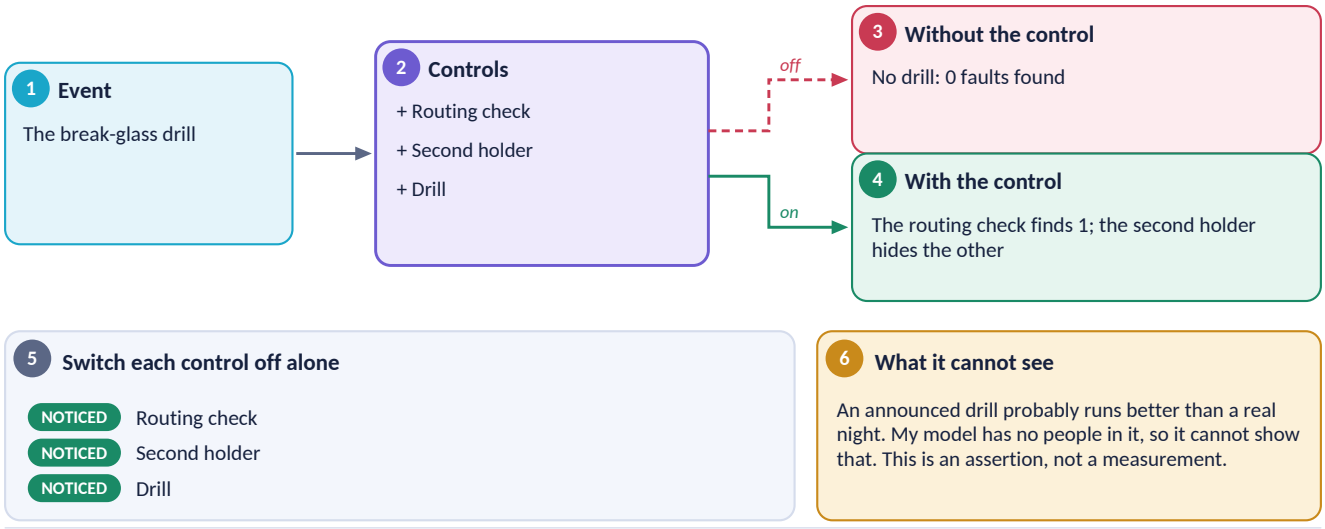
GUESS	**Matched** in both runs (control off, control on).

MEASURED	Without controls: the attacker reaches the last link. With all controls: stopped at link 3. Reported at link 4. Each control alone: Alert on every use does not stop it; Rotate on return stops it at link 3. Best single control: Rotate on return.
TAKE-AWAY	An alert on every use reports the reuse at link 4 and does not stop it. Rotating the password on return makes the pasted one useless, which stops the chain at link 3.

P-R15-12 The break-glass drill

Step 6: Watch · Run 4 · Privileged access · **Guess wrong** · **Limit recorded**

A quarterly drill with 4 steps: the alert fires, an on-call person acknowledges within 15 minutes, the sealed copy is found, and the password is rotated afterwards. Two faults are planted: the alert still goes to a person who left, and the sealed copy is with a person on leave.

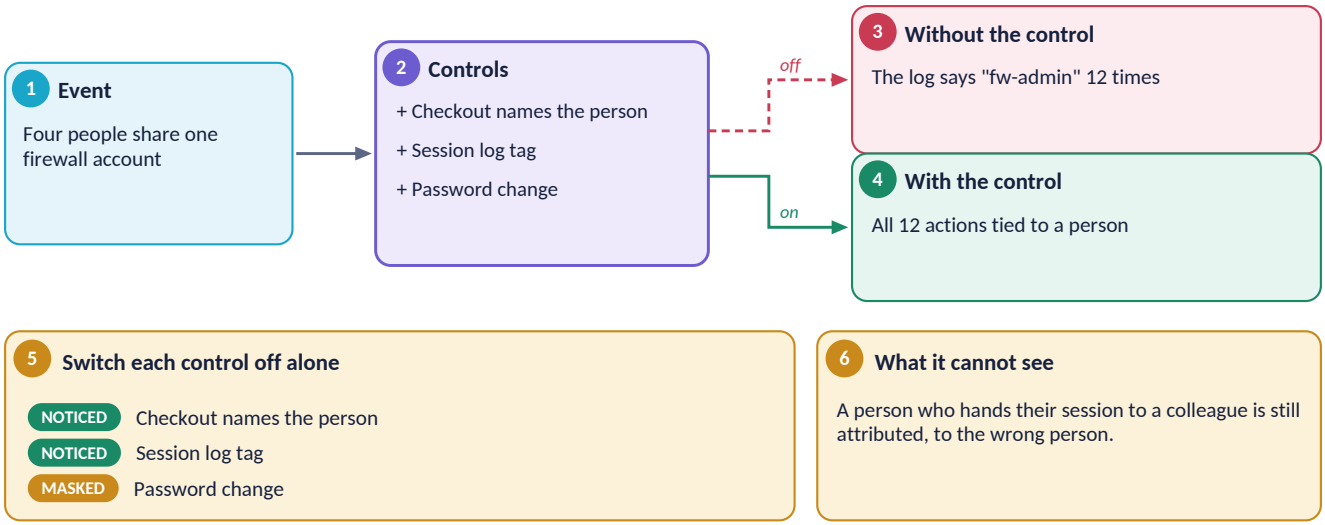


GUESS	**Wrong.** I guessed the drill would find 2 faults and that nothing finds a fault without it. It found 1. The routing check caught the alert fault before the drill ran, and the second holder made the sealed copy fault harmless without removing it.
MEASURED	Without: faults found 0, faults fixed 0, first run failures none, steps pass second run none. With: faults found 1, faults fixed 1, first run failures 0, steps pass second run 4.
EXTRA SCENARIO	Routing check off. Result matched my guess.
EXTRA SCENARIO	Second holder off. Result matched my guess.
EXTRA SCENARIO	Drill off. Result differs from my guess: {'faults_found': [0, 1]}.
TAKE-AWAY	The drill found 1 fault, not 2. The routing check caught the alert fault before any drill ran, and the second holder made the sealed copy fault harmless without removing it. An announced drill may be easier than a real night, which a model with no people in it cannot show.

P-R15-14 Shared accounts: who did what

Step 6: Watch · Run 4 · Privileged access · OWASP NHI9 · **Guess matched** · **Control masked** · **Limit recorded**

One shared firewall account is used by 4 people. 12 actions in a day. 2 sessions overlap.

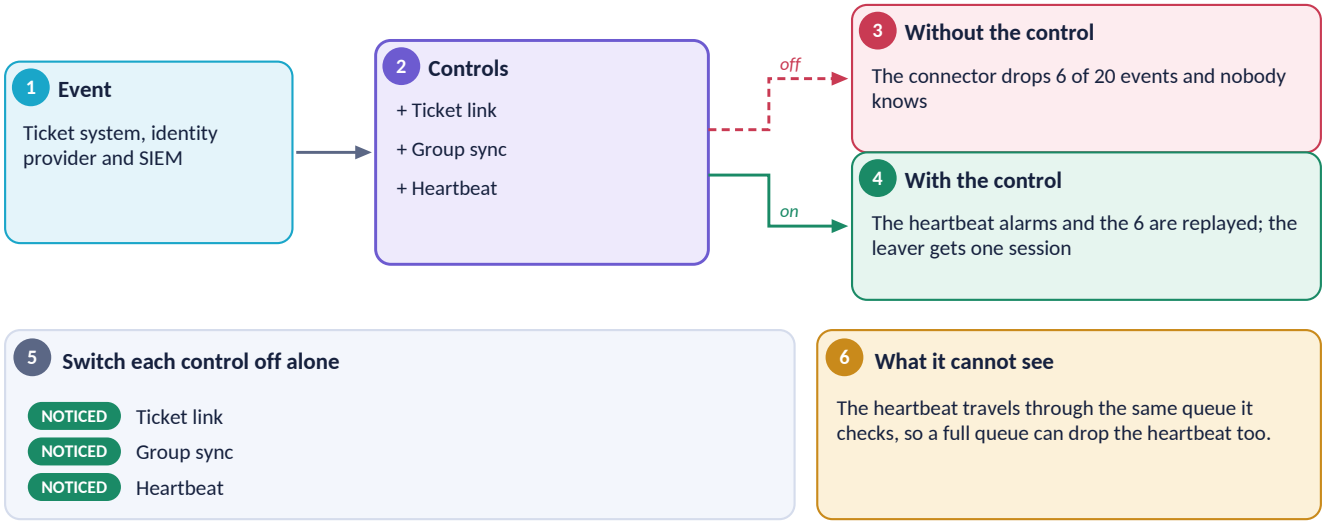


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: attributed 0, ambiguous 0, password changes 0, late login possible yes. With: attributed 12, ambiguous 0, password changes 4, late login possible no.
EXTRA SCENARIO	Log tag off. Result matched my guess.
EXTRA SCENARIO	Password change off. Result matched my guess.
EXTRA SCENARIO	Check-out off. Result matched my guess.
TAKE-AWAY	Check-out that names the person attributed all 12 actions once the session log tag was on. Without the tag, 10 were attributed and 2 were ambiguous. Without check-out, none were. A session handed over between people is attributed to the wrong person.

P-R15-22 Integration with ticket system, identity provider and SIEM

Step 6: Watch · Run 4 · Privileged access · **Guess wrong** · **Limit recorded**

20 privileged sessions in a day. The ticket system links each session to a ticket. The identity provider syncs group changes. The SIEM receives an event per session. The SIEM connector drops events when its queue is full. One leaver is removed at the identity provider 1 hour before the sync reaches the vault.



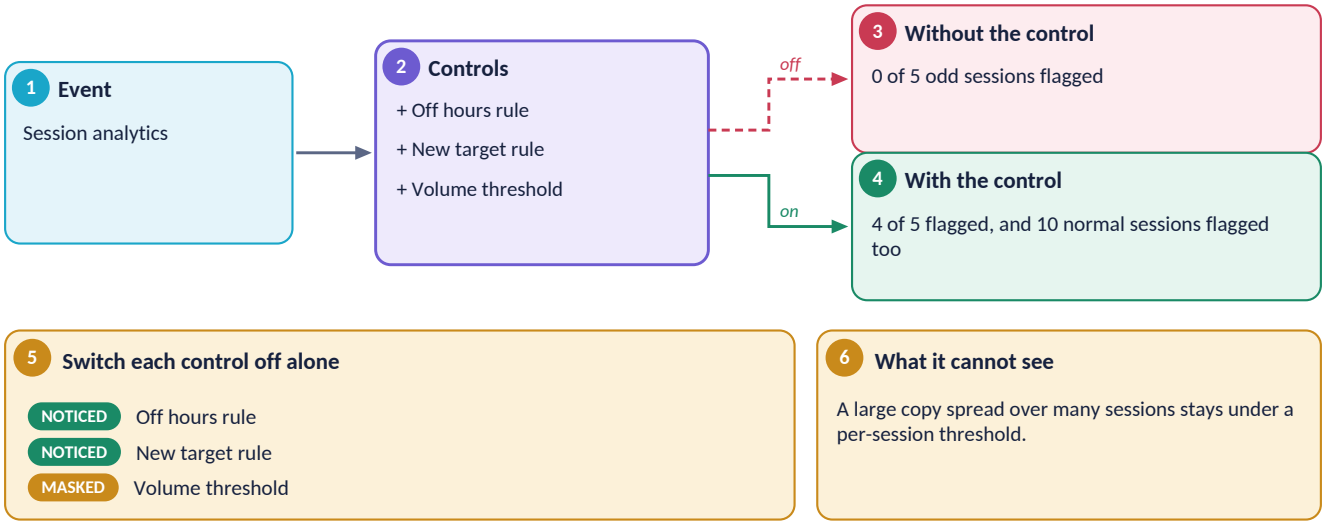
GUESS	**Wrong.** I guessed 0 events arrived without controls. The connector delivers 14 of 20 and drops 6 whether or not a heartbeat exists. The heartbeat adds the alarm and the replay, not the delivery.

MEASURED	Without: tickets linked 0, siem events arrived 14, lost unnoticed 6, heartbeat alarmed no, leaver session in gap 1, leaver access after sync yes. With: tickets linked 20, siem events arrived 20, lost unnoticed 0, heartbeat alarmed yes, leaver session in gap 1, leaver access after sync no.
EXTRA SCENARIO	Heartbeat off. Result matched my guess.
EXTRA SCENARIO	Sync off. Result matched my guess.
EXTRA SCENARIO	Ticket link off. Result matched my guess.
TAKE-AWAY	Tickets were linked for all 20 sessions, and the heartbeat raised an alarm for lost events. The connector delivered 14 of 20 either way, so I was wrong that nothing arrived without controls. A heartbeat that goes through the same full queue it checks can miss the loss.

P-R15-24 Session analytics

Step 6: Watch · Run 4 · Privileged access · **Guess matched** · **Control masked** · **Limit recorded**

200 privileged sessions. 5 are odd: 3 outside working hours, 1 to a target the person never used, 1 that copies a large amount of data.



GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: odd flagged 0, odd missed 5, false positives 0. With: odd flagged 4, odd missed 1, false positives 10.
EXTRA SCENARIO	Off hours rule off. Result matched my guess.
EXTRA SCENARIO	New target rule off. Result matched my guess.
EXTRA SCENARIO	Volume threshold off. Result matched my guess.
TAKE-AWAY	The off hours and new target rules flagged 4 of the 5 odd sessions and 10 normal ones. The volume rule never fired, because the large copy was 950 MB against a 1000 MB threshold. Twenty copies of 100 MB stay under it as well.

CHAPTER 11 · FRAMEWORK STEP 7 OF 7

11 Step 7: Retire and respond

Remove what is unused, cut access fast after a breach.

What nobody uses should go, in stages, and access to a breached vendor should end quickly. This step covers retired applications, vendor sessions, AI-tool grants, a breached vendor and automations that outlive a test.

What the cases in this step showed

- After an application was retired, all 3 of its identities still worked 90 days later.
- A vendor session left no record and no end. A broker that recorded it closed it at 4 hours.
- Five automations outlived a test. A sweep disabled 4 of them.

> **A question to ask**
> When did you last switch off something nobody could name an owner for?

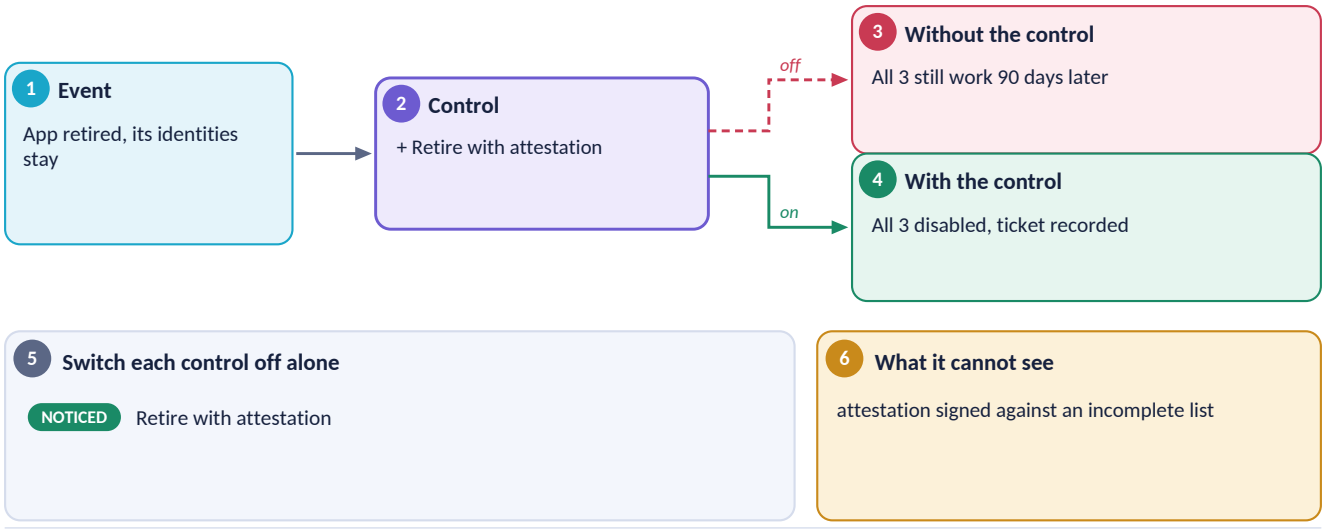
8 cases follow. All guesses in this step matched. Controls nothing noticed: N-R14-23, C-R16-C04, N-R14-16.

Event · Control · Result without the control · Result with the control · Nothing noticed, or a limit

N-R14-11 Application retired, identities remain

Step 7: Retire and respond · Run 1 · Own and retire · OWASP NHI1 · **Guess matched** · **Limit recorded**

An application is retired. Its service account, key and database user stay active.

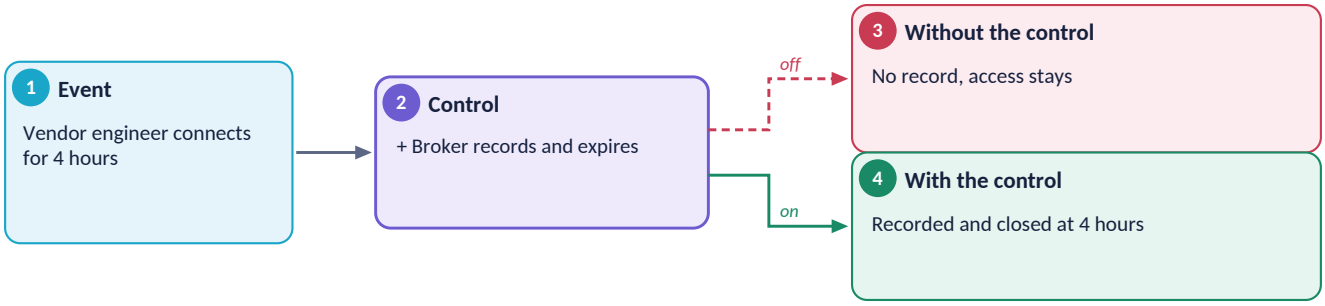


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: active after 90d 3. With: active after 90d 0, ticket yes.
TAKE-AWAY	Retiring an application does not retire its identities. The attestation rule closed all three, but only against the list it was given. An incomplete list leaves some open.

P-R15-17 Vendor session

Step 7: Retire and respond · Run 1 · Privileged access · **Guess matched**

A vendor engineer connects for a slow query. The sponsor approved 4 hours.



5 Switch each control off alone

NOTICED Broker records and expires

6 What it cannot see

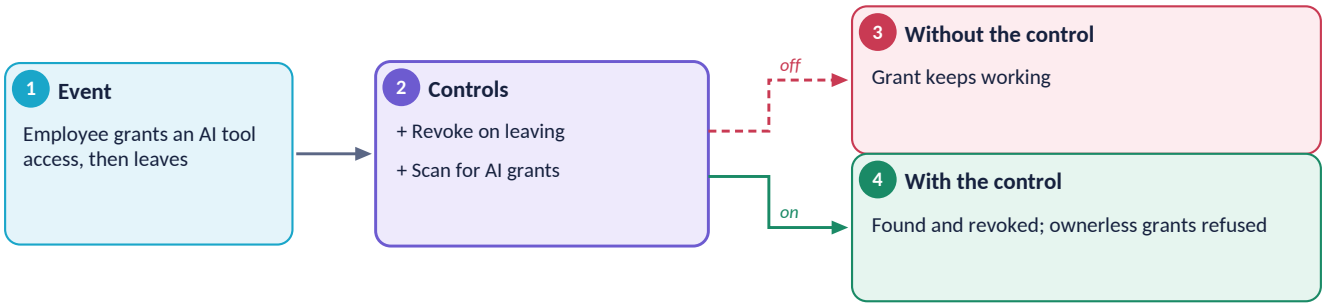
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: recorded no, open at 5h yes. With: recorded yes, open at 5h no.
TAKE-AWAY	A vendor session with no record and standing access is the default. A broker that records the session and closes it at 4 hours replaced it.

S-R17-01 Personal OAuth grant to an AI tool

Step 7: Retire and respond · Run 1 · Shadow AI · OWASP NHI1, NHI3 · **Guess matched**

An employee grants an AI tool read access to mail and files with a personal approval. The employee then leaves.



5 Switch each control off alone

NOTICED Revoke on leaving
NOTICED Scan for AI grants

6 What it cannot see

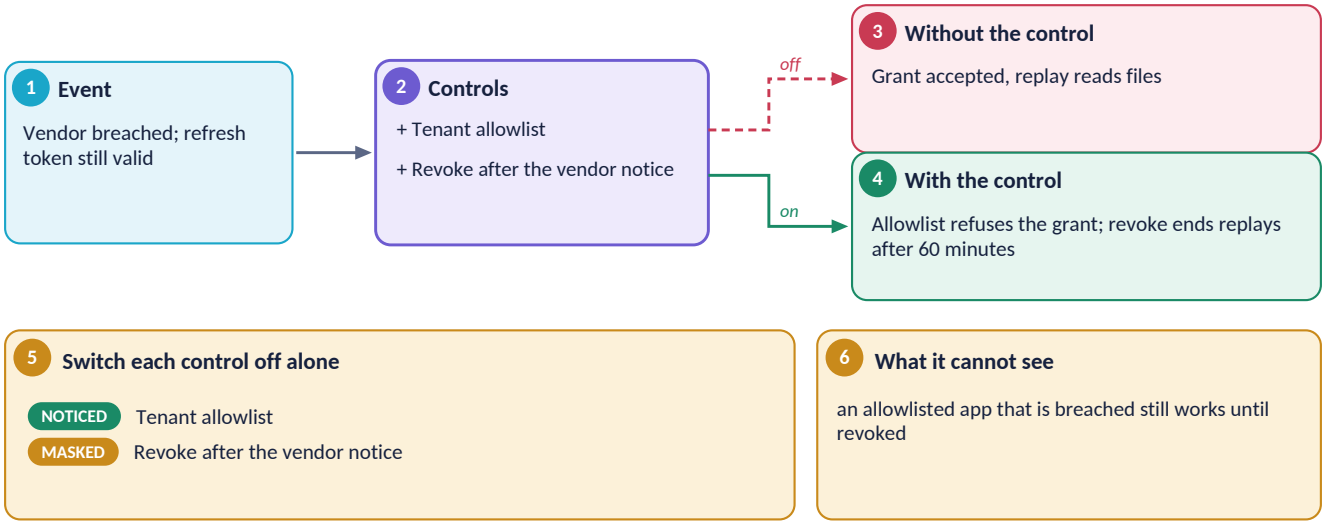
No limit recorded for this case.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: grant works after leaver yes, grant flagged no. With: grant found yes, grant revoked yes, ownerless new refused yes.
TAKE-AWAY	An employee's grant to an AI tool kept working after they left. Revoking on leaving and scanning for grants found it, and grants with no owner were refused.

N-R14-23 Vendor breached, OAuth refresh token still valid

Step 7: Retire and respond · Run 1 · Gap cases from 2026 incidents · OWASP NHI3 · **Guess matched** · **Control masked** · **Limit recorded**

An employee linked an AI office app with "allow all" 20 days ago. The vendor is then breached. The attacker replays the refresh token from their own network.

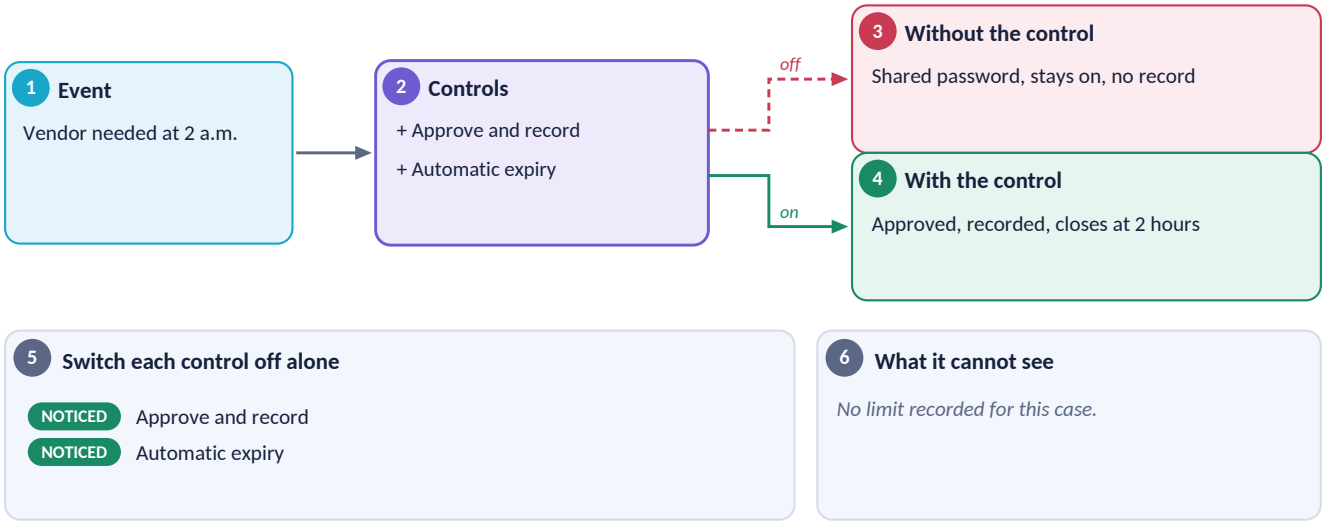


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: grant accepted yes, replay min30 yes, replay min90 yes. With: grant accepted no, replay min30 no, replay min90 no.
EXTRA SCENARIO	Revoke only (app already granted). Result matched my guess.
EXTRA SCENARIO	Revoke off, allowlist off. Result matched my guess.
TAKE-AWAY	Letting every app in lets a breached vendor's token in. An allowlist refused the grant. An allowlisted app that is breached still works until you revoke it, and revoking ended replays only after 60 minutes.

P-R15-19 A vendor is needed at 2 a.m.

Step 7: Retire and respond · Run 2 · Privileged access · OWASP NHI9 · **Guess matched**

A vendor engineer needs access for an emergency.

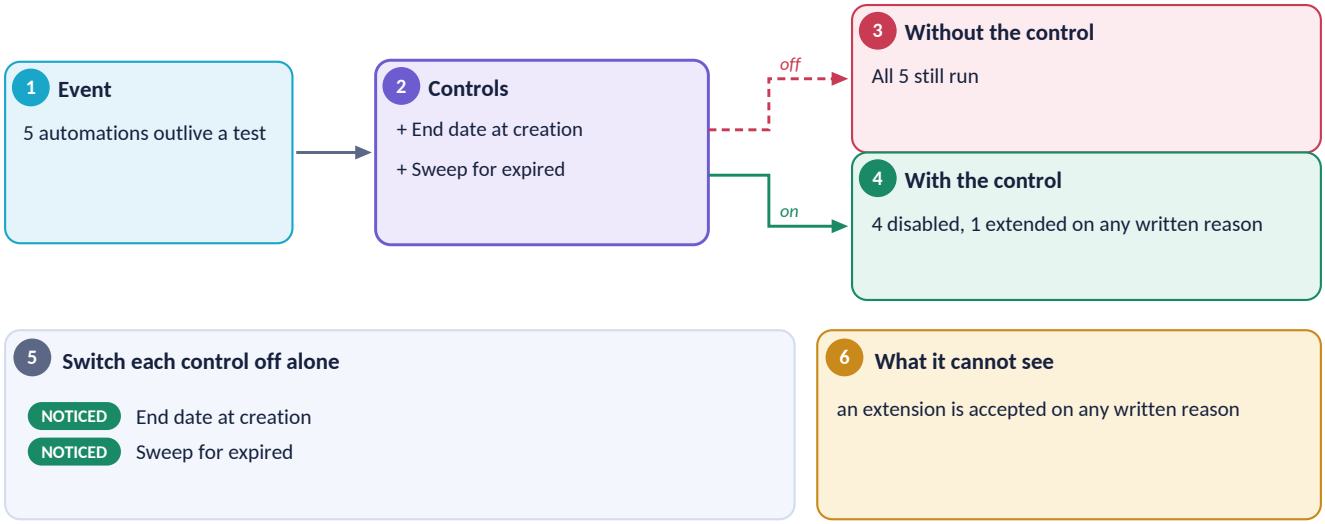


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: active after 3h yes, recorded no. With: active after 3h no, recorded yes.
TAKE-AWAY	A vendor needed at 2 a.m. got a shared password that stayed on. An approved and recorded session that closes at 2 hours replaced it.

S-R17-10 Scheduled automations outlive the test window

Step 7: Retire and respond · Run 2 · Shadow AI · OWASP NHI1 · **Guess matched** · **Limit recorded**

5 scheduled workflows were created for a test that ended 30 days ago.

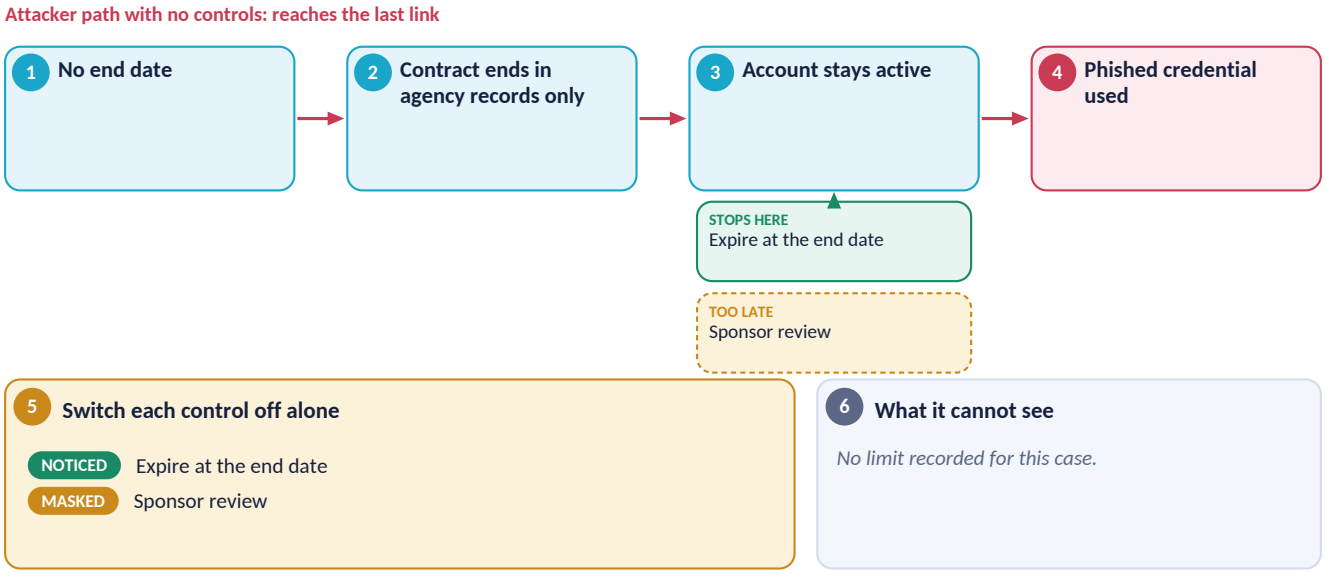


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: disabled 0, running 5. With: disabled 4, running 1.
TAKE-AWAY	Five automations outlived a test. An end date at creation plus a sweep disabled 4. One was extended, and an extension is accepted on any written reason.

C-R16-C04 The contractor who never left

Step 7: Retire and respond · Run 2 · Chain tests · **Guess matched** · **Control masked**

Chain of links: no end date, contract ends in agency records, account stays, phished credential used.

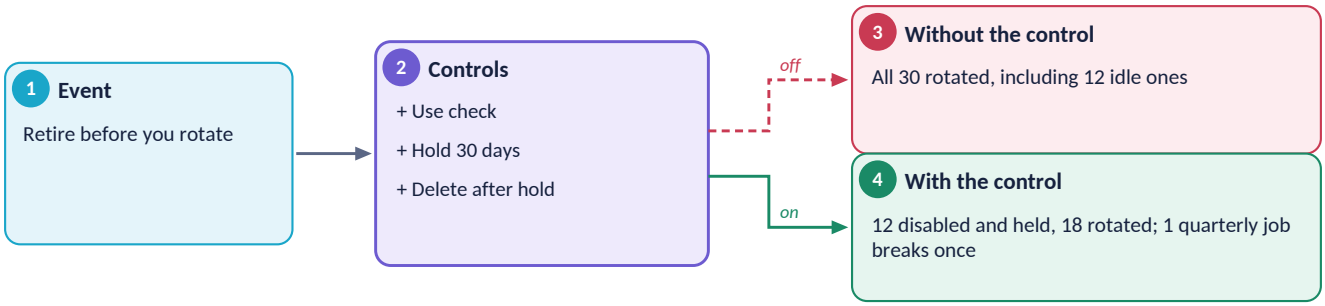


GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without controls: the attacker reaches the last link. With all controls: stopped at link 3. Each control alone: Expire at the end date stops it at link 3; Sponsor review does not stop it. Best single control: Expire at the end date.
EXTRA SCENARIO	Attack 120 days after contract end, sponsor review runs at 90. Result matched my guess.
TAKE-AWAY	Expiring the account at the end date stops the chain at link 3. A sponsor review alone leaves a window of up to 90 days. If the attack comes 120 days after the contract ends, the review does stop it.

N-R14-16 Retire before you rotate

Step 7: Retire and respond · Run 4 · Own and retire · OWASP NHI1 · **Guess matched** · **Control masked** · **Limit recorded**

30 identities are due for rotation. 12 have not been used for 90 days or more. 1 of those 12 is used by a quarterly job.



5 Switch each control off alone

- NOTICED Use check
- NOTICED Hold 30 days
- MASKED Delete after hold

6 What it cannot see

The use logs miss 2 identities that sign in by an older route, so they are retired while still in use.

GUESS	**Matched** in both runs (control off, control on).
MEASURED	Without: disabled 0, rotated 30, outages 0, permanent loss 0. With: disabled 12, rotated 18, outages 1, permanent loss 0.
EXTRA SCENARIO	Hold off. Result matched my guess.
EXTRA SCENARIO	Use check off. Result matched my guess.
TAKE-AWAY	The use check disabled 12 of 30 identities, rotated the other 18, and 1 outage followed. The 30 day hold meant nothing was lost for good. Without the hold, that identity would have been lost permanently. Use logs that miss an older sign-in route make a used identity look idle.

CHAPTER 12

12 Results

What matched, what was wrong, what nothing noticed, and what each control cannot see.

By framework step

Step	Cases	Matched	Wrong	Control masked	Limit recorded
Find	6	4	2	1	3
Own	8	8	0	2	2
Limit	18	17	1	7	12
Store and issue	10	5	5	5	4
Rotate and expire	10	10	0	0	2
Watch	7	5	2	2	6
Retire and respond	8	8	0	3	4
All	**67**	**57**	**10**	**20**	**33**

The ten wrong guesses

A wrong guess is the most useful thing the lab produced. Each is recorded with what I wrote and what happened.

Case	What I wrote	What happened
S-R17-05 Secrets in AI-assisted code and config	I guessed the scan would miss 1 of 8 planted secrets.	It missed 2: a secret split over two lines and one in base64.
N-R14-25 Credential stolen from a CI runner, replayed	I guessed a short token lifetime would change whether a replay worked.	It changed nothing. Binding the token and revoking it already refused both replays.
N-R14-07 One identity, three names	I guessed 51 entries without the control and 30 with it.	The true counts are 43 and 29. Nine identities with 2 or 3 names each cannot make 51. The rule also merged two real accounts.
C-R16-C01 The forgotten service account	I guessed the secret scan on tickets would be the most useful single control.	The owner rule was. It stops the chain at the first link.
N-R18-01 A copied key from another network	I guessed 3 alerts with all controls on.	The result was 1 alert. The model raises one alert per new network, and all 3 replays came from the same network. Replays from 3 networks gave 3.
P-R15-06 The person never sees the password	I guessed the credential injection would matter when switched off alone, and that rotation after each session was safe to drop.	The reveal policy still stopped both reveals, so the injection went unnoticed. Without rotation all 3 remembered passwords still worked.

Case	What I wrote	What happened
P-R15-12 The break-glass drill	I guessed the drill would find 2 faults and that nothing finds a fault without it.	It found 1. The routing check caught the alert fault before the drill ran, and the second holder made the sealed copy fault harmless without removing it.
P-R15-22 Integration with ticket system, identity provider and SIEM	I guessed 0 events arrived without controls.	The connector delivers 14 of 20 and drops 6 whether or not a heartbeat exists. The heartbeat adds the alarm and the replay, not the delivery.
S-R17-08 An agent built in a low code tool and never registered	I guessed 4 agents would hold credentials at day 10 with the issue rule off, and that the 30 day expiry would go unnoticed.	The scan had already flagged them and 3 owners had registered, so 1 agent holds credentials. The expiry is what disables the last one.
S-R17-09 An agent creates credentials and sub agents for itself	I guessed 4 alerts.	The model alerts on each of the 5 creation attempts, refused or not. Alerting only on creations that succeed would give 1. I never wrote down which I meant.

Controls that nothing noticed

In 20 cases at least one control could be switched off alone and nothing changed. That means another control was doing the same job, or this control did not matter in that case. In both cases you cannot tell it is working by looking at the result.

Case	Control(s) masked	Switched off alone, noticed instead
N-R14-23 Vendor breached, OAuth refresh token still valid	Revoke after the vendor notice	Tenant allowlist
N-R14-25 Credential stolen from a CI runner, replayed	Short token lifetime	Bind the token and revoke
P-R15-16 Help desk reset path	Strong proof for a reset; Notice and delay	None. Every control was masked by another.
S-R17-06 AI-service keys leak into repositories	Rotate every 90 days	Scan and revoke on find
C-R16-C01 The forgotten service account	Secret scan on tickets; Rotation	Owner required
C-R16-C02 The token in the repository	Short-lived tokens; Revoke on find	Block secrets at commit
C-R16-C04 The contractor who never left	Sponsor review	Expire at the end date
C-R16-C06 Approval fatigue	Batch limits	Show the risk first; Second approver for high risk
N-R18-01 A copied key from another network	Revoke old	Workload binding; Alert new network
N-R18-02 A test credential that opens production	Path restriction	Separate identity; Alert test asks prod
N-R14-06 An identity created outside the normal process	Weekly sweep; Automatic expiry	Cloud policy
N-R14-10 The owning team is disbanded	Attestation	Orphan queue; Limit 14 days

Case	Control(s) masked	Switched off alone, noticed instead
N-R14-12 Overprivileged identities	Person approves	Right sizing report; Wildcard rule
N-R14-16 Retire before you rotate	Delete after hold	Use check; Hold 30 days
P-R15-04 The elevation path is down	Break glass; Fallback review	Second node
P-R15-06 The person never sees the password	Inject credential; Reveal disabled	Rotate after session
P-R15-14 Shared accounts: who did what	Password change	Checkout names the person; Session log tag
P-R15-23 Endpoint privilege management	Log elevations	Remove local admin; Allow list
P-R15-24 Session analytics	Volume threshold	Off hours rule; New target rule
S-R17-07 AI features inside an approved SaaS app	Scope review; Read log	File limit

Limits I recorded

A limit is what the control cannot see. These 33 are written down. The other 34 cases have no limit recorded, which is not the same as having none.

Case	What the control cannot see
N-R14-11 Application retired, identities remain	Attestation signed against an incomplete list.
N-R14-15 Rotate before consumer is updated	A consumer missing from the list still fails (report-job).
P-R15-05 Standing admin group membership	8 members remain and 2 of them are broader than they need.
P-R15-11 Break-glass used at 2 a.m.	The text is not checked for truth.
P-R15-13 Break-glass becomes a side door	A ticket number is not checked against the ticket system.
N-R14-23 Vendor breached, OAuth refresh token still valid	An allowlisted app that is breached still works until revoked.
N-R14-25 Credential stolen from a CI runner, replayed	Bound token still works from inside the runner during the job.
N-R14-07 One identity, three names	My arithmetic was wrong: 9 identities with 2 or 3 names each cannot give 51 entries; and stripping trailing digits merged two real accounts.
N-R14-22 A person logs in with a service account	A password copied during a checkout and used from another tool is not seen by the control.
P-R15-16 Help desk reset path	If the real person is also tricked into approving the notice, the account is lost with both controls on.

Case	What the control cannot see
S-R17-10 Scheduled automations outlive the test window	An extension is accepted on any written reason.
C-R16-C06 Approval fatigue	The rule model says risk-first display only flags the request. Whether a tired approver acts on the flag is human behaviour, which this model does not test.
N-R18-01 A copied key from another network	A replay from inside the real billing workload carries the certificate, so the binding cannot see it.
N-R18-02 A test credential that opens production	A refresh job copies production rows into the test database under the production identity. None of the three controls inspects data, so this is an assertion about my model, not a measurement.
N-R14-02 Secrets in code, config, chat and tickets	A secret inside a screenshot or attachment is missed, even in a place the scans cover.
N-R14-06 An identity created outside the normal process	An administrator can create an account with a tag naming a real person who never agreed. Every check passes it.
N-R14-10 The owning team is disbanded	A team mailing list that nobody reads is accepted as an owner.
N-R14-12 Overprivileged identities	Ninety days of use cannot see a job that runs once a year, so its permission is removed too.
N-R14-13 Rotation on a schedule	A consumer that caches for 3 hours still fails during a 2 hour overlap.
N-R14-16 Retire before you rotate	The use logs miss 2 identities that sign in by an older route, so they are retired while still in use.
P-R15-01 Request privileged access with a ticket and an end time	A ticket that is open but belongs to another system is accepted. Nothing checks that it matches the task.
P-R15-04 The elevation path is down	If both nodes fail for the same reason, such as a shared database, the second node does not help.
P-R15-06 The person never sees the password	A recording tool on the user machine, or the credential in memory on the target, sits outside all three controls. This is an assertion about my model, not a measurement.
P-R15-12 The break-glass drill	An announced drill probably runs better than a real night. My model has no people in it, so it cannot show that. This is an assertion, not a measurement.
P-R15-14 Shared accounts: who did what	A person who hands their session to a colleague is still attributed, to the wrong person.
P-R15-20 Discover privileged accounts and assign owners	The last person to sign in is often not the responsible one, and a wrong owner who confirms anyway passes.
P-R15-21 Separation of duties inside privileged access	Two people approving each other's requests both pass, because each rule looks at one person at a time.
P-R15-22 Integration with ticket system, identity provider and SIEM	The heartbeat travels through the same queue it checks, so a full queue can drop the heartbeat too.
P-R15-23 Endpoint privilege management	An allowed application that can start a shell passes its elevation on to the shell.
P-R15-24 Session analytics	A large copy spread over many sessions stays under a per-session threshold.
S-R17-07 AI features inside an approved SaaS app	A file the user pastes in by hand is not covered by a limit on what the assistant fetches.

Case	What the control cannot see
S-R17-08 An agent built in a low code tool and never registered	An agent under a personal account outside the tenant is not in the app list the scan reads.
S-R17-09 An agent creates credentials and sub agents for itself	The agent asks a person to create the key, and the person does. That sits outside all three controls.

What the numbers do not say

- That any product passes or fails. I tested none.
- That a control is worth its cost. I have no cost data.
- That 57 of 67 is a good score. The guesses and models are mine, so it is a consistency check.
- That the 34 cases with no recorded limit have no limit.

CHAPTER 13

13 The market in 2026

Four deals, one new identity type and a standards project. Checked on 2 November 2026.

In the first half of 2026, four deals closed in which larger security companies bought privileged access, machine access or non-human identity specialists. Microsoft documented identity objects for AI agents. NIST asked the public how to identify and authorize agents. Each fact below has a date, a source and a label for how far I trust it.

4
acquisitions closed, 11 Feb to 29 Jun 2026

600+
commenters on NIST's agent identity concept paper

10
risks in the OWASP NHI Top 10 (2025)

0
products I tested

How to read the labels

Primary: the party's own page or document. **Secondary**: someone else reporting or analysing it. **Vendor**: a sales or press statement I could not check. **Opinion**: a view and not a measurement. The trust label (high, medium or low) says how much I would rely on it. Prices, ownership and roadmaps are the facts most likely to be wrong or to change. Check the vendor's own document before you quote any of them.

The timeline

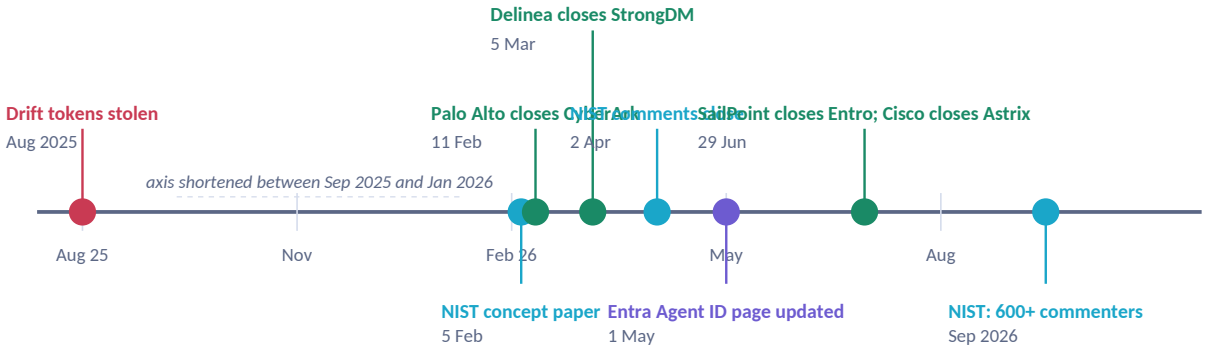


Figure 13.1 Events in this chapter. Green: deals. Cyan: NIST. Violet: Microsoft. Red: the Drift incident.

Who bought whom in 2026

Closed	Buyer	Bought	What the target did	Terms	How I know
11 Feb 2026	Palo Alto Networks	CyberArk	Privileged access and machine identity	$45.00 cash plus 2.2005 Palo Alto shares per CyberArk share	Buyer's release [S1], primary
5 Mar 2026	Delinea	StrongDM	Access for engineering, DevOps and AI environments	Not read	Buyer's release [S2], primary. A data aggregator says 15 Jan [S6]. I used the release.
29 Jun 2026	SailPoint	Entro Security	Non-human identity and credentials security, Tel Aviv	Not disclosed	Buyer's release [S3], primary
29 Jun 2026	Cisco	Astrix Security	Non-human identity security	Not stated in what I read. About $400 million is reported.	Closing: Cisco blog update [S4], primary. Announcement 4 May and the price: CSA note [S5], secondary.

What I take from it (my view). The platform vendors want machine identity inside their platform. Two of the four targets, Entro and Astrix, were non-human identity specialists. StrongDM sold access for engineering teams, and CyberArk sold privileged access. If you chose a specialist a year ago, ask the new owner for the product roadmap in writing. I have not seen any of those roadmaps.

> **Where sources disagree**
> A data aggregator lists the Delinea and StrongDM deal on 15 January 2026 [S6]. Delinea's own release says it completed on 5 March 2026 [S2]. I used the company's release.

AI agents get their own identity objects

Microsoft's documentation for Entra Agent ID, last updated 1 May 2026, describes an agent identity as a special service principal. It has no credentials of its own. A reusable template called a blueprint creates it and acquires tokens for it. It can record a sponsor, the person or group accountable for the agent, who is contacted if there is an incident [S7]. This is vendor documentation: it describes the product and not how well it works.

Why it matters here: in the lab, four agents shared one team key, so the log said only "team key" and a revoke hit all four (N-R14-21). With one key per agent, the log named the agent and the revoke hit one. A sponsor plus an identity per agent is the product-side version of that control. I tested a model of the idea. I did not test Entra.

Standards and guidance

OWASP Non-Human Identities Top 10, 2025

The ten risks, in OWASP's order [S8]: NHI1 Improper Offboarding; NHI2 Secret Leakage; NHI3 Vulnerable Third-Party NHI; NHI4 Insecure Authentication; NHI5 Overprivileged NHI; NHI6 Insecure Cloud Deployment Configurations; NHI7 Long-Lived Secrets; NHI8 Environment Isolation; NHI9 NHI Reuse; NHI10 Human Use of NHI. Chapter 4 maps each one to the lab cases.

NIST NCCoE: software and AI agent identity and authorization

NIST's National Cybersecurity Center of Excellence published a concept paper on 5 February 2026 and took comments until 2 April 2026 [S9]. In September 2026 NIST said it had heard from more than 600 commenters, and that its DevSecOps project will provide the first implementation use case: showing how AI agents can be identified, authenticated and authorized in the software development lifecycle [S10]. A concept paper is not guidance. No control in it is yet something you can be audited against.

The Salesloft Drift incident

Google's threat intelligence group reported that, from as early as 8 August 2025 through at least 18 August 2025, an actor it tracks as UNC6395 used stolen OAuth tokens tied to the Salesloft Drift app to read data in customers' Salesforce accounts. Google saw the actor look for AWS access keys, passwords and Snowflake tokens. Salesloft and Salesforce revoked all active access and refresh tokens on 20 August 2025. On 28 August Google added that tokens for Drift's email integration were also compromised and advised customers to treat every token connected to Drift as potentially compromised [S11]. An AppOmni post says more than 700 organizations were affected and cites an FBI advisory [S12]. I have not seen the FBI document.

> **Where sources disagree**
> One vendor blog dates the same campaign to June 2026 [S13]. Google's advisory says August 2025 [S11]. I used Google and left the other out of the facts.

Other signals, with lower weight

- Tuhin Banerjee argues on the Cloud Security Alliance blog (23 April 2026) that inventory-first discovery is losing ground to short-lived identities, and that ownership and fast revocation are the neglected parts [S14]. Opinion.
- Vercel confirmed unauthorized access in April 2026. Reports say it began with a third-party AI app that an employee had linked with broad permissions [S15]. Secondary, low trust.
- GitGuardian's 2026 report counts 28,649,024 new secrets on public GitHub, 1,275,105 of them AI-service secrets, and 24,008 unique secrets in MCP configuration files [S16]. Vendor research.
- Palo Alto Networks says machine identities outnumber human identities by more than 80 to 1, and that nearly 90% of organizations have suffered an identity-centric breach [S1]. These are the company's statistics in a press release. I did not find the underlying study.

What I think the market still misses

This is my reading of the lab and not a survey.

Gap	What the lab saw	Cases
Checks that a sign-off is true	Owner attestations, break-glass justifications and ticket numbers were accepted as text in my models. I suspect many real workflows are the same.	N-R14-11, P-R15-11, P-R15-13
Speed of revocation across companies	After a vendor breach the clock starts at their notice and not at your inventory. In the model, a replay at minute 30 still worked.	N-R14-23, N-R14-05
Identities that live for minutes	A weekly inventory cannot see a token that lasts an hour. The short lifetime did not matter once binding and revoke were on, which is a reminder to test it alone.	N-R14-25

Gap	What the lab saw	Cases
One view of agent, person and inherited permissions	An AI tool inherited 40 folders when it needed one. An automation using a person's login made the log unreadable.	S-R17-02, S-R17-03

What I did not check

- Analyst reports (Gartner, Forrester, KuppingerCole). They are licensed and I did not read them.
- Any product. I tested none, so I make no claim about what a product does today.
- Pricing beyond what the press releases state. Cisco and Astrix is reported and not confirmed.
- Okta, Microsoft Defender, Ping and the secrets managers, beyond one Microsoft document.
- The FBI advisory on the Salesloft Drift campaign. I only saw it cited.

The full source list is in Appendix C. I plan to re-check this chapter every quarter.

CHAPTER 14

14 What is missing

The gaps I know about. A book that hid them would be weaker.

Gap	Detail
No product was tested.	Every result comes from a small model I wrote. I make no claim about what any product does today.
One author for guesses, models and results.	An outside reader writing guesses first is the stronger test. It is on the roadmap.
Two of the OWASP risks are thinly covered.	Round 18 added a case each for insecure authentication (NHI4) and environment isolation (NHI8). Each risk still rests on two cases. The agentic risks ASI05 to ASI07 have no cases.
Sign-offs that are only text.	Attestations, break-glass reasons, extensions and ticket numbers were accepted as written. I have not tested what checking them would take.
Nothing cloud-specific.	AWS, Azure and Google Cloud each have their own key and role habits. The models are generic.
Catalogue rows that need a real environment.	Some rows cannot be shown in a small model. The completeness register on the website gives each one a final status and a reason. Nothing was run for them.
No Kubernetes workload identity.	It has its own tooling and is out of scope for this run.
No cost or performance data.	The models cannot say what a control costs to run or how it slows people down.
No Indian rules check.	RBI, CERT-In and the data protection law were not mapped. I make no compliance claim.
Licensed analyst reports were not read.	Gartner, Forrester and KuppingerCole are licensed. The market chapter uses public primary sources.
Mac commit times are not recorded.	I have the commit hashes. I did not write down exactly when each one was made, and I cannot tell you which file commit f902ea8 holds.
Accessibility and speed checks of the website pages.	Lighthouse and a screen-reader pass are not run yet. They concern the web pages, not this book.
A hash proves a file did not change, not when I wrote it.	It shows the guess file is the same file that was committed. The commit time is the only date evidence.

Where you can help

If you work on identity or privileged access and you think a case is wrong, or you can think of a variant that breaks a control, tell me. I will add it and keep the original on the page. If you would like to write guesses for a case before you see mine, I would like that most of all.

CHAPTER 15

15 Roadmap

What is done, what I am checking, and what comes next. No invented deadlines.

I have not put dates on the future items. A date I cannot keep is a claim I cannot back, so the order is the plan. Posting anything publicly waits for my own go.

Done (10)

When	Item	Detail
31 Oct 2026	**Use-case catalogue and test plan**	Rows for non-human identity, privileged access and shadow AI, with business use cases, a test plan and a retro. Six gap rows were added later.
2 Nov 2026	**First run: 27 cases**	Guesses hashed and committed first. 25 matched, 2 wrong.
2 Nov 2026	**Second run: 19 cases**	13 stretch cases and 6 chain tests. Mac and sandbox output matched.
2 Nov 2026	**Lab page, PDF book, video**	46 animated case cards at launch, a book, and a 54-second silent video. Rebuilt on 10 November with all 67 cases.
2 Nov 2026	**Framework, market, method, audit, roadmap, explainer**	This set of pages, with downloadable audit data.
10 Nov 2026	**Round 18: two cases**	NHI4 and NHI8, the two thin OWASP items. 1 guess wrong (the alert count) and 2 controls masked. Mac and sandbox output matched.
10 Nov 2026	**Round 19: the 19 queued cases**	Guesses committed first as a2dc1fd. 14 matched in full, 5 had a wrong guess, and 14 of 57 controls changed nothing the case counts.
10 Nov 2026	**Completeness register**	Every one of the 193 catalogue rows has a final status. Rows that need a real environment were not run, and each has a reason.
10 Nov 2026	**Counts brought to 67 cases and 10 wrong guesses**	Lab page, audit data and files, framework, method, explainer, the PDF book and the video all rebuilt from the same data.
10 Nov 2026	**Stage 2 pages**	Tool fit, capability matrix, risk scores, requirements, SIT and UAT plan and control mapping, now updated with rounds 18 and 19.

Now (1)

When	Item	Detail
Not run	**Lighthouse and a screen-reader pass**	On 10 November I checked headings, table captions, image text and phone width on the new and changed pages. Lighthouse and a screen reader are still to do, in a normal browser.

Next (3)

When	Item	Detail
Parked	**Rows that need a real environment**	The catalogue rows that cannot be modelled in memory are listed in the completeness register with a reason for each.
Parked	**Read ATT&CK campaign C0064**	I noted it but have not read it.
Parked	**Check vendor wording**	The PAM and secrets-manager descriptions on the market page. Product claims need the vendor's own documents.

Later (6)

When	Item	Detail
No date set	**An outside reader writes guesses first**	A stronger test than my own: someone else guesses a few cases before seeing mine.
No date set	**Cloud-specific variants**	AWS, Azure and Google Cloud each have their own key and role habits.
No date set	**Indian rules check**	RBI, CERT-In and the data protection law. I will make no compliance claim.
No date set	**Cost data**	None yet.
Every quarter	**Re-check the market page**	Prices, ownership and roadmaps change fastest. Watch the NIST agent identity project, whose first use case is in DevSecOps.
Series	**Next topics**	Conditional access, MFA, 2FA and SSO.

Rules I follow for every item

1. Guesses first. Write what I expect, hash it, commit it, then write the code.
2. Wrong guesses stay on the page next to the right answer.
3. Every case gets a limit: what the control cannot see.
4. Market facts get a date, a source and a trust label. If I cannot check one, I say so.
5. No product is tested, so none is endorsed or criticised.

APPENDIX A

Guess files and hashes

The evidence that the guesses came first.

Each guess file was hashed with SHA-256 on the Mac and committed before the code for those cases existed. The hashes below are the ones recorded at the time. You can recompute them yourself.

File	Cases	SHA-256
`guesses-round-14-15.md` Rounds 14 and 15 (20 cases)	20	`f06f355eb80c151cb237ca4ef0c09dad` `9bc995fe5d395dca03f8756b0c69c784`
`guesses-round-17.md` Round 17, shadow AI (4 cases)	4	`4e6dfc1a80b2fa1e0a0da0a129882e87` `fdd3be931b5dddafd018d92c05dc8b7c`
`guesses-gap-cases.md` Gap cases (3 cases)	3	`7d3aee7a941b3915915690294e97ef22` `118957fc82b5505a1a0502d6e4bd5f8d`
`guesses-stretch-and-chains.md` Stretch cases and chain tests (19 cases)	19	`40c2f87c9f3fa914b48a09c4abf016f1` `189b02ea91f07232e456275b842489ed`
`guesses-round-19.md` Round 19, the queued cases (19 cases)	19	`729e16f25cf4a67e34ab87607b80ad59` `ae0935d4d72b1a087dfa0cb2bcec1b4b`
`guesses-round-18.md` Round 18, NHI4 and NHI8 (2 cases)	2	`9155e0783c997589bc8daf2a6bc2dad4` `afa1cec0a2e183f9254665f847404180`

Commits on the Mac

Commit	What it holds
`7737a2c`, `314d4ee`	First run: guess files and code.
`474ddc9`	The three gap-case guesses.
`f902ea8`	First run. I did not record which file it holds.
`78d7e3e`	Second-run guesses (13 stretch cases and 6 chain tests), before any code.
`05235fe`	Second-run code and results.
`e50df1b`	Round 18 guesses (2 cases), before any code.
`ce3c57e`	Round 18 code and results.
`a2dc1fd`	Round 19 guesses (19 cases), before any code.
`cbec7a8`	Round 19 code and results.

A hash proves a file did not change after the commit. It does not prove when I wrote it. The commit time is the only date evidence, and I did not record those times.

Check them yourself

Step	Do this	You should see
1	Download `nhi-lab/evidence/` from the repository.	A folder with guesses/, the case files cases.py to cases4.py, the runners run.py to run4.py and verify.py.
2	Run `python3 verify.py` in that folder.	"6 of 6 guess files match the recorded hash." Tested in the build sandbox on 10 November 2026.
3	Run `python3 run.py` `python3 run2.py` then `python3 run3.py`. They need only Python 3 and check the hashes first.	The tables in RESULTS.md and RESULTS-stretch.md. On 2 November 2026 the results were identical to the committed ones except for the time stamp.

APPENDIX B

Audit table

All 67 cases in one table. The same data is on the website as CSV and JSON.

Case	Title	Step	Run	Guess	Masked	Limit
N-R14-01	Inventory misses a source	Find	1	matched		
N-R14-03	Long-lived CI variable read by another job	Store and issue	1	matched		
N-R14-04	Certificate with no owner expires	Rotate and expire	1	matched		
N-R14-05	Old OAuth grant, vendor breached	Rotate and expire	1	matched		
N-R14-09	Identity with no owner	Own	1	matched		
N-R14-11	Application retired, identities remain	Retire and respond	1	matched		yes
N-R14-14	Rotation fails silently	Rotate and expire	1	matched		
N-R14-15	Rotate before consumer is updated	Rotate and expire	1	matched		yes
N-R14-17	Loose federation trust	Limit	1	matched		
N-R14-18	Front door for new identities	Own	1	matched		
P-R15-02	Just-in-time window	Rotate and expire	1	matched		
P-R15-03	Work runs past the window	Rotate and expire	1	matched		
P-R15-05	Standing admin group membership	Limit	1	matched		yes
P-R15-07	Direct login still open	Limit	1	matched		
P-R15-08	Recording gap on one target	Find	1	matched		
P-R15-09	Two approvers for Tier 0	Limit	1	matched		
P-R15-11	Break-glass used at 2 a.m.	Watch	1	matched		yes
P-R15-13	Break-glass becomes a side door	Watch	1	matched		yes
P-R15-17	Vendor session	Retire and respond	1	matched		
P-R15-18	Vendor person leaves the vendor	Own	1	matched		
S-R17-01	Personal OAuth grant to an AI tool	Retire and respond	1	matched		
S-R17-03	Agent runs under a person's account	Own	1	matched		
S-R17-04	Ghost credential	Own	1	matched		
S-R17-05	Secrets in AI-assisted code and config	Store and issue	1	wrong		
N-R14-23	Vendor breached, OAuth refresh token still valid	Retire and respond	1	matched	yes	yes
N-R14-24	Secrets in env variables not marked sensitive	Store and issue	1	matched		
N-R14-25	Credential stolen from a CI runner, replayed	Store and issue	1	wrong	yes	yes
N-R14-07	One identity, three names	Find	2	wrong		yes
N-R14-19	Scoring: rank so the top gets fixed first	Rotate and expire	2	matched		

Case	Title	Step	Run	Guess	Masked	Limit
N-R14-20	Close only when the old secret is dead	Rotate and expire	2	matched		
N-R14-21	Agents share a team credential	Own	2	matched		
N-R14-22	A person logs in with a service account	Limit	2	matched		yes
P-R15-10	Phishing-resistant MFA for admins	Limit	2	matched		
P-R15-15	The vault, its backups and who can read them	Store and issue	2	matched		
P-R15-16	Help desk reset path	Limit	2	matched	yes	yes
P-R15-19	A vendor is needed at 2 a.m.	Retire and respond	2	matched		
P-R15-25	Mass rotation after a breach	Rotate and expire	2	matched		
S-R17-02	AI tool inherits the full permissions of the person	Limit	2	matched		
S-R17-06	AI-service keys leak into repositories	Find	2	matched	yes	
S-R17-10	Scheduled automations outlive the test window	Retire and respond	2	matched		yes
C-R16-C01	The forgotten service account	Store and issue	2	wrong	yes	
C-R16-C02	The token in the repository	Store and issue	2	matched	yes	
C-R16-C04	The contractor who never left	Retire and respond	2	matched	yes	
C-R16-C05	The break-glass password everyone knows	Watch	2	matched		
C-R16-C06	Approval fatigue	Limit	2	matched	yes	yes
C-R16-C17	The old door	Limit	2	matched		
N-R18-01	A copied key from another network	Store and issue	3	wrong	yes	yes
N-R18-02	A test credential that opens production	Limit	3	matched	yes	yes
N-R14-02	Secrets in code, config, chat and tickets	Store and issue	4	matched		yes
N-R14-06	An identity created outside the normal process	Own	4	matched	yes	yes
N-R14-10	The owning team is disbanded	Own	4	matched	yes	yes
N-R14-12	Overprivileged identities	Limit	4	matched	yes	yes
N-R14-13	Rotation on a schedule	Rotate and expire	4	matched		yes
N-R14-16	Retire before you rotate	Retire and respond	4	matched	yes	yes
P-R15-01	Request privileged access with a ticket and an end time	Limit	4	matched		yes
P-R15-04	The elevation path is down	Limit	4	matched	yes	yes
P-R15-06	The person never sees the password	Store and issue	4	wrong	yes	yes
P-R15-12	The break-glass drill	Watch	4	wrong		yes
P-R15-14	Shared accounts: who did what	Watch	4	matched	yes	yes
P-R15-20	Discover privileged accounts and assign owners	Find	4	matched		yes
P-R15-21	Separation of duties inside privileged access	Limit	4	matched		yes
P-R15-22	Integration with ticket system, identity provider and SIEM	Watch	4	wrong		yes
P-R15-23	Endpoint privilege management	Limit	4	matched	yes	yes
P-R15-24	Session analytics	Watch	4	matched	yes	yes
S-R17-07	AI features inside an approved SaaS app	Limit	4	matched	yes	yes

Case	Title	Step	Run	Guess	Masked	Limit
S-R17-08	An agent built in a low code tool and never registered	Find	4	wrong		yes
S-R17-09	An agent creates credentials and sub agents for itself	Limit	4	wrong		yes

Masked: at least one control could be switched off alone with no change. Limit: a limit is written down for the case. Download the full table, with 16 columns, from roshantrivedi.co.in/nhi-lab/audit/.

APPENDIX C

Sources

Every source used in the market chapter. Retrieved 2 November 2026 unless noted.

#	Title and note	Publisher and date	Type	Trust
1	Palo Alto Networks completes acquisition of CyberArk to secure the AI era Read in full. Statistics in it are the company's own.	Palo Alto Networks (press release) 11 Feb 2026	primary	high
2	Delinea completes StrongDM acquisition I read the opening of the release in a search result, not the whole page.	Delinea (press release) 5 Mar 2026	primary	medium
3	SailPoint completes acquisition of Entro Security Read in full. Terms not disclosed.	SailPoint (press release) 29 Jun 2026	primary	high
4	Cisco announces intent to acquire Astrix Security (updated 29 June 2026) I read the update line in a search result: "We have completed the acquisition of Astrix Security."	Cisco (blog) Updated 29 Jun 2026	primary	medium
5	AI agent identity consolidation: NHI market concentration risk Source for the 4 May 2026 announcement date and the reported price of about $400 million.	Cloud Security Alliance, research note 2026	secondary	medium
6	Acquisitions by Delinea Lists 15 Jan 2026. Disagrees with Delinea's release (5 Mar 2026). I used the release.	Tracxn (data aggregator) Oct 2026	secondary	low
7	Overview of agent identities in Microsoft Entra Agent ID Vendor documentation. Describes the product, not how well it works.	Microsoft Learn Page updated 1 May 2026	primary	high
8	OWASP Non-Human Identities Top 10, 2025 Names and descriptions of the ten risks.	OWASP 2025	primary	high
9	Accelerating the adoption of software and AI agent identity and authorization (concept paper) Comments closed 2 April 2026. A concept paper only, not guidance.	NIST NCCoE / CSRC 5 Feb 2026	primary	high
10	Comments on software and agentic AI identity concept paper Source for 600+ commenters and the DevSecOps first use case.	NIST news Sep 2026	primary	high
11	Widespread data theft targets Salesforce instances via Salesloft Drift Source for the dates and the advice to treat connected tokens as compromised.	Google Cloud Threat Intelligence Group Aug 2025, updated 28 Aug 2025	primary	high
12	Salesloft Drift-Salesforce breach (UNC6395) Relays "over 700 organizations" and cites FBI advisory CSA-2025-250912. I did not open the FBI document.	AppOmni (vendor blog) 2025	secondary	medium
13	Salesloft Drift OAuth token breach (Icarus campaign) Gives June 2026 dates that contradict Google's own advisory (August 2025). I did not use it.	Rescana (vendor blog) undated in my copy	secondary	low
14	We are fixing the wrong problem in non-human identity security An opinion built on named incidents, with no survey data.	Tuhin Banerjee, Cloud Security Alliance blog 23 Apr 2026	opinion	medium

#	Title and note	Publisher and date	Type	Trust
15	Vercel security breach, April 2026 Summary only. Attribution and some details are unverified.	Strapi (blog summary) Apr 2026	secondary	low
16	The State of Secrets Sprawl 2026 Vendor research on 2025 data. Figures carried from my earlier read; I did not re-fetch the report in this pass.	GitGuardian 2026	vendor	medium

Other reading

- OWASP Top 10 for Agentic Applications (2026). I read a summary by Teleport, so check the OWASP original before quoting.
- Wiz blog on a Non-Human Identities dashboard (February 2024), the Clutch Security page on Okta integrations, and SailPoint's Entro documentation. These are vendor descriptions and I did not test any of them.

APPENDIX D

Glossary

The words used in this book.

Term	Meaning
Agent identity	A credential or account that an AI agent uses, kept separate from any person's login.
Attestation	A signed statement, usually by an owner, that something is true. In the lab it was text and was not checked.
Blast radius	How much damage a credential can do if it is stolen or misused.
Break-glass account	An emergency account used when normal sign-in is down. It should be rare, loud and rotated after use.
Chain test	A series of links an attacker needs. The test records which link each control stops.
Consumer	An application or job that uses a secret. Change the consumer before the secret.
Control	A rule or check meant to stop a failure.
Front door	The place where new identities are created or approved, and where the wrong ones can be refused.
Ghost credential	A key or account that nobody owns and nobody remembers.
Guess file	The written expectations for a group of cases. It is hashed and committed before any code is written.
Hash (SHA-256)	A 64-character fingerprint of a file. Change one character in the file and the fingerprint changes.
Just-in-time (JIT) access	Access granted for a short window when it is needed and removed when the window ends.
Limit	What a control cannot see. Every case should have one.
Masked	Switching a control off alone changed nothing, because another control covered it or it did not matter in that case.
Noticed	Switching that one control off changed a result.
Non-human identity (NHI)	An account or credential used by software and not by a person: a service account, API key, token, certificate, workload or agent.
OAuth grant	Permission a person or organisation gives an app to act on their data, usually through a token.
Replay	Using a stolen token again from somewhere else.
Roll forward	Issue a new value, move users to it, and only then remove the old one.
Service account	An account an application or job uses to sign in.
Sponsor	The person accountable for a vendor or agent identity, who is contacted if there is an incident.
Tier	A rating of how much damage an identity can do. Tier 0 can control identity systems or all of production, Tier 1 reaches production data or systems, Tier 2 reaches little. These tiers are a proposal. Your organisation sets the thresholds.
Wrong guess	A number or a ranking in my guess that did not equal the result. The book keeps both.

AUTHOR

About the author

Roshan Trivedi, Bengaluru.

I make secure access something people can actually use. I have spent fourteen years in identity and privileged access, and I now own an enterprise credential-management platform and its privileged access product. In practice that means architecture, service design, standards and the roadmap, and just as much the work of getting teams to adopt it and being able to show an auditor how it works.

Most of my thinking lately goes into one question: what happens to identity when the user is a service account, a pipeline or an AI agent? This lab is one answer, tested in public, with the mistakes left in.

The case studies and labs on my site are anonymised. They leave out employers, clients and internal data on purpose.

How to cite this book
Roshan Trivedi, "Machine identities, tested in public", edition 2, 10 November 2026. roshantrivedi.co.in/nhi-lab/.
Creative Commons Attribution 4.0 (CC BY 4.0). You may share and adapt it, including commercially, if you credit "Roshan Trivedi, roshantrivedi.co.in" and link to the licence.

What this book is not
It is not legal advice, a compliance claim or a product review. Mappings to OWASP, NIST and ISO are my own reading. All data is made up.

Check my work.

Every guess file, hash, result and script is in the public repository. The audit page lets you filter the 67 cases and download them as CSV or JSON. If a case is wrong, tell me. I will fix it and keep the original on the page.

roshantrivedi.co.in/nhi-lab/

roshantrivedi.co.in/nhi-lab/audit/

roshantrivedi.co.in/nhi-lab/framework/